

555.4

Cloud Logging and Monitoring

Licensed To: Arvind Pariti <paritiarvind@gmail_com> April 13, 2026



PLEASE READ THE TERMS AND CONDITIONS OF THIS COURSEWARE LICENSE AGREEMENT ("CLA") CAREFULLY BEFORE USING ANY OF THE COURSEWARE (DEFINED BELOW) ASSOCIATED WITH THE SANS INSTITUTE COURSE. THIS IS A LEGAL AND ENFORCEABLE CONTRACT BETWEEN YOU (THE "USER") AND THE ESCAL INSTITUTE OF ADVANCED TECHNOLOGIES, INC. /DBA SANS INSTITUTE ("SANS INSTITUTE") FOR THE COURSEWARE. BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA.

With this CLA, SANS Institute hereby grants User a personal, non-exclusive license to use the Courseware subject to the terms of this CLA. Courseware means all printed materials, including course books and lab workbooks, slides or notes, as well as any digital or other media, audio and video recordings, virtual machines, software, technology, or data sets distributed by SANS Institute to User for use in the SANS Institute course associated with the Courseware. User agrees that the CLA is the complete and exclusive statement of agreement between SANS Institute and User and that this CLA supersedes any oral or written proposal, agreement or other communication relating to the subject matter of this CLA.

BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA. USER FURTHER AGREES THAT ANY BREACH OF THE TERMS OF THIS CLA MAY CAUSE IRREPARABLE HARM AND SIGNIFICANT INJURY TO SANS INSTITUTE, AND THAT SANS INSTITUTE MAY ENFORCE THESE PROVISIONS BY INJUNCTION (WITHOUT THE NECESSITY OF POSTING BOND), SPECIFIC PERFORMANCE, OR OTHER EQUITABLE RELIEF.

If User does not agree to the terms of this CLA, User should not access the Courseware. User may return the Courseware to SANS Institute for a refund, if applicable.

User may not copy, reproduce, re-publish, distribute, display, modify or create derivative works based upon all or any portion of the Courseware, in any medium, whether printed, electronic or otherwise, for any purpose, without the express prior written consent of SANS Institute. User may not sell, rent, lease, trade, share, or otherwise transfer the Courseware in any way, shape, or form to any person or entity without the express written consent of SANS Institute. Additionally, User may not upload, submit, or otherwise transmit Courseware to any artificial intelligence system, platform, or service for any purpose, regardless of whether the intended use is commercial, educational, or personal, without the express written consent of SANS Institute. User agrees that the failure to abide by this provision would cause irreparable harm to SANS Institute that is impossible to quantify. User therefore agrees to a base liquidated damages amount of \$5000.00 USD per item of Courseware infringed upon or fraction thereof. In addition, the base liquidated damages amount shall be doubled for any Courseware less than a year old as a reasonable estimation of the anticipated or actual harm caused by User's breach of the CLA. Both parties acknowledge and agree that the stipulated amount of liquidated damages is not intended as a penalty, but as a reasonable estimate of damages suffered by SANS Institute due to User's breach of the CLA.

If any provision of this CLA is declared unenforceable in any jurisdiction, then such provision shall be deemed to be severable from this CLA and shall not affect the remainder thereof. A written amendment or addendum to this CLA that is executed by SANS Institute and User may accompany this Courseware.

SANS Institute may suspend and/or terminate User's access to and require immediate return of any Courseware in connection with any (i) material breaches or material violation of this CLA or general terms and conditions of use agreed to by User, (ii) technical or security issues or problems caused by User that materially impact the business operations of SANS Institute or other SANS Institute customers, or (iii) requests by law enforcement or government agencies.

SANS Institute acknowledges that any and all software and/or tools, graphics, images, tables, charts or graphs presented in this Courseware are the sole property of their respective trademark/registered/copyright owners, including:

The Apple® logo and any names of Apple products displayed or discussed in this book are registered trademarks of Apple, Inc.

PMP® and PMBOK® are registered trademarks of PMI.

SOF-ELK® is a registered trademark of Lewes Technology Consulting, LLC. Used with permission.

SIFT® is a registered trademark of Harbingers, LLC. Used with permission.

VMware Workstation Pro®, VMWare Workstation Player®, VMWare Fusion®, and VMware Fusion Pro® are registered trademarks of VMware, Inc. Used with permission.

Governing Law: This CLA shall be governed by the laws of the State of Maryland, USA.

Courseware licensed to User under this CLA may be subject to export laws and regulations of the United States of America and other jurisdictions. User warrants he or she is not listed (i) on any sanction programs list maintained by the U.S. Office of Foreign Assets Control within the U.S. Treasury Department ("OFAC"), or (ii) denied party list maintained by the U.S. Bureau of Industry and Security within the U.S. Department of Commerce ("BIS"). User agrees to not allow access to any Courseware to any person or entity in a U.S. embargoed country or in violation of a U.S. export control law or regulation. User agrees to cooperate with SANS Institute as necessary for SANS Institute to comply with export requirements and recordkeeping required by OFAC, BIS or other governmental agency.

All reference links are operational in the browser-based delivery of the electronic workbook.

Licensed To: Arvind Pariti <paritiarvind@gmail.com> April 13, 2026 SEC555_4_K02_01

Cloud Logging and Monitoring

DETECTION ENGINEERING AND SIEM ANALYTICS

© 2025 SANS INSTITUTE | ALL RIGHTS RESERVED

K02_01

This area is intentionally left blank.

Table of Contents

Azure Cloud Logging	3
Lab 4.1: Logging Unauthorized Access to Sensitive Data	55
Microsoft Defender Suite and Copilot for Security	56
Lab 4.2: Defender for Cloud	99
Microsoft Sentinel and KQL	100
Lab 4.3: Sentinel and KQL	133
AWS Cloud Logging	134
Lab 4.4: Creating an AWS Lab, Configuring and Testing CloudWatch	158
Contacts and Resources	159

This area is intentionally left blank.

Course Roadmap

Section 1: Detection Engineering and SIEM Architecture

Section 2: Network and Endpoint Analysis

Section 3: Asset Discovery, Baselines, and UEBA

Section 4: Cloud Logging and Monitoring

Section 5: Alerting and Detection Engineering Pipelines



- Azure Cloud Logging
 - ☐ Lab 4.1: Logging Unauthorized Access to Sensitive Data
- Microsoft Defender Suite and Copilot for Security
 - ☐ Lab 4.2: Defender for Cloud
- Microsoft Sentinel and KQL
 - ☐ Lab 4.3: Sentinel and KQL
- AWS Cloud Logging
 - ☐ Lab 4.4: Creating an AWS Lab, Configuring and Testing CloudWatch

This area is intentionally left blank.

Module Objectives



The student will gain an understanding of the need for cloud logging and monitoring, in addition to working with various Azure log sources, the Azure Monitor, and Log Analytics Workspaces.

This area is intentionally left blank.

Should I Worry About the Cloud? (1)

T-Mobile (2023)

- **Impact:** >30,000,000 clients.
- **Data Obtained:** Personal information (names, addresses, SSN, driver's license numbers).
- **Reason:** AWS S3 bucket misconfiguration.

Toyota Motor (2015-2023)

- **Impact:** 260,000 customers.
- **Data Obtained:** Vehicle-mounted terminal ID (identification number for each in-vehicle device (navigation terminal)), chassis number (identification number assigned to each vehicle), vehicle location information. Also, potential video footage taken from a dashcam captured outside the vehicle, collected from their corporate services.
- **Reason:** Insufficient enforcement of the rules for handling data on a cloud server.

Microsoft (2023)

- **Impact:** Emails of key executives and various employees.
- **Data Obtained:** The information that was obtained was used to yield subsequent access to source code repositories and customer secrets contained in emails.
- **Reason:** APT29 compromised a legacy test tenant account, using a password spray attack to gain initial access. That later led to the ability to pivot over to the actual MS corporate tenant.

In security, one of the most common sayings tends to be not to ignore the basics. Yet, some of those basics tend to get ignored quite frequently. When attempting to create a new Azure storage blob or AWS S3 bucket, they both have public access disabled by default. It's the vendor setting to keep us out of harm's way. Yet sometimes these settings are manually changed (for example, to be able to share something quickly), with no password requirement for a client or an external partner. Quick and dirty is not what an ideal security approach looks like. Security professionals should scrutinize settings for validity and find the most optimal ones to protect organizations at scale.

OWASP was founded in 2001. The first OWASP Top 10 was published in 2003. As an example, it contained command injection. In the most recent one published in 2021, we still have injection ranking at position 3. One may wonder, why is that? Why do we still miss some of the fundamentals? It is often because of lack of visibility. A few years ago, a client of the author asked to monitor their international environment. At some point, there was an extended scanning activity taking place at a small branch of that company. That scan was not caught by any of the security tools. The client was furious. But when drilling down into that, the branch in question was never onboarded in any monitoring tool. There were no logs ingested to indicate anything concerning.

Enter the SANS motto: **Prevention is ideal, detection is an absolute must.** How would we ever see them coming, if we have blinders on?

References:

- <https://sec555.com/1081c>
- <https://sec555.com/410ea>
- <https://sec555.com/m0v7e>
- <https://sec555.com/46fh5>

Should I Worry About the Cloud? (2)

CommuteAir (2023)

- **Impact:** More than 1.5 million individual records.
- **Data Obtained:** DHS "No Fly" and "Selective Screening" lists, CommuteAir employee information.
- **Reason:** Exposed Jenkins server was publicly facing and identifiable over ZoomEye (Chinese equivalent to Shodan). Hard-coded credentials in it were used to access AWS S3 buckets containing critical data.

Uber (2022)

- **Impact:** Full administrative access to Uber's AWS, GCP, vSphere, and Windows environments.
- **Data Obtained:** Sales metrics, Slack information, corporate EDR solution, and other internal data.
- **Reason:** After purchasing access credentials for an external contractor over the dark web, the attacker performed an MFA bombing attack with numerous MFA requests sent to the employee and even contacted them via WhatsApp to convince them to accept, until they did.

Uber (2014 and 2016)

- **Impact:** Sensitive data of 100,000 users (2014), 57 million users (2016).
- **Data Obtained:** Sensitive data, including users' names and driver's license numbers. More than 200 user bank account numbers (2014). In 2016, 57 million users' names and driver's license numbers were exposed.
- **Reason:** Keys found in GitHub. A public key was identified in a repository in 2014, while in 2016 GitHub credentials that were stolen led to an engineer's private repository.

References:

- <https://sec555.com/vma3b>
- <https://sec555.com/39g5c>
- <https://sec555.com/4gup9>

Microsoft Azure Shared Responsibility Model

	Responsibility	SaaS	PaaS	IaaS	On-prem
Responsibility always retained by the customer	Information and data	Customer	Customer	Customer	Customer
	Devices (Mobile and PCs)	Customer	Customer	Customer	Customer
	Accounts and identities	Customer	Customer	Customer	Customer
Responsibility varies by type	Identity and directory infrastructure	Shared	Shared	Customer	Customer
	Applications	Shared	Shared	Customer	Customer
	Network controls	Shared	Shared	Customer	Customer
	Operating system	Shared	Shared	Customer	Customer
Responsibility transfers to cloud provider	Physical hosts	Microsoft	Microsoft	Microsoft	Customer
	Physical network	Microsoft	Microsoft	Microsoft	Customer
	Physical datacenter	Microsoft	Microsoft	Microsoft	Customer

■ Microsoft
 ■ Customer
 ▬ Shared

When using a cloud service, it's extremely important to remember that you can't shift responsibility. For example, if you're providing security monitoring services to one of your end clients and your detection instance is hosted in Microsoft Azure, and that goes down for an amount of time, you can't just say to your end client that it's not your fault. You can always caveat that condition in your service contract, but you can't take yourself out of the equation altogether. Microsoft Azure's shared responsibility model, shown in the above image, shows where responsibility lies, regarding different scenarios.

Example 1: You are using IaaS and the network goes down. Microsoft is responsible in that case.

Example 2: You are using PaaS and you are wondering about network controls, since you see they're considered shared. Microsoft is responsible for making the Network Security Groups (NSG) and firewall services available. The client is responsible for configuring the NSG inbound and outbound rules. If you sustain a compromise because that hasn't happened at all or at an adequate level, then it's not the vendor's fault. Responsibility in that case lies with the cloud client.

Another very important point to remember is that the data, devices, accounts, and access management are always the responsibility of the client. That means that if you need your data to be encrypted, you need to make certain that it is. That won't be something that Microsoft does for you. Having said that, when encryption is enabled, you have an option to select between your keys being managed by Microsoft or yourself. In general, it is highly recommended to read the documentation very carefully and to also negotiate contractual terms and service level agreements and solidify those so you know exactly what responsibilities the vendors have vs. the ones the client has.

Image reference:

- <https://sec555.com/npq0f>

Microsoft Azure: Well-Architected Framework



- **Cost Optimization**
 - Balance out project cost, available budget, and still get the best results.
- **Security**
 - Protect the CIA triad.
- **Reliability**
 - Ensure environmental stability and appropriate operation.
- **Operational Excellence**
 - Promote DevOps.
- **Performance Efficiency**
 - How does your workload react to demand changes?

Azure uses the Well-Architected Framework, which focuses on five main pillars:

1. Cost Optimization
2. Security
3. Reliability
4. Operational Excellence
5. Performance Efficiency

Cost Optimization

Everything costs money, and security professionals are always surrounded by that challenge. What's the most cost-efficient way of delivering a project or performing an activity? Cost optimization focuses on allowing the business to achieve its goals, within the agreed financial budget. That includes obtaining the necessary tools, licenses, and resources to deliver with exceptional quality. The cost of some of these items may be elevated, but perhaps the quality of the service the business has requested justifies that. After all, it's about the ROI (Return on Investment). To go toward that, the team involved should have a very good perception of what each component costs, how it ties with the overall business goals, and be aware of the fluctuations of cost as time progresses. Always try to design with a view to providing maximum efficiency for the business, but keep in mind what you are spending. I.e., does it make sense to log network security group flow logs for 12 months? On the flipside of that, does it make sense to only keep them for 10 days? Always account for the total cost of ownership. It's not just about initial licensing and configuration but also about staff training, so this work can be maintained and repeated when required. Keep close monitoring of your deployment and perform often assessments about possible redesign, improvements, or spinning resources down when they're not required so you can be as cost-efficient as possible. One of the most common omissions in cloud deployments is forgetting resources (e.g., virtual machines) powered on, even if not needed, thus incurring a heavy cost at the end. Microsoft has a full cost optimization checklist available.¹

Security

Heavy emphasis is given on protecting the CIA (Confidentiality, Integrity, Availability) of any organization. To provide ample protection, appropriate procedures need to be created to empower you to respond to any given security incident that may take place. Concepts like secure code development, network segmentation, implementing a Zero-Trust model, and adopting a least privilege approach when assigning users privileges in the environment become of paramount importance. Protecting CIA requires performing asset identification and inventory creation, data classification, and assigning data appropriate labels (e.g., public, internal, confidential, restricted). After that, data should be protected in accordance with its level of importance for the business. Techniques include access control, maintaining a need-to-know access mentality, and extensive use of encryption. Creating a backup policy and adhering to it will go a long way to allow data to be restored in case of an incident. A core component here is logging and monitoring organizational activity (which is the main focal point of this course). Microsoft has a full security checklist available.²

Reliability

This pillar's main focus is maintaining a stable and working environment while trying to tackle outages, service disruptions, and other types of failure. A critical factor is what the most important assets and services are to the business that need to continue constant operation; i.e., if the business is a worldwide retailer, it may always require its web servers to be available to allow clients to shop. Understanding what parts of the business need to continue operational unimpeded vs. other parts that can continue operating in a temporary degraded state is very important, as it will allow effort prioritization. Working out when resources need to be scaled up to support increased business needs before that starts impacting the business needs is also quite vital. Having proper recovery plans and procedures in place and testing those are extremely important for the organization to continue operating in cases of faults. Combining that with enough resource redundancy (e.g., network, virtual machines, power, and more) is key to successfully sustaining operations. Microsoft has a full reliability checklist available.³ Using automated tools for changes and solid testing and deployment methodologies will also help maintain a stable and productive environmental posture.

Operational Excellence

The main point for operational excellence is working in a DevOps (Development and Operations) methodology. That means, encouraging the software developers and operational teams to work together with business-aligned goals and objectives. Items to consider include using common tools, allowing the operation teams to provide feedback to developers about working and non-working components, documenting processes and system operation, and spreading knowledge across the environment. Microsoft has a full operational excellence checklist available.⁴

Performance Efficiency

This pillar answers the key question of "How does your workload react to demand changes?"

To answer that, you first need to know what your business requirements are and set appropriate measuring targets to allow you to continuously measure your environment's performance. Historical data analysis and trending can greatly help to paint a picture of expected future use. Remember to build things with a future scalability viewpoint and always perform ample capacity planning to empower you to take necessary decisions. Ensure you include proper system testing techniques and methodologies in your planning to meet business demands. Don't hesitate to change non-working components or architectures, if that is for the greater good of the environment. Microsoft has a full performance efficiency checklist available.⁵

1. <https://sec555.com/uk9g8>
2. <https://sec555.com/jtgyz>
3. <https://sec555.com/6khca>
4. <https://sec555.com/10fdl>
5. <https://sec555.com/tx0dh>

Image reference:

- <https://sec555.com/cm6bu>

Licensed To: Arvind Pariti <paritiarvind@gmail_com> April 13, 2026

Microsoft Azure: Holistic Monitoring Strategy

1. **Establish a security baseline** that's aligned to compliance requirements, industry standards, and platform recommendations.
2. **Maintain a secure development lifecycle** by using a hardened, automated, and auditable supply chain.
3. **Classify and consistently apply sensitivity and information type labels** on all workload data and systems involved in data processing.
4. **Create intentional segmentation and perimeters** in your architecture design and in the workload's footprint on the platform.
5. **Implement strict, conditional, and auditable identity and access management (IAM)** across all workload users, team members, and system components.
6. **Isolate, filter, and control network traffic** across both ingress and egress flows.
7. **Encrypt data by using modern, industry-standard methods** to guard confidentiality and integrity.
8. **Harden all workload components** by reducing extraneous surface area and tightening configurations to increase attacker cost.
9. **Protect application secrets** by hardening their storage and restricting access and manipulation and by auditing those actions.
10. **Implement a holistic monitoring strategy that relies on modern threat detection mechanisms that can be integrated with the platform.**
11. **Establish a comprehensive testing regimen** that combines approaches to prevent security issues, validate threat prevention implementations, and test threat detection mechanisms.
12. **Define and test effective incident response procedures** that cover a spectrum of incidents, from localized issues to disaster recovery. Clearly define which team or individual runs a procedure.

The above list depicts Azure's design review checklist for the security pillar.¹ Look at item #10. That's one of the most critical items and a core element of security. Expanding on the previous motto:

Prevention is ideal. Detection is a must. Detection without response is useless. Meaning, if you can see them coming, you need to do something about it. Imagine preparing for a fire. You take appropriate proactive actions to ensure your house is not a fire hazard. But should a fire break, then you want your fire alarm to go off, but would that be enough? No, because if it goes off without your sprinklers engaging and your fire suppression mechanism kicking in, you might as well be drinking tea or coffee and enjoying the show. Appropriate detection always needs to be combined with the necessary response. That's exactly where we will focus our attention: on appropriate detection, by reviewing log sources of interest and how that can be used to prompt a timely, adequate, and efficient response for the organization.

Items you should consider including in your monitoring include access flows, critical data and assets, networking, operating system, and critical applications. Establishing traffic baselines is necessary so that you can detect any behavior deviations quickly and act promptly to determine if there's an ongoing security incident and proceed with its investigation and resolution. Establish threat intelligence collaborations with necessary third parties and consider combining that with any in-house function you may have to augment the information you obtain from those external partners. Combining this with an appropriate SIEM solution will be critical to the survival of the environment.²

1. <https://sec555.com/tcwr4>
2. <https://sec555.com/ywoqk>

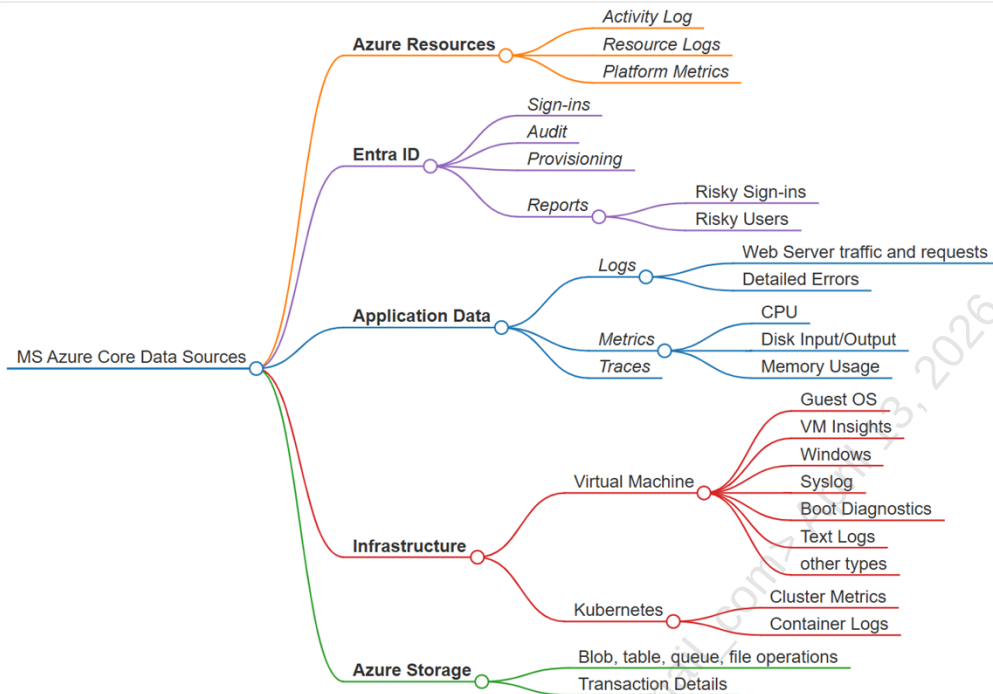
Azure Log Types



The student will gain insight into what the most common Azure log types are and how data can be exported for further analysis.

This area is intentionally left blank.

Main Azure Log Sources



The above mind map shows a collection of the most important MS Azure data sources that any security professional will be required to have in mind. There's another one we'll see later that has a consolidated view of additional ones, but the ones depicted here are crucial for any threat detection engineer, security analyst/engineer, or pretty much anyone working with Azure logs. Note below details regarding log configuration and retention periods for some of the main ones, but a more detailed description of those follows, in addition to their exporting options:

- **Azure Resources**
 - **Activity Log:** Entries are inserted by default without any additional configuration required. Retention period is 90 days.
 - **Resource Logs:** Not collected by default, so the easiest way would be to configure a diagnostic setting and choose where you want the events to be exported to.
 - **Platform Metrics:** These are collected by default every minute and are dispatched to Azure Monitor metrics, but you can also configure an alternative destination.
- **Entra ID**
 - **Sign-ins/Audit/Provisioning Logs:** Entries are collected by default. Retention period depends on licensing. I.e., for a free Microsoft Entra ID tier, these are collected for 7 days, while for an Entra ID P1 or P2 license, these are there for 30 days.
 - **Risky Sign-ins:** Information about risky sign-ins is collected by default. If you have a free tier, that's present for 7 days. With a P1 license, that goes up to 30 days, while a P2 license brings it up to 90 days.
 - **Risky Users:** There's no limit for keeping a record on risky users within your tenant, and these entries are ingested by default.
- **Infrastructure:** Data related to VMs, such as guest OS metrics, is routed to a storage account with no explicit expiration date. The portal displays the last 14 days, to maximize performance. For guest OS metrics being sent to Azure Monitor metrics via the AMA (Azure Monitoring Agent) or the

© SANS Institute 2025
Windows diagnostic extension, retention is set to 93 days. If you're using a Log Analytics agent for those, interactive retention can go up to 2 years.

Reference:

- <https://sec555.com/p9fbk>

Activity Log

Any configuration change or health-related activity taking place within the Azure subscription will appear in the activity log.

No additional configuration required, as these events are automatically collected.

Standard retention period is set at **three months (90 days)**.

Operation name	Status	Event categ...	Time stamp	Subscription	Resource group
✓ Create Flow Log	Succeeded	Administrati...	Tue Nov 26 2024 14:...	sans-range01-sec555	NetworkWatcherRG
Create Flow Log Started		Administrati...	Tue Nov 26 2024 14:...	sans-range01-sec555	NetworkWatcherRG
Create Flow Log Accepted		Administrati...	Tue Nov 26 2024 14:...	sans-range01-sec555	NetworkWatcherRG
✓ Create Flow Log	Succeeded	Administrati...	Thu Sep 26 2024 19:...	sans-range01-sec555	NetworkWatcherRG
Create Flow Log Started		Administrati...	Thu Sep 26 2024 19:...	sans-range01-sec555	NetworkWatcherRG
Create Flow Log Accepted		Administrati...	Thu Sep 26 2024 19:...	sans-range01-sec555	NetworkWatcherRG

Summary JSON Change history

Resource /subscriptions/
/resourcegroups/NetworkWatcherRG/providers/
range-cdrsn-bastion-sec555-range-cdrsn-flowlog

Operation name Create Flow Log

Time stamp Tue Nov 26 2024 14:30:20 GMT+0000 (Greenwich Mean Time)

Event initiated by nick sans.org

Azure's activity log is a great way to identify configurational changes (e.g., creating or starting a VM) or health-related information about your subscription (like an issue with your key vault backup). In the above image, an NSG flow log was created, and the activity log contains a basic summary of that action.

The specific resource being modified is identified under the "Resource" section

(/subscriptions/XXXXXXXXXX-XXXX-XXXX-XXXX-

XXXXXXXXXXXXXXXX/resourceGroups/NetworkWatcherRG/providers...), which contains the subscription ID at the beginning (obfuscated for privacy) and then the item being modified, in this case, creating a new NSG flow log for the NetWatcher service, also highlighted in the "Operation name" field. Note that apart from accessing the activity log from the Azure console, you can also access it via the Azure CLI or using PowerShell. These may be beneficial options if you are doing large-scale searches, or if you need to create scripts performing actions with the output of your results, or if you need to expand upon your filtering and drill down to certain entries by powerful filtering of your results.

Also note that each entry in the Activity log comes with a JSON representation, as depicted in the next page.

Activity Log in JSON Format

```
"correlationId": "bafb742f-8e12-432a-8706-b8dd91d0bc67",
  "description": "",
  "eventDataId": "9aa65786-a09c-49f6-b555-e3138c52018e",
  "eventName": {
    "value": "BeginRequest",
    "localizedValue": "Begin request"
  },
  "category": {
    "value": "Administrative",
    "localizedValue": "Administrative"
  },
  "eventTimestamp": "2024-11-26T14:30:15.7622685Z",
  "level": "Informational",
  "operationId": "459b745a-3fa8-4188-aff6-3485a7fb173d",
  "operationName": {
    "value": "Microsoft.Network/networkWatchers/flowLogs/write",
    "localizedValue": "Create Flow Log"
  },
  "resourceGroupName": "NetworkWatcherRG",
  "resourceProviderName": {
    "value": "Microsoft.Network",
    "localizedValue": "Microsoft.Network"
  },
  "resourceType": {
    "value": "Microsoft.Network/networkWatchers/flowLogs",
    "localizedValue": "Microsoft.Network/networkWatchers/flowLogs"
  }
}
```

Event is an informational level item, so you need to select that level when exporting to a Log Analytics Workspace, if you want to see it there

The resource modified is Network Watcher

In particular, the flow logs category

This is just a small sample of how the activity is depicted in JSON, which allows visibility into quite a lot of fields. This single log entry results in almost 100 lines of JSON logging (with about 30 of those depicted here). All of that information can be used to investigate further, set up alerts, and focus on specific items of interest. It can also be used to export the log entry and ingest it to another tool supporting JSON, for additional analysis. For reference, here's the depicted portion:

```
"correlationId": "bafb742f-8e12-432a-8706-b8dd91d0bc67",
  "description": "",
  "eventDataId": "9aa65786-a09c-49f6-b555-e3138c52018e",
  "eventName": {
    "value": "BeginRequest",
    "localizedValue": "Begin request"
  },
  "category": {
    "value": "Administrative",
    "localizedValue": "Administrative"
  },
  "eventTimestamp": "2024-11-26T14:30:15.7622685Z",
  "level": "Informational",
  "operationId": "459b745a-3fa8-4188-aff6-3485a7fb173d",
  "operationName": {
    "value": "Microsoft.Network/networkWatchers/flowLogs/write",
    "localizedValue": "Create Flow Log"
  },
  "resourceGroupName": "NetworkWatcherRG",
```

```
"resourceProviderName": {  
  "value": "Microsoft.Network",  
  "localizedValue": "Microsoft.Network"  
},  
"resourceType": {  
  "value": "Microsoft.Network/networkWatchers/flowLogs",  
  "localizedValue": "Microsoft.Network/networkWatchers/flowLogs"  
}
```

Licensed To: Arvind Pariti <paritiarvind@gmail_com> April 13, 2026

Activity Log Export

The screenshot shows the Azure Monitor 'Activity log' page. A blue box labeled '1. Select "Export Activity Logs"' points to the 'Export Activity Log' button. Below, the 'Diagnostic settings' page is shown. A blue box labeled '2. Select "Add diagnostic setting"' points to the '+ Add diagnostic setting' link. Another blue box labeled '3. Define a name' points to the 'Diagnostic setting name' field, which contains 'Security Diagnostic'. A blue box labeled '4. Select desired log categories' points to the 'Logs' section where 'Security' is selected under 'Categories'. A final blue box labeled '5. Select desired destination(s) to send logs' points to the 'Destination details' section where 'Send to Log Analytics workspace' is checked.

The activity log supports exporting the logs and sending them to different destinations. To do so, simply follow these steps, after navigating to **Azure Monitor > Activity Log**:

1. Select "Export Activity Logs".
2. Select "Add diagnostic setting" to allow you to choose what log categories are required to be included in the export.
3. Define a diagnostic setting name.
4. Select your desired log categories (multiple selections are possible). Note that a recommended option would be to use a Log Analytics Workspace (as per the example) to be able to use KQL queries to query the stored data or import into Sentinel for alerting (analyzed in detail later on).
5. Choose where to send the exported activity logs (in the above example, these are being sent to the log analytics workspace for further analysis and review).

As you can see in the diagnostic setting pane, there are eight possible categories of logs to choose from in this example. Those are:

- **Administrative:** Actions like create, delete, and update end up in this category. When resources are managed in Azure, that triggers an operation to be performed on a given resource. Types of operations like action, write, or delete, as well as their start and finish (which will be success or failure), are logged as administrative.
- **Security:** Alerts generated by Microsoft Defender for Cloud are included.
- **Service Health:** If your Azure tenant is impacted by a health incident, like a tenant in a geographic location being unreachable, that would be logged under this category.
- **Alert:** Multiple items can trigger Azure alerts falling in this category. Most common ones tend to be resource specific, like a VM running above a certain threshold of CPU or memory.
- **Recommendation:** Any recommendations Azure can provide for any service within your subscription will fall under this category. These can be anything from contact details to critical security

recommendations. Examples:

- "Email notification to subscription owner for high severity alerts should be enabled"
- "Subscriptions should have a contact email address for security issues"
- "Enable Backups on your Virtual Machines"
- "Purchasing a savings plan for compute could unlock lower prices"
- **Policy:** Entries relate to an Azure policy statement being applied. Azure policy is frequently used to enforce environmental and regulatory compliance, cost limitations, security, and overall management.
- **Autoscale:** Entries relate to the autoscale engine. For example, say you have configured a VM to take a specific action to scale memory up when it reaches a maximum threshold and that process fails. That will create an autoscale event, which is logged under this category.
- **Resource Health:** Events relating to Azure resources. Examples include:
 - "Down: Virtual machine has been unavailable for 15 minutes."
 - "The Virtual Machine is undergoing a reboot as requested by a restart action triggered by an authorized user or process from within the Virtual Machine. No other action is required at this time."
 - "The Virtual Machine is in the process of being set up, as requested by an authorized user or process. No other action is required at this time."

Log Export Destination Options Using Diagnostic Setting

- Five options to choose from:
 - Log Analytics workspace.
 - Archive to storage account.
 - Stream to an event hub.
 - Send to partner solution.
 - Another option (not on the list) is to use Graph API.
- Logs are not cheap, so you need to make sure that what you select is what you need, what your budget can sustain, but also enough to drive incident investigations forward.

Home > Monitor | Diagnostic settings > Diagnostic setting

Save Discard Delete Feedback

Diagnostic setting name * PublicFirewallIPDiagnostic

Logs

Category groups

☐ audit ☒ allLogs

Categories

☒ DDoS protection notifications

☒ Flow logs of DDoS mitigation decisions

☒ Reports of DDoS mitigations

Metrics

☒ AllMetrics

Destination details

☐ Send to Log Analytics workspace

☒ Archive to a storage account

Location: East US

Subscription: sans-range01-sec555

Storage account *: sec555rangecdrsncus08cb8

☐ Stream to an event hub

☐ Send to partner solution

Do you really need this?

4 main options for exporting + Graph API

In the above image, you can see a diagnostic setting being created, depicting data regarding the Azure firewall's public IP address. All logs have been chosen to be captured for full visibility, but since logging comes at a considerable cost, you need to think about what use cases you require logs for to decide what type of log sources and associated data you require.

Destination details:

- **Log Analytics workspace:** This feature will be discussed separately later, but for now, do note that the Log Analytics workspace offers a powerful way of aggregating and correlating data within your Azure subscription, which allows you to uncover anomalies or abnormal behavior, both from a security and performance standpoint.
- **Archive to a storage account:** Allows you to send data, which is older than three months, to an Azure storage account, which can be particularly useful for backing up or audit purposes. After the data is ingested into the storage account, you can access it by using the **Azure Storage Explorer** tool (discussed later). Hourly logs will be created for any associated activity, which you can access using the tool.
- **Stream to an event hub** for large data processing requirements (ideal option for sending data to a third party MSSP or SIEM supplier, if it's not on the Azure partner solution list). Export format is JSON.
- **Send to partner solution:** Azure has started establishing partnership agreements with a variety of entities like Elastic, New Relic, and more. The full list located at <https://learn.microsoft.com/en-us/azure/partner-solutions/partners##observability>.
- **Graph API:** There's another option for exporting the Azure logs, which isn't explicitly depicted above. That's **using the Graph API**, which provides visibility to sign-in and audit logs. This is a bit of a more involved approach (as there isn't any direct portal access and it will require access tokens and some more configuration to be performed), but it can greatly help if you're trying to build a SIEM integration or want to query your subscription's data in a fast and efficient way. More details provided later.

Resource Logs

NOTE

Resource logs are not enabled by default!

- Perform resource log collection based on predefined category groups vs. individual category types.
- Two available category groups overall: Audit and All.

Log categories differ per resource. Example: Firewall object vs. NSG

Exporting options are identical to activity logs

Resource logs relate to logs about specific resources within your Azure subscription. Note that these aren't enabled by default, so you will need to navigate to **Microsoft Azure > Monitor > Diagnostic settings > "Select your desired resource" > Add diagnostic setting > "Choose appropriate log group and category and define destination" > Save.**

Category groups contain predefined Microsoft groupings which may aid collection vs. you defining individual category types. Note that the categories within those groups change, and if that happens, your subscription gets automatically adjusted with newly added/removed items.

If you do decide to use category groups, you can't select resource logs based on individual types. From the two available category groups, **"allLogs"** collects every available resource log while **"audit"** is a subset that records the most important data (as per the resource provider). If you select both, the **"allLogs"** option supersedes, and that means all resource logs will be collected. When configuring the destination for resource logs, the options are identical to those of activity logs.

Reference:

- <https://sec555.com/ysob3>

Entra ID Log Types and Identity Protection Reports

Activity Logs

- **Sign-ins:** Managed application and user sign-in data.
- **Audit:** User and group activity information, managed applications.
- **Provisioning:** Monitor provisioning service activity.

Identity Protection Security Reports

- **Risky sign-ins:** Possible account misuse by an illegitimate entity.
- **Risky users:** Possible compromised account identification.

Microsoft Entra ID has three activity log types available (more details follow on the next pages):

- **Sign-in logs:** Contain any type of sign-in to the Entra tenant. This can reveal security irregularities, like users signing in from one geographical location, and then five minutes later, they are seen logging in from a totally different location; suspicious user agents or operating systems not associated with your organization, which may be indicative of account sign-in abuse; users that have provided a correct password but failed to satisfy MFA multiple times; etc.
- **Audit logs:** Contain data about any type of changes that may have taken place across your Azure tenant (e.g., adding/deleting new users, self-provisioning user enrolment requests, managing groups, and more).
- **Provisioning logs:** Any activity taken by a provisioning service ends up here. Examples include identities being added/deleted/modified in ServiceNow, Salesforce, Workday, Oracle, SAP, Box, Dropbox, and others.

Reference:

- <https://sec555.com/a1m95>

Entra ID: Sign-in Logs

Basic info Location Device info Authentication Details Conditional Access Report-only

Date	10/1/2024, 10:56:46 PM
Request ID	8aa39cf6-808d-4e5f-ad2a-eb2a87920e00
Correlation ID	ae693aae-33fd-4d2d-955e-69604f3f64c1
Authentication requirement	Multifactor authentication
Status	Failure
Continuous access evaluation	No

Sign-in error code 500121

Failure reason Authentication failed during strong authentication request.

Additional Details The user didn't complete the MFA prompt. They may have decided not to authenticate, timed out while doing other work, or has an issue with their authentication setup.

Troubleshoot Event Follow these steps:

- Launch the Sign-in Diagnostic.
- Review the diagnosis and act on suggested fixes.

Who

User Minion, Harry

Username harry.minion@

User ID

Sign-in identifier harry.minion@

- Very detailed information available.
- Most important are:
 - User sign-ins (interactive).
 - User sign-ins (non-interactive).
- **Logs are available for 30 days.**
- A user can access their own log data, but accessing other user data requires specific role assignments.
- If there's a conditional policy rule hit, that will show under the Conditional Access tab.

The sign-in logs have an immense amount of information available, which is contained in almost 40 columns. Fields include user, application, sign-in status, origin IP address and operating system, device browser used, tenant identifiers, and many more.¹ There are the following types (with the interactive user sign-ins usually being the most crucial).

Interactive User Sign-Ins²

These reflect user sign-ins using a variety of methods, most commonly a password and Microsoft Authenticator MFA token—if MFA has been set up.

Fields of interest include information about the **user** undertaking an activity (in the above image, the user is Minion, Harry), with an associated **username**, and unique **user ID** and **sign-in identifier**.

The **Authentication requirement** field denotes that MFA has been configured to be required for this sign-in, which means that upon the user entering their current credentials, they will be prompted by an MFA request.

However, in this case, the user failed to provide an appropriate MFA token. In a non-malicious scenario, this would commonly be due to an issue with the MFA application enrolment, in which case a re-enrolment would most likely fix this. However, it could be indicative of an attacker doing something more devious (details on the example depicted shortly). Note that the **Authentication Details** tab contains more insight into the reason, as detailed below.

You can also use **Microsoft's lookup tool**³ and input an error code of interest (e.g., in the above example, 500121) to quickly see the details of that error.

The **Location** tab provides insight about the IP address and location the activity originated from, which can be very useful, especially if you're not expecting users to be logging in from certain areas in the world.

The **Device info** tab contains the browser version, operating system, and the status of the device's compliance (e.g., enrolled in Intune—Microsoft's standard MDM solution).

The **Authentication Details** field states details about what went wrong with the authentication attempt in question (if it wasn't successful).

In the preceding example, although the password was entered correctly, the user declined the MFA authentication token. Really great level of insight there, allowing us to understand exactly what this relates to.

Conditional Access records any related policy rules hit that may impact the user's sign-in attempt. This can be combined with the **Report-only** tab, which means that you can test any conditional access policy before actually deploying it, thus saving yourself from potentially unwanted user side effects.⁴

Non-Interactive User Sign-Ins⁵

These logs imprint activity being indirectly taken on behalf of a user but not directly by the user themselves.⁶ These sign-ins commonly take place by applications or the OS a user uses and happen under the hood, without interrupting the user experience.

1. <https://sec555.com/1m9yz>
2. <https://sec555.com/zjoi4>
3. <https://sec555.com/hqva9>
4. <https://sec555.com/1wf04>
5. <https://sec555.com/sk921>
6. <https://sec555.com/wtiyc>

Entra ID: Sign-in Logs: Scenario Evaluation (1)

User sign-ins (interactive)

User sign-ins (non-interactive)

You are doing a log review for the last week and notice multiple failed authentication attempts for Harry Minion.

Date	↑↓ User	↑↓ Application	↑↓ Status	IP address	↑↓ Location
10/1/2024, 11:04:06 PM	Minion, Harry	Azure Portal	Failure	91.90.123.60	Zaventem, Vlaams-Brabant, BE
10/1/2024, 11:03:59 PM	Minion, Harry	Azure Portal	Failure	91.90.123.60	Zaventem, Vlaams-Brabant, BE
10/1/2024, 11:03:55 PM	Minion, Harry	Azure Portal	Failure	91.90.123.60	Zaventem, Vlaams-Brabant, BE
10/1/2024, 11:03:52 PM	Minion, Harry	Azure Portal	Failure	91.90.123.60	Zaventem, Vlaams-Brabant, BE
10/1/2024, 11:03:48 PM	Minion, Harry	Azure Portal	Failure	91.90.123.60	Zaventem, Vlaams-Brabant, BE
10/1/2024, 11:03:46 PM	Minion, Harry	Azure Portal	Failure	91.90.123.60	Zaventem, Vlaams-Brabant, BE
10/1/2024, 11:03:43 PM	Minion, Harry	Azure Portal	Failure	91.90.123.60	Zaventem, Vlaams-Brabant, BE
10/1/2024, 11:03:40 PM	Minion, Harry	Azure Portal	Failure	91.90.123.60	Zaventem, Vlaams-Brabant, BE
10/1/2024, 11:03:35 PM	Minion, Harry	Azure Portal	Failure	91.90.123.60	Zaventem, Vlaams-Brabant, BE
10/1/2024, 11:03:33 PM	Minion, Harry	Azure Portal	Failure	91.90.123.60	Zaventem, Vlaams-Brabant, BE
10/1/2024, 11:03:29 PM	Minion, Harry	Azure Portal	Failure	91.90.123.60	Zaventem, Vlaams-Brabant, BE
10/1/2024, 11:03:23 PM	Minion, Harry	Azure Portal	Failure	91.90.123.60	Zaventem, Vlaams-Brabant, BE
10/1/2024, 11:00:07 PM	Minion, Harry	Azure Portal	Failure	79.135.105.5	Tirane, Tirane, AL
10/1/2024, 10:59:49 PM	Minion, Harry	Azure Portal	Failure	79.135.105.5	Tirane, Tirane, AL
10/1/2024, 10:59:21 PM	Minion, Harry	Azure Portal	Failure	79.135.105.5	Tirane, Tirane, AL

Do these make sense?

It doesn't matter if you are a security analyst, engineer, or even doing regular account administration. You should still be looking at the logs to uncover suspicious activity or anything potentially looking abnormal. If you do identify something, even at random, you should pursue it further or report it to the appropriate team, so they can investigate it. This is the equivalent of someone tailgating you into the building and you doing nothing about it. Reporting that incident to physical security would be the prudent way to go. Sadly, it is very common for a lot of security engineers to be missing analytical skills, which makes them think that abnormal is actually normal. Sometimes they think it's a misconfiguration or some application feature or similar legitimate activity that prevents them from thinking differently. This is not a criticism but rather it's just the reality of things. Something that can be easily solved with training, awareness, and gaining experience.

If you show a security analyst 20 failed authentication attempts taking place in one hour, they will probably tell you this is a brute force attack against that account. If you show the same to a developer, they may tell you that this is some misconfigured script causing this activity. Taking a step back, the author has seen this being legitimate activity from an overzealous administrator who thought they remembered their actual password. It's all about your vantage point.

In the above image, you can see that there are quite a few failed login attempts for Harry Minion's account in a relatively short amount of time (15 failed login attempts within about 8 minutes). To make this more interesting, initial attempts seem to originate from Albania (Tirana) and subsequent ones from Belgium (Zaventem, Vlaams-Brabant). This doesn't really look to be normal. Let's have a more in-depth look at Harry's account details in Entra ID.

Entra ID: Sign-in Logs: Scenario Evaluation (2)

10/1/2024, 10:41:38 PM	Minion, Harry	Interrupted	London, Greater Londo...
9/28/2024, 8:29:01 PM	Minion, Harry	Success	London, Greater Londo...
9/28/2024, 8:27:30 PM	Minion, Harry	Interrupted	London, Greater Londo...

Login traffic from London, United Kingdom

 **Minion, Harry** ...
User

Entra ID user information states a London address

Search x << Edit properties Delete Refresh Manage view Got feedback

Overview Audit logs Sign-in logs Diagnose and solve problems Manage Custom security attributes Assigned roles

Overview Monitoring **Properties**

Identity

Display name	Minion, Harry	Street address	4 Richmond Mews
First name	Harry	City	London
Last name	Minion	State or province	Central London
User principal name	harry.minion@	ZIP or postal code	W1D 3DH
		Country or region	United Kingdom

Contact Information

There seems to be legitimate traffic originating from London (including a successful sign-in to Harry's account only a couple of days prior to this failed login sequence). A look into Entra ID's user information for Harry shows a London address, which aligns with the above seen traffic. This means that the previous login attempts from Albania and Belgium are most likely attempts to compromise Harry's account credentials. Even if the attacker was successful in identifying the user password, that won't go a long way if the account in question is protected by MFA (which, in this case, it is). As you can see, simple investigative actions of the logs can lead to quick conclusions about potentially suspicious activity.

It's interesting because a few years ago (around September 2022), Microsoft reported about 26% of Entra ID accounts being protected by MFA.¹ In 2024, that percentage reached 38%, according to Microsoft.² What's also interesting is that Microsoft announced in 2019 that enabling MFA prevents 99.9% of attacks against your account.³ But several years after that announcement, we aren't even at 50% MFA-enabled accounts. To tackle that, the vendor has now announced that by mid-2025 you will need to satisfy MFA for most admin tasks (using Entra admin center, Azure CLI/PowerShell/mobile app, and more).⁴ There are some disadvantages and known attacks against MFA,⁵ but that doesn't mean it shouldn't be used. For example, if a user account isn't locked after providing, say, 50 false MFA tokens, is it really MFA's fault? No, this is down to configuration by the system administrator and corporate policies.

1. <https://sec555.com/k7hm8>
2. <https://sec555.com/a85w0>
3. <https://sec555.com/5ufn2>
4. <https://sec555.com/kmt2d>
5. <https://sec555.com/vsg2x>

Entra ID: Audit Logs

9/28/2024, 8:27:30 PM	Authentication Methods	UserManagement	User registered all required s...	Success	User registered all required security info.
9/28/2024, 8:27:30 PM	Core Directory	UserManagement	Update user	Success	
9/28/2024, 8:27:17 PM	Authentication Methods	UserManagement	User registered security info	Success	User registered Authenticator App with Notification and Code
9/28/2024, 8:27:17 PM	Core Directory	UserManagement	Update user	Success	
9/28/2024, 8:27:16 PM	Core Directory	UserManagement	Update user	Success	
9/28/2024, 8:27:05 PM	Authentication Methods	UserManagement	User started security info reg...	Success	User started the registration for Authenticator App with Notification and Code

Suspicious activity detected

We've detected something unusual about this sign-in. For example, you might be signing in from a new location, device, or app. Before you can continue, we need to verify your identity.

[Cancel](#)[Verify](#)

Sign-in attempt from new location

Verify your identity

Your organization requires additional sign in methods to access this resource.



Approve a request on my Microsoft Authenticator app

[More information](#)

Are your verification methods current? Check at <https://aka.ms/mfasetup>

User MFA enrolment has been already completed, according to these 3 log entries

MFA token is triggered to verify identity

Important note: You can identify an account's MFA enrolment status, which shields it from risky sign-in attempts.

Any user, group, or managed application or policy change-related activity taking place in Entra ID gets added into the audit logs.

Examples include users, groups, or applications being added, deleted, or modified.

In the above example, note that Harry Minion's account has been previously enrolled in MFA, as also verified by the audit log (above three highlighted entries). The sequence of steps is as follows:

1. Harry now attempts to log in from an overseas location (which is totally new to Azure, after seeing the user repeatedly logging in from a select few other locations as being the normal behavior for that user). Although a correct username and password are entered into the Azure portal, Entra ID flags this as a suspicious login, and it even says that the user may be signing in from a new location.
2. At that moment in time, if the user selects **Verify**, they will be prompted to provide a Microsoft Authenticator token to complete the sign-in process.

Reference:

- <https://sec555.com/pa0qw>

Entra ID: Risky Sign-Ins (1)



elizabeth.arden@sansrange01sec55.onmicrosoft.com

Your sign-in was blocked

We've detected something unusual about this sign-in. For example, you might be signing in from a new location, device or app. Before you can continue, we need to verify your identity. Please contact your admin.

Elizabeth tried logging in, and her sign-in was blocked, although she provided the correct password.

Troubleshooting details

If you contact your administrator, send this info to them.

[Copy info to clipboard](#)

Error Code: 530031

Request Id: 0caff50d-b2c6-441c-a137-09b59cf03000

Correlation Id: 8b57e504-1e18-4e49-a595-8c7d81d8d0ad

Timestamp: 2024-10-04T16:15:25.270Z

App name: My Apps

App ID: 2793995e-0a7d-40d7-bd35-6968ba142197

IP address: 185.51.134.197

Device identifier: Not available

Device platform: Windows 10

Device state: Unregistered

Diagnostic info provided.

My Apps means an attempt to access "myapps.microsoft.com".

Related fields, like request ID, correlation ID, timestamp, and IP address are all searchable within the logs.

The above user-generated activity resulted in this Risky Sign-in entry.

User risk policy

Sign-in risk policy

Multifactor authentication registration policy

Report

Auto refresh : Off

Date : Last

Show dates as : Local

Risk state : 5 selected

Risk level (real-time) : None Selected

Risk level (aggregate) : None Selected

Detection type(s) : None Selected

Sign-in Type : 2 selected

Add filters

☐ Date ↑↓	User ↑↓	IP address	Location	Risk state ↑↓
☐ 10/4/2024, 7:15:11 PM	Arden, Elizabeth	185.51.134.197	Athina, Attiki, GR	Dismissed

The Azure Entra ID Risky Sign-in report is a tool that can shed light on the decisions Entra ID Protection is making to keep the Azure tenant secure.

In the above example, user Elizabeth Arden tried logging in to **myapps.microsoft.com** and was denied access, although a correct username and password were provided.

But should a correct password be enough to rule out an account compromise, especially with the social engineering phishing email increase that we keep seeing? The answer is no.

The action that Entra ID will take when it detects a risky sign-in attempt depends on the setting the administrator has configured (and if a related conditional policy is hit, it will be reflected under the **Conditional Access Policy** tab).

Example conditional policy actions: Configure a conditional access control policy to ask the users to provide an MFA token for medium- or high-level risk sign-ins, in addition to their credentials.

- ✓ In the case of an incorrect password, you might choose to have the user self-provision a password reset, after several failed attempts to enter the correct one.
- ✓ You might want to block users or challenge them with MFA or other conditions (like owning a compliant device or being Azure joined).
- ✓ If you choose to allow the users to initiate a password reset, you can even choose how that should take place; i.e., using an MFA token, a phone number, email, etc.
- ✓ You may select to have users jump through various hoops, only in case they try to access a highly critical application, like the Azure Privileged Identity Management application.

There are multiple options to choose from, and at the end of the day, you need to choose the ones that help you promote security of your environment without hindering user productivity.

Entra ID: Risky Sign-Ins (2)

Basic info

Device

One or more properties (IP, ASN, location, device, browser, tenant IP subnet) of this sign-in are different from what we have seen recently for the given user. [Learn more](#)

Risky Sign-in Details

User's risk report User's sign-ins User's risky sign-ins User's risk detections Sign-in's risk detections

10/4/2024, 7:15 PM Unfamiliar sign-in properties (Dismissed)

Time detected 10/4/2024, 7:15 PM

Risk state Real-time

Risk level Medium

Source Identity Protection

Detection last updated 10/4/2024, 7:17 PM

Sign-in time 10/4/2024, 7:15 PM

IP address 185.51.134.197

Sign-in location Athina, Attiki, GR

Sign-in client Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/129.0.0.0 Safari/537.36 Edg/129.0.0.0 OS/10.0.22631

Confirm sign-in compromised
Confirm sign-in safe
Dismiss sign-in risk

An administrator can select any final verdict.

These haven't been used before, so Entra doesn't like them.

The dismissal message states that Entra blocked the access attempt because some characteristics of the sign-in didn't reflect what it previously had associated with the user.

The user logged on from a new browser, new device, and new location (none of which Entra had ever seen before).

The action taken (as seen in the previous page) was to block the user attempt.

Retention period is 30 days.

Entra ID generated the above alert because in the past, the user commonly logged on to their account a few times from the UK, using Mozilla Firefox, and the same device. But then, shortly after one of those logins, a separate login took place from:

1. A new machine,
2. using Microsoft Edge, and
3. originating from Athens, Greece.

The combination of those characteristics made Entra decide to block the account.

An administrator can still review this access flow and determine its legitimacy, possibly after cross-referencing this with the user themselves. At that point, they can choose to confirm this sign-in was safe (commonly if the user confirms the activity), they can choose to confirm the account was compromised, or they can choose to dismiss it altogether.

Entra ID: Risky Users (1)

Home > Identity Protection

Identity Protection | Risky users

Search

Learn more Download Select all Confirm user(s) compromised Confirm user(s) safe Dismiss user(s) risk

We recommend migrating Identity Protection policies to Conditional Access for more conditions and controls. Learn more →

Auto refresh : Off Show dates as : Local Risk state : 2 selected Status : Active Risk level : High, Medium

Add filters

User ↑↓	Risk state ↑↓	Risk last updated ↑↓
☐ Arden, Elizabeth	Confirmed compromised	10/4/2024, 8:49:19 PM

Elizabeth has now been moved to the Risky users after an account compromise was confirmed by an administrator.

Dashboard
Tutorials
Diagnose and solve problems
Favorites
Risky workload identities
Protect
Report
Risky users
Risky workload identities
Risky sign-ins
Risk detections

Choosing to confirm that Elizabeth's account was compromised moves the account to the confirmed compromised state and now highlights Elizabeth's account as a risky user.

A user becomes risky when they have one or more sign-ins that are classified as risky, or they have other risks that Entra identifies. Common risks include (but aren't limited to):¹

- Logging in from an anonymous IP address (e.g., while using the Tor browser).
- Logging in from an unfamiliar location/device/browser.
- Multiple failed attempts to log in followed by an immediate successful one.
- Logging in from a known malicious IP address (as identified by Microsoft threat intelligence sources).
- User reported the activity as suspicious because they were prompted for an MFA token without them being the ones actually generating that request.
- Potential leaked credentials in use.

1. <https://sec555.com/njifd>

Entra ID: Risky Users (2)

Reset password ✗ Confirm user compromised ✓ Confirm user safe ✓ Dismiss user risk ⛔ Block user ...

Summarize

Basic info Recent risky sign-ins Detections not linked to a sign-in Risk history

Summary by Copilot

Generated by Copilot

- User Lee Gu has three recent risky activities, all with High risk level.
- The risk detection type is Activity from anonymous IP address.
- Anonymous IP address indicates sign-ins from an anonymous IP address (for example, Tor browser or anonymous VPN).
- Risky sign-in 1 (RequestId: cf51beb9-7ff6-4907-83d3-86197d690100, CorrelationId: ce04a231-43f0-41e7-b032-d8c8ddf786e6) with High risk level occurred on 2024-05-23T05:08:20 UTC for Application M365ChatClient and Resource M365ChatClient. The sign-in IP was 203.0.113.7 and location was Sheridan, Wyoming US. The IP, ASN, Location, Browser Id and Device Id were unfamiliar to the user. There was no MFA for this sign-in.
- Risky sign-in 2 (RequestId: 5c4eedc1-da2c-41e7-8d73-57c792100000, CorrelationId:) with High risk level occurred on 2024-05-23T05:12:42 UTC for Application Browser and Resource SharePoint Online Web Client Extensibility. The sign-in IP was 2605:6400:30:f08c:45b7:4a99:a154:694e and location was Cheyenne, Wyoming US. The IP, ASN, Location, Browser Id and Device Id were unfamiliar to the user. There was no MFA for this sign-in.
- Risky sign-in 3 (RequestId: 2b6da610-18db-4649-bd65-697a8d033600, CorrelationId:) with Medium risk level occurred on 2024-05-23T05:07:33 UTC for Application Browser and Resource OfficeHome. The sign-in IP was 203.0.113.7 and location was Sheridan, Wyoming US. The IP, ASN, Location, Browser Id and Device Id were unfamiliar to the user. There was no MFA for this sign-in.

What to do

Check to ensure this user is in scope of these risk-based Conditional Access policies which will shorten the time to mitigate the attack, automatically close the risk, and save you time and effort.

If you do not have those policies:

1. [Create a sign-in risk based policy](#)
2. [Create a user risk based policy](#)

For now, investigate this user for indicators of compromise and take action using the buttons above. Use our playbooks below for step-by-step guidance.

If Copilot is enabled within the Azure subscription, another tab called "Summarize" is added.

All related risks that Entra has identified are outlined with a short explanation, providing great insight.

Recommendations also included

Enabling Copilot, with a current Azure subscription, can go a long way to provide analysts and engineers with really useful information about any item they're examining. Take the above example. The risks aren't just listed, but now they have a small explanation providing a good overview of what they relate to and how important this is. Of course, a great addition is the recommendation section at the bottom, stating what actions should be taken next in order to deal with the risk at hand.¹ When analysts and engineers are confronted with a wide range of events to analyze, this can make a substantial difference. Note that Copilot is discussed in more detail in the next module.

1. <https://sec555.com/9wsxj>

Image reference:

• <https://sec555.com/clgpm>

NSG Flow Log Creation

The screenshot shows the 'Details' and 'Traffic analytics' sections of the NSG Flow Log creation wizard. Callouts highlight the following configurations:

- Source IP or range:** Set to 10.5.4.1 under 'Source IP addresses/CIDR ranges'.
- Source port or range:** Set to * under 'Source port ranges'.
- Destination IP or range:** Set to 1.5.12.41 under 'Destination IP addresses/CIDR ranges'.
- Destination port or range:** Set to 21-1000 under 'Destination port ranges'.
- Select the protocol:** TCP is selected under 'Protocol'.
- Set captured flow action to be allow or deny:** Allow is selected under 'Action'.
- Set the Log Analytics workspace:** The 'Log Analytics workspace' field is highlighted.
- Set desired retention:** Retention days are set to 30.

Traffic analytics settings:

- Enable traffic analytics: ☒
- Subscription: sans-
- Log Analytics workspace: 9784ba92-
- Traffic logging interval: Every 1 hour

- NSG flow logs give you great network visibility.
- Monitor traffic to identify unexpected patterns, network/application issues.
- Choose version 2 for the most enriched option.
- Traffic can be captured on an NSG or virtual network.

Network security groups are used to filter traffic destined to or sourcing from Azure resources in an Azure virtual network. NSG Flow log records in particular can be used to give you a great overview of inbound and outbound connections on a network security group (they keep track of layer 4 information). They can help you:

- Perform network monitoring and assess bandwidth utilization.
- Export flows of traffic to analytics workspaces and third-party visualization tools.
- Troubleshoot issues and optimize your network performance.

To create a flow log, browse to the Network Watcher service and then go to Logs > Flow logs. Select "Create". Once you select the subscription resource, configure a flow name and desired location, storage account settings, and the workspace these logs will be sent to. You also need to configure the target resource group. The above example relates to creating an NSG flow to monitor any allowed traffic sourcing from IP address 10.5.4.1 (any source port) and destined to 1.5.12.41, over any TCP port within the 21-1000 range.

Now, you might say, "I just created a flow, so how do I see that log output"? There are a few options for that.

A very typical (but a bit painful one) is to use Azure Storage Explorer, demonstrated on the next page.

Another one is using a Log Analytics workspace and exporting the data there, to be able to apply some fancy KQL afterward. Let's view both of those options.

But before doing that, always keep in mind that when creating a flow, you need to select a version between 1 and 2.

Choosing version 2 allows you to check the flow state, meaning you can identify if this flow is a new one or a continuation of a pre-existing one.

Option 1 (Hard Way): NSG Flow Azure Storage Explorer View

1. Browse to Blob Containers and choose desired directory

2. Choose desired day

3. Choose desired hour

4. Choose desired minute

5. PT1H.json file matching criteria

Name	Access Tier	Last Modified	Blob Type	Content Type	Size
PT1H.json	Hot (inferred)	26/11/2024 17:00	Block Blob	application/octet-stream	122.11 KiB

To view an NSG flow with **Azure Storage Explorer** (mentioned earlier), follow the initial steps below:

- Download, install it, and log in with your Azure credentials.¹
- Navigate to the subscription in question.

After the above are complete, continue with the below:

1. Navigate to your Blob Containers and identify the related directory.
2. Identify the day of interest.
3. Identify the hour of interest.
4. Identify the minute of interest.
5. That filtering will lead you to a **PT1H.json** file. All flow log files have that filename.

You can then preview or download that file and view it with a third-party tool (for example, the **Microsoft Visual Studio Code** tool² is a great option). That has been used to unpack the information on the next page.

1. <https://sec555.com/hr9ys>
2. <https://code.visualstudio.com>

PT1H.json Information

```
{
  "time": "2024-11-26T16:00:19.3013204Z",
  "systemId": "ea4da...",
  "category": "NetworkSecurityGroupFlowEvent",
  "resourceId": "/SUBSCRIPTIONS/4996A69F-I...",
  "operationName": "NetworkSecurityGroupFlowEvents",
  "properties": {
    "Version": 2,
    "flows": [
      {
        "rule": "UserRule_out-100-allow-any-any-0",
        "flows": [
          {
            "flowTuples": [
              "1732636810,10.130.9.200,10.130.9.242,22680,9100,T,O,A,E,1,74,0,0"
            ]
          }
        ]
      }
    ]
  }
}
```

Multiple flow log entries are normally there, but this has been simplified with one here for clarity.

Within the PT1H.json blob, there's some great information for your awareness.

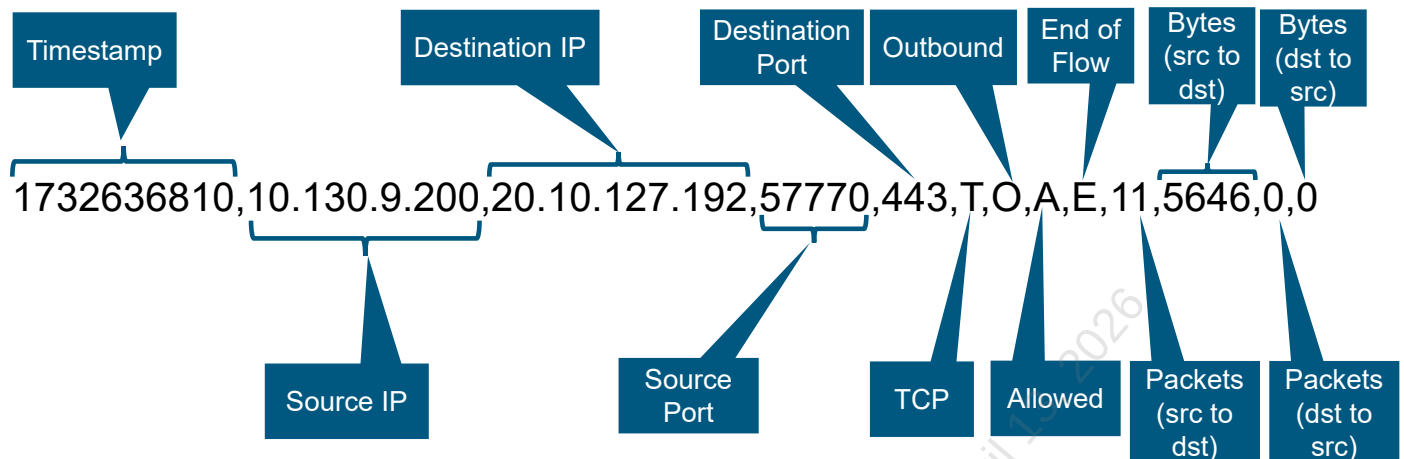
- **Time:** Represents the UTC time (indicated by the ending Z) when the event was logged (here, that's **2024-11-26T16:00:19.3013204**).
- **SystemId** denotes the network security group ID.
- **Category** denotes the event category. Here, that's **NetworkSecurityGroupFlowEvent**.
- **ResourceId** denotes the Resource ID of the network security group (here, that's the bastion host of the range, which is **"/SUBSCRIPTIONS/4996A69F-XXXXXXXXX/RESOURCEGROUPS/SEC555-RANGE-CDRSN/PROVIDERS/MICROSOFT.NETWORK/NETWORKSECURITYGROUPS/SEC555-RANGE-CDRSN-BASTION"**).
- **OperationName:** When referring to NSG flow log records, that will always be **NetworkSecurityGroupFlowEvents**.
- **Version:** Denotes the flow version in use. Here, that's version 2.
- The outer **flows** section contains numerous entries for different rules in operation.
- **Rule:** This denotes which rule(s) these flows listed for.
- The inner flows section denotes the collection of flows.

The flowTuples section follows on the next page.

Reference:

- <https://sec555.com/xq3zp>

NSG Flow Log Records: Flow Tuples



- Configuration possible in Azure Network Watcher or Azure NSG.
- Capture ports, IP addresses, protocols, timestamps, start and end flow times, was the flow allowed or denied, and more.
- If using version 2, flow status shows if this was a new flow or continuation of pre-existing one.

The operation name will always be "NetworkSecurityGroupFlowEvents". But the actual interesting flow detail is under `flowTuples`. If you notice, the previous page's JSON object has a `flowTuples` section annotated with a comment. Let's drill into that by looking at an example of the last line in that section's statement and work out what information each field actually represents.¹ That is:

"1732636810,10.130.9.200,20.10.127.192,57770,443,T,O,A,E,11,5646,0,0"

1. **Timestamp:** This is the timestamp in Unix Epoch format. Using an online Epoch to human time converter tool² and inputting 1732636810, shows that the human-readable date is: 26 November 2024, 16:00:10.
2. **Source IP address:** 10.130.9.200 is where the traffic is sourcing from. That's the address of the 555 range bastion host.
3. **Destination IP address:** 20.10.127.192 is where the traffic is destined to.
4. **Source port:** 57770 is the traffic source port.
5. **Destination port:** 443 is the destination port.
6. **Protocol:** T means the protocol in question is TCP. (Overall: **T** means TCP, **U** means UDP).
7. **Traffic flow:** O means outbound traffic (Overall: **I** means inbound, **O** means outbound).
8. **Traffic decision:** A means allowed (Overall: **A** means allowed, **D** means denied).
9. **Flow state:** E means end of the flow. Note this field only exists in version 2 flows (Overall: **B** means begin, which indicates a new flow is now being created. **C** means continuing, which indicates there's an already existing flow and the current traffic is a continuation of it. **E** means end, indicating the end of a flow).
10. **Packets sent:** 11 packets sent from the source to the destination.
11. **Bytes sent:** 5646 bytes sent from the source to the destination.
12. **Packets received:** 0 packets received at the destination from the source.
13. **Bytes received:** 0 bytes received at the destination from the source.

1. <https://sec555.com/0186n>

2. <https://sec555.com/qhu58>

Option 2 (Easy Way): NSG Flow Using KQL

```

5 AzureNetworkAnalytics_CL
6 | where SubType_s == "FlowLog"
7 | where SrcIP_s == "10.130.9.200"
8 | extend FlowDirection = iff(FlowDirection_s == 'O', 'Outbound', 'Inbound')
9 | extend AllowedOrDenied = iff(FlowStatus_s == 'A', 'Allowed', 'Denied')
10 | extend SourceIP = iff(isempty(SrcIP_s), extract_all(@"\d{1,3}\.\d{1,3}\.\d{1,3}\.\d{1,3})", SrcPublicIPs_s), SrcIP_s)
11 | extend DestinationIP = iff(isempty(DestIP_s), extract_all(@"\d{1,3}\.\d{1,3}\.\d{1,3}\.\d{1,3})", DestPublicIPs_s), DestIP_s)
12 | extend Protocol = case(L4Protocol_s == 'T', "TCP", L4Protocol_s == 'U', "UDP", L4Protocol_s)
13 | project-rename NSGFL_Version = FASchemaVersion_s
14 | project TimeGenerated, FlowDirection, AllowedOrDenied, SourceIP, DestinationIP, DestPort_d, Protocol, L7Protocol_s, NSGList_s, NSGRule_s, NSGFL_Version
15 | limit 100
  
```

TimeGenerated [UTC]	FlowDirection	AllowedOrDenied	SourceIP	DestinationIP	DestPort_d	Protocol	L7Protocol_s
> 11/26/2024, 4:11:05.564 PM	Outbound	Allowed	10.130.9.200	[20.10.127.193;20.189.173.28...	443	TCP	https

```

AzureNetworkAnalytics_CL
| where SubType_s == "FlowLog"
| where SrcIP_s == "10.130.9.200"
| extend FlowDirection = iff(FlowDirection_s == 'O', 'Outbound', 'Inbound')
| extend AllowedOrDenied = iff(FlowStatus_s == 'A', 'Allowed', 'Denied')
| extend SourceIP = iff(isempty(SrcIP_s), extract_all(@"\d{1,3}\.\d{1,3}\.\d{1,3}\.\d{1,3})", SrcPublicIPs_s), SrcIP_s)
| extend DestinationIP = iff(isempty(DestIP_s), extract_all(@"\d{1,3}\.\d{1,3}\.\d{1,3}\.\d{1,3})", DestPublicIPs_s), DestIP_s)
| extend Protocol = case(L4Protocol_s == 'T', "TCP", L4Protocol_s == 'U', "UDP", L4Protocol_s)
| project-rename NSGFL_Version = FASchemaVersion_s
| project TimeGenerated, FlowDirection, AllowedOrDenied, SourceIP, DestinationIP, DestPort_d, Protocol, L7Protocol_s, NSGList_s, NSGRule_s, NSGFL_Version
| limit 100
  
```

The data was sent earlier to a Log Analytics workspace. There's even a standard KQL query called "IPv4 NSG Flow Log Search" that can be used. The query's code (depicted above) is:

```

AzureNetworkAnalytics_CL
| where SubType_s == "FlowLog"
| where SrcIP_s == "10.130.9.200"
| extend FlowDirection = iff(FlowDirection_s == 'O', 'Outbound', 'Inbound')
| extend AllowedOrDenied = iff(FlowStatus_s == 'A', 'Allowed', 'Denied')
| extend SourceIP = iff(isempty(SrcIP_s), extract_all(@"\d{1,3}\.\d{1,3}\.\d{1,3}\.\d{1,3})", SrcPublicIPs_s), SrcIP_s)
| extend DestinationIP = iff(isempty(DestIP_s), extract_all(@"\d{1,3}\.\d{1,3}\.\d{1,3}\.\d{1,3})", DestPublicIPs_s), DestIP_s)
| extend Protocol = case(L4Protocol_s == 'T', "TCP", L4Protocol_s == 'U', "UDP", L4Protocol_s)
| project-rename NSGFL_Version = FASchemaVersion_s
| project TimeGenerated, FlowDirection, AllowedOrDenied, SourceIP, DestinationIP, DestPort_d, Protocol, L7Protocol_s, NSGList_s, NSGRule_s, NSGFL_Version
| limit 100
  
```

Note that it has been modified only to fit the timeframe of interest and the source IP address of 10.130.9.200. If you remove that, it will just show you the overall NSG flow log details.

Any flow log related information is inputted into AzureNetworkAnalytics_CL when you enable

Analytics during your NSG flow creation. And just like magic, all that information is now captured in the workspace for easy analysis.

The only thing the standard query does for you is to take the information from the NSG flow log and present it in a more easily digestible manner by creating new columns, like FlowDirection being populated with Outbound or Inbound, instead of O or I, source IP address represented by the SourceIP column vs. the actual SrcIP_s filed in the flow log, and similarly for allowed or denied traffic, destination IP and protocol.

A full traffic analytics schema breakdown of all the fields is included in Microsoft's documentation.¹

1. <https://sec555.com/4g3k6>

Azure Virtual Machine (VM) Logs



VM Host Logs: CPU, network, disk utilization

- Metrics
- Activity Logs
- Boot Diagnostics

VM Guest Logs: OS and applications inside the VM

- KPI
- Operating System
- Guest OS Data

VM Insights monitors the VM and provides full insight while being able to push data in Azure Monitor

Virtual machines are the most used component in any cloud environment, which means visibility to them allows tracking performance and responding to security-related incidents. Log types related to VMs are:¹

- VM host specific:
 - **Metrics:** Indicators of health and performance for the virtual machine, relating to the actual host the VM is running on. Beautiful statistics are available to track items such as host CPU utilization, disk latency and performance, I/O operation efficiency, and VM availability. Stored in the Azure Monitor metrics database.
 - **Logs:** Actual logs configured to capture specific information to allow troubleshooting and investigations. Stored in the Azure Monitor logs store.
- VM guest specific:
 - **Guest OS metrics:** Like the VM host-specific ones, but this time referring to the guest OS.
 - **Logs:** Logs from the guest operating system running in any Azure VM.
 - **Boot Diagnostics Logs:** Logs related to VM booting, including screenshots and serial output (enabled by default).

You need to ensure you configure the appropriate data collection rules so you are able to collect items of interest, but you first need to install the Azure Monitor Agent on any VMs you are interested in monitoring.² To do so, navigate to your desired Azure VM and then go to Monitoring > Diagnostic settings, where some of the most critical options relate to configuring the log collection agent settings (under the Agent tab), the event and application logs (under the Logs tab) and the ability to send your data to Azure Monitor and/or Application Insights (under the Sinks tab). Both metrics and insights need to be configured and pointed to an appropriate storage location for further investigation of events.

1. <https://sec555.com/d6esf>
2. <https://sec555.com/3gbdh>

Storage Account Misconfiguration

The screenshot illustrates a storage account misconfiguration in Azure. The 'test-container' is shown with 'Anonymous access level' set to 'Container (anonymous read access for containers and blobs)'. A callout box explains that this container is set for anonymous access, allowing attackers to enumerate containers, blobs, files, and queues. A simple GET request is shown to retrieve the file 'Password list follows.txt', which contains a list of usernames and passwords. The XML response shows the file's name and URL. A callout box notes that this is 'Juicy information obtained by attacker'.

Change access level
Change the access level of all selected containers.
Anonymous access level ⓘ
Container (anonymous read access for containers and blobs)
OK Cancel

Name	Last modified	Method	Request URI
test-container	10/17/2024, 9:37:20 PM	GET	https://myaccount.blob.core.windows.net/mycontainer?restype=container&comp=list

GET request format

Set parameters

Container contents listed

This XML file does not appear to have any style information associated with it. The document tree is shown below.

```
<?xml version="1.0" encoding="utf-8" standalone="no" ?>
<EnumerationResults ContainerName="https://sec555rangecdrsncus08cb8.blob.core.windows.net/test-container">
  <Blobs>
    <Blob>
      <Name>Password list follows.txt</Name>
      <Url>https://sec555rangecdrsncus08cb8.blob.core.windows.net/test-container/Password list follows.txt</Url>
    </Blob>
  </Blobs>
</EnumerationResults>
```

Juicy information obtained by attacker

Password list follows

Jane	password1
John	123456789
Niki	pass123
Bob	1q2w3e4r
Dana	Toughpass

"Test-container" is a container set with anonymous access.

Attackers can enumerate an Azure tenant for containers and blobs, files, and queues that have been misconfigured and gain access.

A simple GET request retrieves the file ☹️

The above example shows the attacker viewpoint of an easy day. A container exists within the Azure tenant, which has been set for anonymous access. That means that if anyone is given the unique URI where this resource resides, then they can access it. Note that when you create a new container, the default permission set is private, which doesn't allow anonymous access. You might wonder why anyone would configure it differently then. Ease of use and external access without the need of having an account make for poor administration, but this is something happening more frequently than you think. In the above container, there's a file named *"password list follows.txt"* where a list of users and their associated passwords is stored. This represents any type of information that you want to keep internal to your environment, of course. If you want to list blobs, you can use the following URI to make a GET call:¹ `https://myaccount.blob.core.windows.net/mycontainer?restype=container&comp=list`.

In the above example, the account name is the **555 range**, while the container name is **test-container**. Replacing those in the URI and inserting that in any browser provides an XML layout that contains a link to the blob in question. You can browse to that using any browser or the good old CURL CLI-based tool.² :(

That is really bad, as the attacker can now retrieve all our private information. How would that look in the logs, and how do you search for it?

1. `https://sec555.com/xvsip`
2. `https://sec555.com/4lyze`

Storage Account Misconfiguration: Log Entries

Simple KQL query to identify any anonymous requests for the URI containing our sensitive "test-container"

```

1 StorageBlobLogs
2 | where AuthenticationType == "Anonymous"
3 | where Uri contains "test-container"
  
```

Someone seems to have used CURL to access the data

That's the misconfigured container

Full URI recorded

TimeGenerated (UTC)	AccountName	Location	Protocol	OperationName	AuthenticationType	Uri	StatusCode
> 10/17/2024, 8:40:43.407 PM	sec555rangecdrsncus08cb8	eastus	HTTPS	GetContainerProperties	Anonymous	https://sec555rangecdrsncus08cb8.blob.core.windows.net:443/test-container?restype=container	200

AccountName	sec555rangecdrsncus08cb8
Location	eastus
Protocol	HTTPS
OperationName	GetContainerProperties
AuthenticationType	Anonymous
StatusCode	200
StatusText	Success
DurationMs	9
ServerLatencyMs	9
Uri	https://sec555rangecdrsncus08cb8.blob.core.windows.net:443/test-container?restype=container

UserAgentHeader	curl/7.88.1
Etag	0x8DCEEB7F65B38F
ServiceType	blob
ObjectKey	/sec555rangecdrsncus08cb8/test-container
RequestHeaderSize	176
ResponseHeaderSize	179
LastModifiedTime [UTC]	2024-10-17T20:37:20Z
Category	StorageRead
TlsVersion	TLS 1.3
MetricResponseType	Success
SourceAccessTier	Invalid
SourceSystem	Azure

Blob logs are stored under the Azure "!\$logs" container, while any metric-related details are under "\$metric" (within the "Microsoft.Storage/storageAccounts" namespace). Regarding anonymous requests, Azure logs server errors, successful requests, client and server timeout errors, and failed GET requests with an HTTP response error code of 304 (Not Modified).

There are different ways of accessing those log entries (for example, you can use dashboards, workbooks, or Power BI for visualization purposes), but if you are doing an investigation and would like to gain maximum insight in the easiest way, that's querying the data using Log Analytics (analyzed in detail later). You can use KQL (Kusto Query Language) to make robust and easily adjustable queries. More in-depth details about KQL will be provided in another module, but for now, let's write a simple query to search within the logs regarding anonymous requests for the "test-container", which is the one depicted above.

```

StorageBlobLogs
| where AuthenticationType == "Anonymous"
| where Uri contains "test-container"
  
```

The above query will search within the blob storage logs for any anonymous requests for a URI that contains the "test-container," which is of interest here. Of course, you can make more composite requests over large periods of time to uncover interesting data. For example, let's look at an adjusted version.

```

StorageBlobLogs
| where TimeGenerated > ago(30d) and AuthenticationType == "Anonymous"
| project TimeGenerated, OperationName, AuthenticationType, Uri
  
```

This one goes back 30 days and checks the blob storage logs for anonymous requests. Once it identifies them, it extracts only specific columns and places them in a table format for our analysis. The columns specified in this case are TimeGenerated, OperationName, AuthenticationType, and full Uri.

MITRE ATT&CK Cloud Matrix

Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Exfiltration	Impact
5 techniques	5 techniques	7 techniques	5 techniques	13 techniques	11 techniques	14 techniques	5 techniques	5 techniques	3 techniques	9 techniques
Drive-by Compromise	Cloud Administration Command	Account Manipulation (5)	Abuse Elevation Control Mechanism (1)	Abuse Elevation Control Mechanism (1)	Brute Force (4)	Account Discovery (2)	Internal Spearphishing	Automated Collection	Exfiltration Over Alternative Protocol	Account Access Removal
Exploit Public-Facing Application	Command and Scripting Interpreter (1)	Create Account (1)	Account Manipulation (3)	Domain or Tenant Policy Modification (1)	Credentials from Password Stores (1)	Cloud Infrastructure Discovery	Remote Services (2)	Data from Cloud Storage	Exfiltration Over Web Service (1)	Data Destruction (1)
Phishing (2)	Serverless Execution	Event Triggered Execution	Domain or Tenant Policy Modification (1)	Exploitation for Defense Evasion	Exploitation for Credential Access	Cloud Service Dashboard	Software Deployment Tools	Data from Information Repositories (5)	Transfer Data to Cloud Account	Data Encrypted for Impact
Trusted Relationship	Software Deployment Tools	Implant Internal Image	Event Triggered Execution	Hide Artifacts (1)	Forge Web Credentials (2)	Cloud Service Discovery	Taint Shared Content	Data Staged (1)		Defacement (1)
Valid Accounts (2)	User Execution (1)	Modify Authentication Process (3)	Valid Accounts (2)	Impersonation	Modify Authentication Process (3)	Cloud Storage Discovery	Use Alternate Authentication Material (2)	Email Collection (2)		Endpoint Denial of Service (3)
		Office Application Startup (5)		Indicator Removal (1)	Multi-Factor Authentication Request Generation	Log Enumeration				Financial Theft
		Valid Accounts (2)		Modify Authentication Process (3)	Network Service Discovery	Network Sniffing				Inhibit System Recovery
				Modify Cloud Compute Infrastructure (5)	Steal Application Access Token	Network Sniffing				Network Denial of Service (2)
				Modify Cloud Resource Hierarchy	Use Alternate Authentication Material (2)	Permission Groups Discovery (1)				Resource Hijacking (4)
				Unused/Unsupported Cloud Regions	Steal Web Session Cookie	Software Discovery (1)				
					Unsecured Credentials (3)	System Information Discovery				
						System Location Discovery				
						System Network Connections Discovery				

Misconfigured storage is one of the most critical issues in cloud security. The Cloud-Native OWASP Top 10 list has insecure cloud, container, or orchestration configuration as the #1 listed item.¹ The MITRE ATT&CK cloud matrix, depicted above, also has storage listed under discovery and collection techniques. It's highly beneficial to look at attacks listed in both of these frameworks when creating detection rules. Some recommendations to ensure storage security are:²

- ✓ Use HTTPS for data in transit transfers.
- ✓ Encrypt data at rest by choosing the appropriate disk encryption option.
- ✓ Create shared access signatures (SAS) which allow you to configure options such as:
 - ❑ Services you want to be allowed for access (e.g., blobs, files, queues, tables).
 - ❑ Resource types (services, containers, objects).
 - ❑ Permissions (read, write, delete, and more).
 - ❑ Operating protocols (e.g., HTTP, HTTPS, or both).
- ✓ Use MS Entra ID role-based access control to limit access to data.
- ✓ Avoid making containers accessible via anonymous requests by configuring them to be private.

1. <https://sec555.com/9fzot>
2. <https://sec555.com/89kh2>

Image reference:

- <https://sec555.com/sklp7>

Azure Threat Research Matrix

Reconnaissance	Initial Access	Execution	Privilege Escalation	Persistence	Credential Access	Impact
Port Mapping	Valid Credentials	Virtual Machine Scripting	Privileged Identity Management Role	Account Manipulation	Steal Managed Identity JsonWebToken	SAS URI Generation
IP Discovery	Password Spraying	Unmanaged Scripting	Elevated Access Toggle	Account Creation	Steal Service Principal Certificate	File Share Mounting
Public Accessible Resource	Malicious Application Consent	Managed Device Scripting	Local Resource Hijack	HTTP Trigger	Service Principal Secret Reveal	Replication
Gather User Information			Principal Impersonation	Watcher Tasks	Azure KeyVault Dumping	Soft-Delete Recovery
Gather Application Information			Azure AD Application	Scheduled Jobs	Resource Secret Reveal	Azure Backup Delete
Gather Role Information				Network Security Group Modification		
Gather Resource Data				External Entity Access		
Gather Victim Data				Azure Policy		

Another great resource when creating detection engineering content is the Azure Threat Research Matrix (ATRM).¹ Microsoft has created this to allow us to understand how attackers can leverage various TTPs to execute attacks against your Azure-based resources. It's structured very similarly to the pre-mentioned MITRE ATT&CK matrix. Each top row item (Initial Access, Execution, etc.) marks a specific tactic an attacker can leverage, while the list underneath those terms denotes specific techniques that can be used to perform it. When you drill down to specific sub-topics, there are certain examples on how the Azure CLI/PowerShell, Azure Portal, and Graph API can be used to perform these, in addition to resources of interest being available for further research.

For example, if you browse to AZT104,² you will see a short description about what this technique relates to (falling under the reconnaissance tactic). Basically, it allows you to identify user information. If you browse to the Azure CLI tab, you see command `az ad user show`, which you can use to view user details, using the user's Azure object ID, as follows.

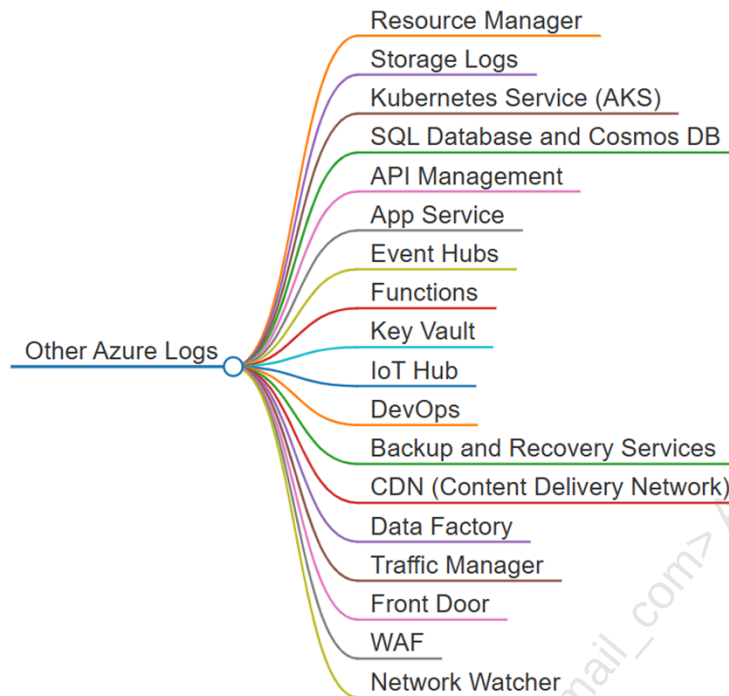
```
az AD user show --id 86dd5d16-130c-4979-xxxx-xxxxxxxxxxxx
```

1. <https://sec555.com/wqtb5>
2. <https://sec555.com/8vtu5>

Image reference:

- <https://sec555.com/wqtb5>

Other Azure Logs



The above graphic represents other possible logs you might want to consider creating an ingestion configuration for, depending on what your use cases are. You can choose what the appropriate export options for these would be and how long you need to keep them for, which can be a considerably large period, if you configure an archival storage account. These items are also provided below:

- Azure Resource Manager
- Azure Storage
- Azure Kubernetes Service (AKS)
- Azure SQL Database and Cosmos DB
- Azure API Management and Azure App Service
- Azure App Service
- Azure Event Hubs
- Azure Functions
- Azure Key Vault
- Azure IoT Hub
- Azure DevOps
- Azure Backup and Recovery Services
- Azure CDN
- Azure Data Factory
- Azure Traffic Manager
- Azure Front Door
- Azure WAF
- Azure Network Watcher

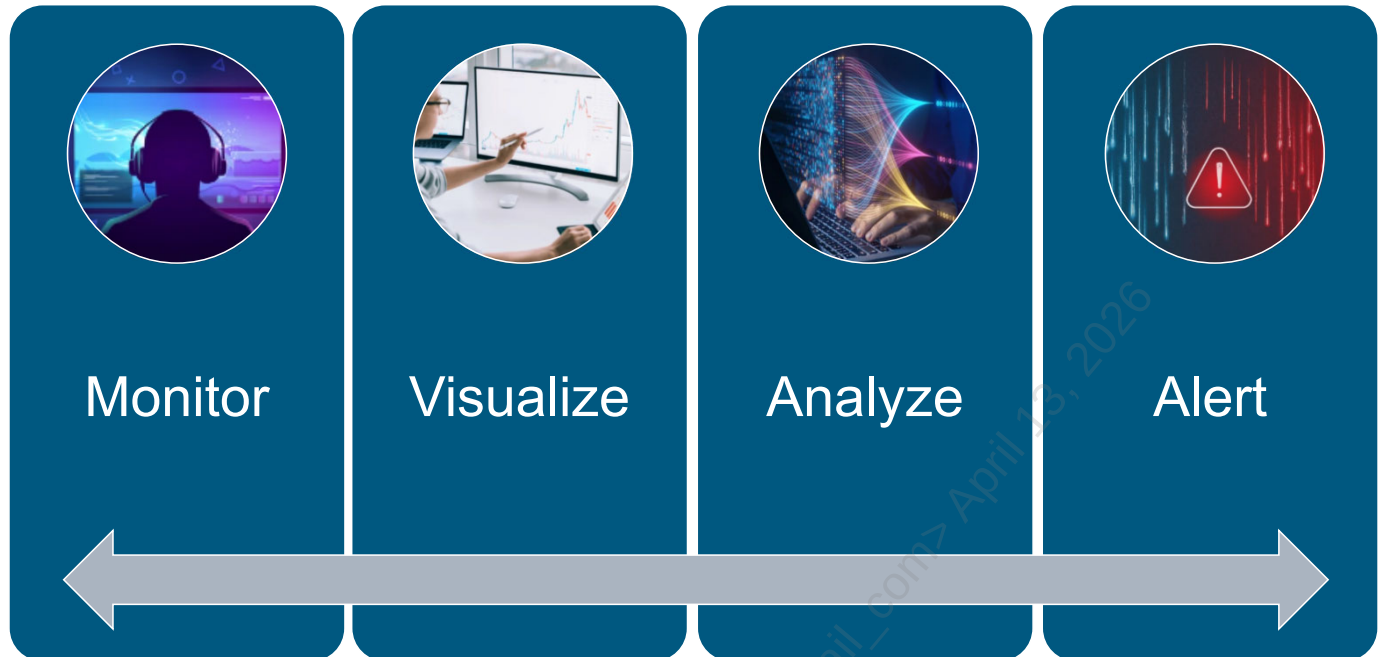
Analyze, Visualize, Report, Tell a Story



The student will obtain valuable insight into what options are available to allow log data to be filtered, visualized, and used in various ways.

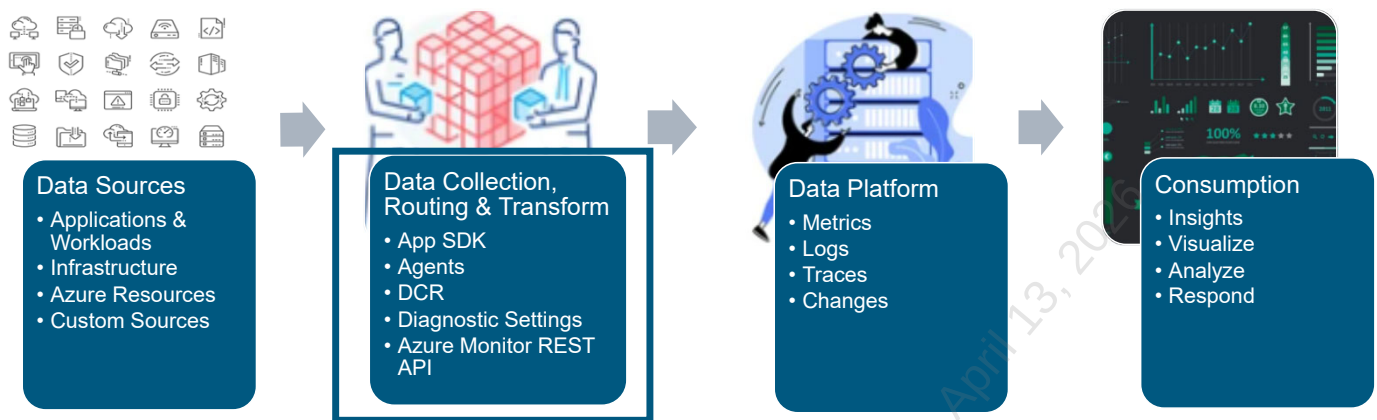
This area is intentionally left blank.

Azure Monitor Introduction



- **Monitor and visualize metrics:** Azure Monitor collects all types of numerical metrics depending on what your organization needs. It helps the administrator emphasize the system health, appropriate operation, and proper performance.
- **Query and analyze logs:** Azure Monitor Logs (Log Analytics) generates activity logs, diagnostic logs, and telemetry information from your monitoring solutions. The service provides analytics queries that you can use to help with troubleshooting and visualizations of your log data.
- **Set up alerts and actions:** Azure Monitor lets you set up alerts for your gathered data to notify you when critical conditions arise. You can configure actions based on the alert conditions, and take automated corrective steps based on triggers from your metrics or logs.

Azure Monitor Data Collection, Routing, and Transform



Any of the pre-mentioned data sources, or a combination of them, can be used to activate data collection, routing, and transformation in Azure. Here are some possible ways for that:¹

- **Application SDK:** Application Insights can be enabled by the related agent or by adding the Application Insights SDK to your application code. For example, if you need to deploy it to a VM, navigate to Home > Monitor > Virtual machines > Overview > Enable (by choosing that on the desired VM).
- **Azure Monitor Agents:** Used mainly for data collection from Azure guest OS in virtual machines.
- **DCR (Data Collection Rules):** Use specific rules to regulate how data collection should take place and where data should be dispatched.
- **Diagnostic settings:** Configure data to be sent to a Log Analytics Workspace, storage account, event hub stream, or another partner solution (as shown before).
- **Azure Monitor REST API:** Gather data via the Azure Monitor API and send it to a Log Analytics workspace or the Metrics storage.

Reference:

- <https://sec555.com/v26z4>

AMA (Azure Monitoring Agent) Installation Options



Agent client file installation (e.g., MSI on Windows 10/11).



DCR creation (agent installed automatically on DCR target resources).



VM Insights enablement (agent installed automatically on target VMs and DCR created).



Configure Azure Policy (deploy AMA on policy-targeted machines).



Container Insights (agent installed on Kubernetes clusters).



VM extension by using the Azure portal, Azure CLI, PowerShell, or the Resource Manager template.

The AMA is the number one choice for being able to monitor VMs, collect logs, and send those to Azure Monitor. It allows you to collect Windows events, performance counters, Syslog data, logs in raw text, JSON, or IIS logs.¹

It can be installed on Azure VMs, other cloud VMs, or on-premises resources. It supports a range of operating systems, which include multiple versions of Linux/Unix and Windows.² There are various ways to install the AMA.³

- **Installation of client file:** Use an MSI and install on Windows 10/11.
- **Create a data collection rule:** That will make the AMA be installed in any of the VMs that are added as resources in the DCR (shown later).
- **Use VM Insights:** Enabling VM Insights on a given VM will result in the AMA being installed and a related DCR being created.
- **Azure Policy:** Create a deployment policy in Azure and configure it to install the agent on all machines, which will also automatically associate them with the necessary DCRs.
- **Container Insights:** If using a Kubernetes cluster, a containerized version of the agent is installed and a related DCR is created.
- **VM extension:** Install the AMA agent on the target resources, but don't forget to create a DCR for it, as this option won't create one for you. You need to complete this for the collection to commence. You can use one of four options to install the VM extension:
 - Azure portal
 - PowerShell
 - Azure CLI
 - Resource Manager template

1. <https://sec555.com/sfdia>

2. <https://sec555.com/usgvj>

3. <https://sec555.com/nytd6>

Creating a Data Collection Rule (DCR)

The screenshot shows the 'Create Data Collection Rule' wizard in the Azure portal. The 'Basics' tab is active, showing fields for Rule Name, Subscription, Resource Group, Region, and Platform Type. The 'Resources' tab is also visible, showing the 'Select a scope' section. The 'Collect and deliver' tab is highlighted with a blue circle and a callout box. The 'Collect and deliver' tab shows the 'Configure the event logs and levels to collect' section, with checkboxes for Application, Security, and System logs, and their respective levels (Critical, Error, Warning, Information, Verbose). The 'Windows Event Logs' are selected as the data source. The 'Select a scope' section shows the 'Resource group' as 'All resource groups' and 'Resource types' as 'All resource types'. The 'Scope' list includes 'sans-range01-sec555', 'sec555-range-cdrsn', and three specific resources: 'sec555-range-cdrsn-dc01', 'sec555-range-cdrsn-dc02', and 'sec555-range-cdrsn-ftp01'. Three blue callout boxes provide additional context: Box 1 points to the 'Windows' platform type selection, stating '1. DCR that contains the Windows machines of the tenant'. Box 2 points to the selected resources in the 'Scope' list, stating '2. Target scope includes the domain controllers and one FTP server'. Box 3 points to the 'Collect and deliver' tab, stating '3. Choose appropriate logs and associated levels'.

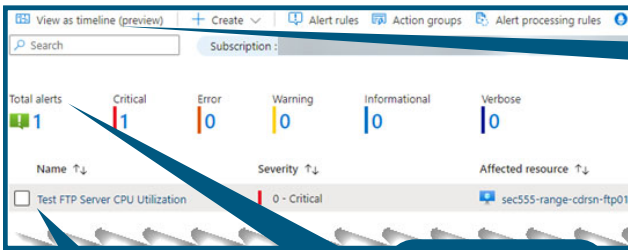
Follow these steps to create the desired data collection rule:

1. Give the rule a name, choose the targeted subscription and resource group of interest (or create a new one if the desired one doesn't exist), and choose the region and platform type (here, that's Windows).
2. The configuration of the Resources tab follows, which will have you select a target scope, meaning which machines you require (in the example depicted, two of the domain controllers and an FTP server have been chosen).
3. "Collect and deliver" follows, which means choosing the appropriate logs and logging levels.
4. Optionally: Define any tags of interest.
5. Select "Review and Create".

Your selected log sources should now report to the Azure cloud.

It's worth highlighting that in order to set your security team for success here, you need to ensure you are collecting the right log sources and that you also define the appropriate collection levels. If you don't, then critical information required to troubleshoot security incidents or performance issues will be lost. It's also important to perform a review of the settings you have configured to ensure they are fit for purpose. Frequency can vary, but in the author's opinion, biannually is a great option, even possibly quarterly, depending on the number of devices you have in your environment and the associated log collection complexity. Ultimately, it would be much better for you to identify any issues early on, preferably without experiencing any issues, vs. doing so after the fact.

Configure Azure Monitor Alerts

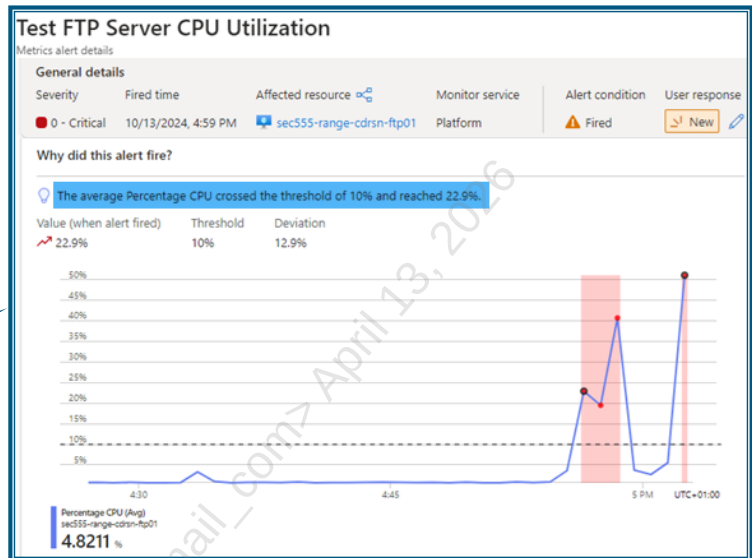


1. Create alert

2. Alert is created

3. Hits can be seen populating the list

4. Alert hit depicted with full details



Creating alerts in Azure Monitor is one of the most useful ways to get notified about things going wrong or flagging behaviors that deviate from what you expect. To create an alert, go to **Monitor > Alerts > Create > Alert rule**. Then choose your resource of interest. In the above example, the FTP server has been selected. After that, select **Next: Condition**. Depending on the resource you have chosen in the previous step, a collection of signals will be displayed, allowing you to choose the most appropriate one.¹ In the above, the percentage CPU is being tracked for going above 10%. You can specify your threshold and the period being evaluated for that threshold to be reached to raise an alert for you. Then, choose your severity level and associated action, configuring an action group of interest, which can also contain notifications via email/SMS/Push/Voice to the appropriate individuals you designate within your Azure subscription. In addition to that, you may choose the alert to trigger an action, like a runbook, event hub integration, Logic App, Azure function, and others. Also note that although you can create new alerts from scratch, Microsoft already has recommended alerts you can enable in the Azure portal, which are composed by identifying important signals and specific resource thresholds in addition to client insight about useful alerts of interest.

If you prefer, you can also manage alert rules using the Azure CLI `az monitor metrics alert` command, PowerShell, or REST API, which can be particularly useful if you need to perform complex querying or need to filter and possibly pass the output to another tool for further actions.

1. <https://sec555.com/e2uqy>

Configure Log Analytics Workspace

Create Log Analytics workspace

Basics Tags Review + Create

Subscription * ⓘ

Resource group * ⓘ [Create new](#)

Instance details

Name * ⓘ

Region * ⓘ

1. Provide subscription information

2. Choose interactive (up to 2 years) and total (up to 12 years) retention periods

Data retention settings

Interactive retention ⓘ

Total retention period ⓘ

Same as workspace settings (30 days)

Same as interactive retention (30 days)

30 days

60 days

90 days

120 days

180 days

270 days

1 year

1.5 years

2 years

3 years

4 years

5 years

6 years

7 years

8 years

9 years

10 years

11 years

12 years

Data collection rules ⓘ

Save

Cancel

- Logs have a cost.
- Default workspace period is 30 days for most tables.
- Do you need data for longer?
- Interactive vs. archived states.

Creating a Log Analytics workspace is very straightforward. Just go to **Home > Monitor > Log Analytics workspaces** and then:

- Provide your subscription information, desired resource group (or create a new one if need be), enter a name, and select a region.
- Optionally: Enter any tags you require. And after validation is passed, select "Create".

Alternatively, you can create a workspace using the Azure CLI or PowerShell, or even a resource manager template.

Note that if you need to change the default workspace 30-day data retention period (note that some of the log tables have 90 days), you need to select the desired workspace and then go to **Settings > Usage and estimated costs > Data Retention**. However, if you need to change the retention period of specific tables, go to the specific workspace you want to change, then to **Settings > Tables** > select the three dots at the far-right side of the desired table. There you will find two options:

- **Interactive retention:** That's the period for which data will be available for interactive queries.
- **Total retention:** Sum of interactive and archive periods (totaling 12 years = 2 interactive + 10 archived).

Another very useful item to note is finding which resource agents are connected to provide data to your workspace. If you go to the specific workspace you want to change, then to **Settings > Agents**, you will have two tabs, one for Windows agents and one for Linux. Note that if you have any legacy agents, those will be under **Classic > Legacy agents management** (not under Settings).

If you go to **Settings > Linked storage accounts**, you can see any linked storage accounts to this workspace, and you can choose to save search and log alert queries into it, in addition to some custom and IIS logs.

Log Analytics Queries Using Azure Resource Graph Explorer

Get started **Results** Messages

name ↑↓	subnets_name	subnets_properties_addressPrefix	Location	Resource group	Subscription
sec555-range-vnet	AzureFirewallSubnet	10.130.8.0/26	East US	sec555-range-cdrsn	sans-range01-sec555
sec555-range-vnet	server	10.130.9.0/24	East US	sec555-range-cdrsn	sans-range01-sec555
sec555-range-vnet	AzureFirewallManagementSubnet	10.130.8.64/26	East US	sec555-range-cdrsn	sans-range01-sec555
sec555-range-vnet	soc	10.130.11.0/24	East US	sec555-range-cdrsn	sans-range01-sec555
sec555-range-vnet	desktop	10.130.10.0/24	East US	sec555-range-cdrsn	sans-range01-sec555

Resources

```
| where type == 'microsoft.network/virtualnetworks'
| extend subnets = properties.subnets
| mv-expand subnets
| project name, subnets.name, subnets.properties.addressPrefix,
location, resourceGroup, subscriptionId
```

If you select *Logs* while on a specific workspace, the query hub will load, and you can then use any pre-created queries of interest to extract relevant information.

Another option is to use the Azure Resource Graph Explorer and input KQL queries to immediately obtain information that you can use to draw fast conclusions.¹

The depicted example query lists all Azure virtual network subnets whilst filtering the data and providing only six columns of interest, while discarding the rest:

Resources

```
| where type == 'microsoft.network/virtualnetworks'
| extend subnets = properties.subnets
| mv-expand subnets
| project name, subnets.name, subnets.properties.addressPrefix,
location, resourceGroup, subscriptionId
```

The following lists all the resources within your Azure subscription:

Resources

```
| project name, type, location
| order by name asc
```

1. <https://sec555.com/4tpfa>

Log Analytics Health Rules

- You need to choose health-oriented rules to ensure awareness, if your workspace isn't responding or not working optimally
- Heartbeat
- Free space
- Processor time
- Available memory

Create an alert rule

Scope Condition Actions Details Tags Review + create

Configure when the alert rule should trigger by selecting a signal and defining its logic.

Signal name *

Alert logic

Threshold

Aggregation

Operator

Unit

Threshold *

Split by dimensions

Dimension name Operator Dimension values

Select dimension

Add custom value

When to evaluate

Check every

Lookback period

Review + create Previous Next: Actions >

Project details

Select the subscription and resource group in which to save the alert rule.

Subscription *

Resource group *

Create new

Alert rule details

Severity *

Alert rule name *

Alert rule description

Criticality should reflect the data present in the workspace

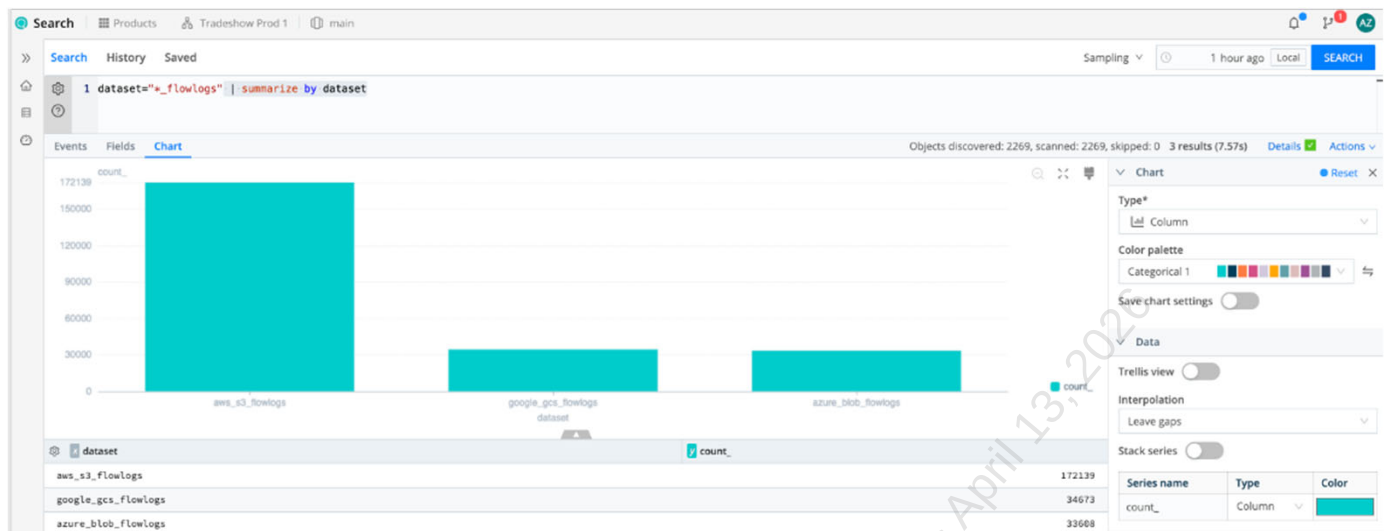
Set appropriate evaluation criteria and thresholds

Don't forget to set appropriate alerts to notify you when the workspaces in your environment experience issues. They can be valuable resources, so setting appropriate alerting is extremely important for a healthy environment. There are numerous signals you can monitor for, and the below are some very interesting and worth considering:

- Available memory
- Free space
- CPU utilization
- Average disk read/writes
- Total bytes sent
- Heartbeat
- Ingestion time
- Uptime

Last, but not least, don't forget to ensure appropriate notifications are configured and automated actions that may be required (if any).

Cribl



Collect – Process – Enrich – Normalize – Reduce Noise = Make operations and alerting efficient

Cribl is a tool that aims to provide value to your data by facilitating collection and using a pipeline called Cribl Stream, which allows it to preprocess and enrich data before collection and storage.

An example could be having 100 known URLs that employees browse to all the time. You don't necessarily need those to be included in your logs, so you can choose not to include them.

It allows you to obtain data from numerous sources (e.g., Amazon CloudFront/CloudWatch/S3/CloudTrail/Lambda and more) and send it to any destination, whether that is cloud, on-prem, or hybrid.

It's also a great way to be able to funnel data that you wouldn't be able to process otherwise without going to great lengths, or with possibly large delays. You can choose to flush out noisy entries, add threat detection enrichment, use it while migrating from a legacy system to a newer one (Cribl would be the conduit taking data from the old and sending that to the new system), or even perform data masking before sending it to other tools.

Who uses Cribl?

- **IT operations** teams use it to streamline log data and minimize ingestion costs before sending that data to other third-party tools, like Splunk, Qradar, or Elasticsearch.
- **SOC** teams use it for enrichment (as mentioned earlier), which in turn improves incident response.
- **DevOps** teams use it to analyze performance metrics and log data.
- **Cloud providers** use it to dispatch logs of interest in a way that reduces egress costs.

References:

- <https://sec555.com/bqn9f>
- <https://sec555.com/6wa5q>

Summary

There's a big variety of log sources that can be utilized in Microsoft Azure. It's instrumental to know what those are and configure them accordingly, to be able to offer maximum value in any given investigative scenario.

Knowing how to use the logs to your advantage entails different approaches. Sometimes you may use Azure CLI/PowerShell, other times the Resource Graph Explorer, or sometimes using Azure Monitor and associated analysis may be more efficient. It's vital to be able to be knowledgeable about all these tools to get the job done.

This area is intentionally left blank.

Logging Unauthorized Access to Sensitive Data

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Course Roadmap

Section 1: Detection Engineering and SIEM Architecture

Section 2: Network and Endpoint Analysis

Section 3: Asset Discovery, Baselines, and UEBA

Section 4: Cloud Logging and Monitoring

Section 5: Alerting and Detection Engineering Pipelines



- Azure Cloud Logging
 - ☐ Lab 4.1: Logging Unauthorized Access to Sensitive Data
- Microsoft Defender Suite and Copilot for Security
 - ☐ Lab 4.2: Defender for Cloud
- Microsoft Sentinel and KQL
 - ☐ Lab 4.3: Sentinel and KQL
- AWS Cloud Logging
 - ☐ Lab 4.4: Creating an AWS Lab, Configuring and Testing CloudWatch

This area is intentionally left blank.

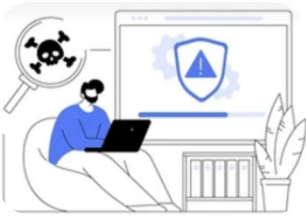
Module Objectives



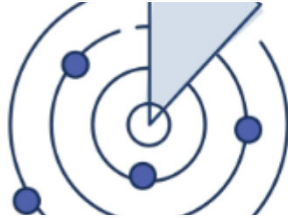
The student will gain insight into the Defender suite (with emphasis on Defender for Cloud, Endpoint, and XDR) and Copilot for Security.

This area is intentionally left blank.

Defender Product Series



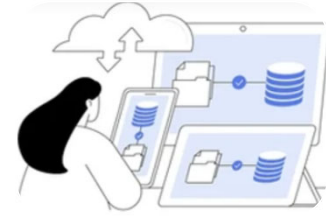
Defender XDR



Defender for Endpoint



Defender for Cloud



Defender for Cloud Apps



Defender for Identity



Defender Vulnerability Management



Defender for Office 365



Defender for IoT

Microsoft has a collection of Defender products aimed at addressing the varied needs of any business:

- **Defender XDR:** Combines telemetry from various sources to offer a one-stop shop when it comes to identifying and remediating threats. It can combine insight from all the other products, including Entra ID Protection and Microsoft DLP (Microsoft Purview). It has a combined incident queue allowing enhanced environmental visibility and situational awareness. It facilitates threat hunting by creating rules and detecting incidents across multiple products, thus lifting any narrowed insight that may exist by a single available product.
- **Defender for Endpoint:** Continuous endpoint protection, even when a device is not on the corporate network. It has advanced features, like the ability to suppress risk by taking automatic actions, providing a full and up-to-date asset inventory of the environment at any moment in time and offering the ability to allow only trusted applications to run or restrict certain behavioral features that can be risky. Also has an antivirus capability, which is enhanced with machine learning, big data analytics, behavioral analysis, and next-generation threat intelligence. It also has a sandbox capability, allows to submit files for analysis, and allows API integration to allow integration with third-party SIEM or other solutions.
- **Defender for Cloud Apps:** Protects your cloud applications by encompassing enhanced cloud access security broker functionality (e.g., insight into the cloud applications used across the company, protecting them from threats, and assessing their posture for company compliance). It can also provide application-to-application protection to ensure swift remediation. Allows application use identification by correlating network traffic to identify applications used on or off the corporate environment. It's also able to perform an automatic security posture assessment and provide remediation recommendations on application security issues that it has identified.
- **Defender for Identity:** Protect your domain controllers and users by detecting various attacks, such as lateral movement, domain enumeration, compromised credentials, gold and silver ticket attacks. The ability to do a full posture assessment of your cloud/on-prem/hybrid domain infrastructure and gain advice about enhancing protection is also provided.

- **Defender Vulnerability Management:** Offers the ability to perform a variety of scans, including compliance assessments. Provides insight into the software you're using and any associated threats it comes with, while also allowing you to know which browser extensions and digital certificates are used across your company. You can choose to block execution of vulnerable applications, create IT remediation tickets, and view remediation status in real time.
- **Defender for Office 365:** Protect the items under your Office 365 subscription. Has anti-malware protection, phishing detection, and anti-spam protection, supports connection filtering, allowing it to block tenant-wide access to suspicious URLs, while it supports email message tracing and API integration with other tools.
- **Defender for IoT:** Designed to secure IoT (Internet of Things) and OT (Operational Technology) environments by identifying and remediating vulnerabilities on a variety of components.

Reference:

- <https://sec555.com/nkl2s>

Defender for Cloud (1)



The student will obtain an understanding of Defender for Cloud operation, provisioning, and alerting.

This area is intentionally left blank.

Defender for Cloud (2)

Enabling Defender for Cloud means also enabling protection/detection for:

- Servers (vulnerability identification, fileless attack mitigation, Docker host hardening).
- Key Vault (detect suspicious activity, like password and secrets unauthorized access).
- Storage (anonymous access, infected file identification).
- Databases (find common vulnerabilities and detect attacks).
- DNS (discover data exfiltration, malware, phishing/crypto mining activity).
- Resource Manager (uncover known exploitation tools and lateral movement attempts).
- Application Service (identify initial access, monitor request/response traffic, and internal logs).
- Containers (scan for vulnerabilities, perform cluster discovery).
- Miscellaneous protections (Azure WAF, DDoS, and security hardening recommendations).

Enabling Defender for Cloud means you are enabling the following:

- **Defender for Servers¹**
 - Defender for Servers (which integrates with Defender for Endpoints) is automatically included in your Azure subscription. An alert triggering in Defender for Servers means it now shows on Defender for Cloud, allowing you to provide appropriate remediations.
 - Vulnerability identification options allow you to see vulnerability alerts as a security recommendation.
 - Embedded file integrity monitoring capability.
 - Docker host hardening supports automatically validating any Docker container configuration against the CIS benchmarks and provides alerting if any deviations from them are found.
 - Fileless attack mitigation by periodical scanning the machine's memory at runtime for known attack tools and suspicious behaviors.
 - Data is collected with
 - Integration with Azure Services for Windows machines
 - Auditd is used for Linux.
 - Azure Arc is used for hybrid configurations, including those containing non-Azure machines.
- **Defender for Key Vault²**
 - Provides alerts for suspicious access or modification of Key Vault passwords, certificates, encryption keys, and overall secrets.
- **Defender for Storage³**
 - Identifies anonymous/suspicious access (e.g., originating from a risky location like a TOR node), usage of compromised accounts, and malicious content existence.
- **Defender for Databases (includes SQL, open source relational—PostgreSQL, MySQL, MariaDB—and Azure Cosmos)⁴**
 - Detects suspicious access, scans databases for potential vulnerabilities, and detects common attacks (like SQL injection and brute force attempts).

- © SANS Institute 2025
- **Defender for DNS**⁵
 - Identifies malicious DNS queries, communications with malicious resolvers, and DNS data exfiltration.
 - **Defender for Resource Manager**⁶
 - Identifies suspicious activities like use of known exploitation tools, lateral movement, shutting down AV, and running malicious scripts.
 - **Defender for Application Service**⁷
 - Creates security recommendations for security artifacts while seamlessly binding with Defender for Cloud Apps.
 - **Defender for Containers**⁸
 - Supports protection of Azure AKS, Amazon EKS, and unmanaged Kubernetes distributions. Scans containers for vulnerabilities and raises alerts for suspicious actions being performed.
 - **Miscellaneous**⁹
 - Display Azure WAF and Azure DDoS protection alerts (assuming the related licenses are active) and any security hardening recommendations Defender for Cloud identifies.

1. <https://sec555.com/jrg4q>
2. <https://sec555.com/o3296>
3. <https://sec555.com/adlqx>
4. <https://sec555.com/xrhav>
5. <https://sec555.com/2hywl>
6. <https://sec555.com/ukb9o>
7. <https://sec555.com/qzo91>
8. <https://sec555.com/217vn>
9. <https://sec555.com/8if5m>

Enable Defender for Cloud: Auto Provisioning

1. Create a Log Analytics workspace.
2. Enable Microsoft Defender for Cloud by choosing the appropriate plan.

Cloud Security Posture Management (CSPM)				
Plan	Pricing*	Resource quantity	Monitoring coverage	Status
Foundational CSPM	Free Details >		Full	☐ Off ☐ On
Defender CSPM	\$5/Billable resource/Month Details >	15 resources	Partial Settings >	☐ Off ☒ On
Cloud Workload Protection (CWP)				
Plan	Pricing*	Resource quantity	Monitoring coverage	Status
Servers	Plan 2 (\$15/Server/Month) Change plan >	14 servers	Full Settings >	☐ Off ☒ On
App Service	\$15/instance/Month Details >	0 instances	Full	☐ Off ☒ On
Databases Action required	Selected: 4/4 Select types >	Protected: 0/0 instances	Partial Settings >	☐ Off ☒ On
Storage	\$10/Storage account/month \$0.15/GB scanned for On-Upload Malware Scanning (configurable) Details >	1 storage accounts	Full Settings >	☐ Off ☒ On
Containers	\$7/VM core/Month Details >	0 container registries; 0 kubernetes cores	Partial Settings >	☐ Off ☒ On
Key Vault	\$0.25/Vault/Month Details >	1 key vaults	Full	☐ Off ☒ On

Follow these steps to enable Defender for Cloud:

1. Create a Log Analytics workspace for log analysis:

- Go to the Microsoft Azure search bar, search for "Log Analytics workspaces" and browse to Log Analytics workspaces when found.
- Select "Create".
- Fill in the related details about your subscription, the desired resource group (or create a new one if an appropriate one doesn't exist), the name, and region, and select "Create".

2. Enable Microsoft Defender for Cloud:

- Go to the Microsoft Azure search bar, search for "Defender for Cloud" and browse to "Microsoft Defender for Cloud" when found.
- The "Getting Started" page is then displayed. Scroll all the way down and select your subscription (if not selected already). Then select "Upgrade".
- Then select Microsoft Defender for Cloud > Management > Environment settings and select your Azure subscription.
- Review selected plans and select Settings & monitoring.
- In the Auto provisioning page, set the status of auto provisioning for the Log Analytics agent to on.
- Select the Log Analytics workspace created earlier. Enable all plans (or customize differently, if needed). Click Save.

Enable Defender for Cloud: Manual Provisioning

Disable auto provisioning

Create a workspace and enable Microsoft Defender for Cloud on that workspace, where the Log Analytics agent will be installed

Choose Environment settings

Choose the workspace on which the agent will be installed at, ensuring that:

- Read and write permissions exist on the workspace
- Workspace needs to be in the same subscription used for Defender for Cloud

Make sure the Microsoft Defender for Cloud option is set to On. Deploy either to:

- New VMs (using a resource manager template to install the Log Analytics agent)
- Existing VMs (using Azure Monitor for virtual machines)

If you need to perform a manual provisioning of Defender for Cloud, you have to follow these steps:

1. Disable auto-provisioning.
2. Create a workspace in which you will enable Defender for Cloud, but ensure a) it exists in the same subscription used for Defender for Cloud, and b) that you have read and write permissions set to it.
3. Check Defender for Cloud is set to **on**.

New VMs: Follow the referenced links for setting up Log Analytics workspace in Windows or Linux.

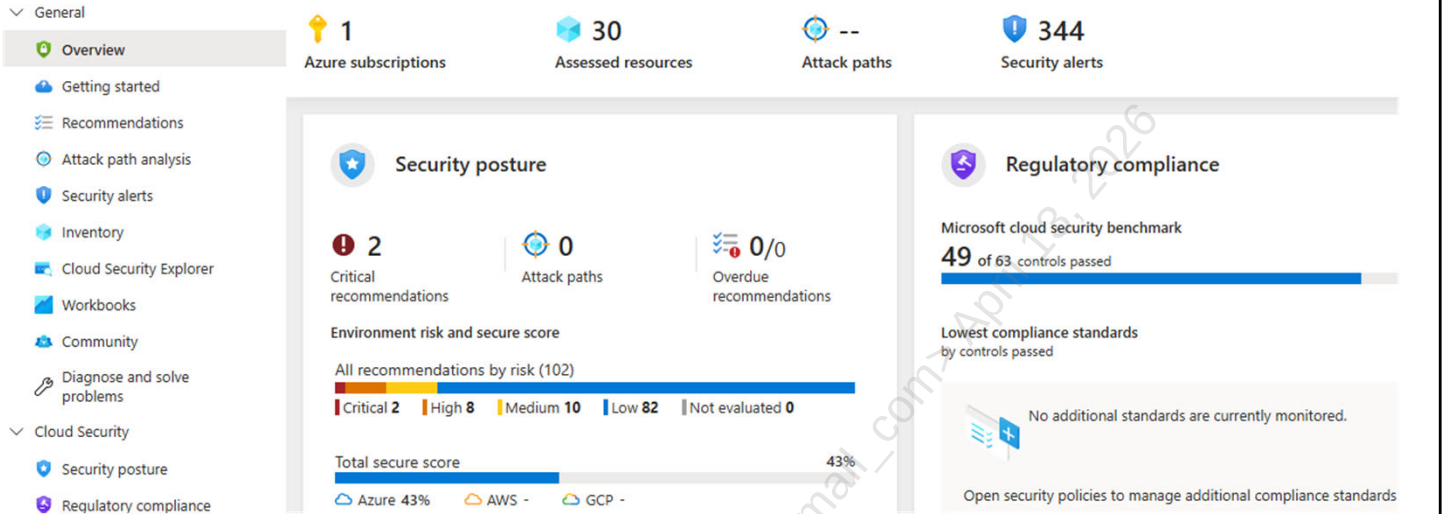
Existing VMs: Follow the referenced link for setting up Azure Monitor.

References:

- Install Log Analytics for Windows: <https://learn.microsoft.com/en-us/azure/virtual-machines/extensions/oms-windows>
- Install Log Analytics for Windows using PowerShell: <https://learn.microsoft.com/en-us/azure/virtual-machines/extensions/oms-windows?toc=%2Fazure%2Fazure-monitor%2Ftoc.json%3Fazure-portal%3Dtrue>
- Install Log Analytics for Linux: <https://learn.microsoft.com/en-us/azure/virtual-machines/extensions/oms-linux>
- Install Log Analytics for Linux using PowerShell: <https://learn.microsoft.com/en-us/azure/virtual-machines/extensions/oms-linux?toc=%2Fazure%2Fazure-monitor%2Ftoc.json%3Fazure-portal%3Dtrue>
- Monitor virtual machines with Azure Monitor: <https://learn.microsoft.com/en-us/azure/azure-monitor/learn/quick-collect-azurevm>

Enable Defender for Cloud on Non-Azure Resources

- Azure Arc-enabled servers (easiest and recommended approach).
- Azure portal use for non-Azure machines.
- Add Linux machines.
- Add Windows machines.
- Add AWS accounts.
- Connect GCP.



1. **Azure ARC** (provides a uniform method to manage VMs, Kubernetes clusters, Azure data services, and SQL servers that may be present in Azure, other clouds, or on-premises).
 - Navigate to Azure Arc > Infrastructure > Servers > Add
 - Select Add single server and then Generate script. Review prerequisites and select Next.
 - Select subscription, Resource group, Region, Operating system and connectivity mode and select Next.
 - Download script (after making any changes, if you wish to).
 - Install Windows/Linux agents using the provided script.
 - Optional: If you navigate back to the Azure Arc > Servers page, you should now see your machines reporting into it.
2. **Azure portal.**
 - Go to Microsoft Defender for Cloud and go to the Getting started tab.
 - Select Add non-Azure Servers and select Continue.
 - Open the Inventory page, under the Defender for Cloud menu.
 - Select the plus sign where it states + Add non-Azure servers.
 - Select the pre-existing Log Analytics workspace or create a new one and add desired computers by selecting Add Servers.
 - Choose the appropriate machine type (Windows vs. Linux).
3. **Add Linux machines.**
 - Go to Agents management, copy the WGET command into a new text file, and save it.
 - On your Linux machine, open the file with the WGET command, select it, and paste it into a terminal console.
 - When the installation finishes, you can validate that the omsagent is installed by running the pgrep command, which will return the omsagent PID.
 - Logs are at: /var/opt/microsoft/omsagent/workspace id/log/. Note that it might take up to 30 minutes for the new Linux machine to appear in Defender for Cloud.

4. Add Windows machines.

- Go to Agents management, select the appropriate agent file (32 or 64 bit).
- Copy the Workspace ID and Primary Key.
- Copy the downloaded setup file to the target computer and run it.
- Follow the installation wizard (Next > I Agree > Next > Next).
- On the Azure Log Analytics page, enter the previously copied Workspace ID and Workspace Key (Primary Key).
- Enter all the configuration settings and select Next.
- While in the Ready to Install page, review the settings to be applied and choose **Install**.
- Select Finish.
- Once this step is completed, the Microsoft Monitoring Agent appears in the machine's control panel.

5. Add AWS accounts.

- Follow the instructions.

6. Add GCP accounts.

- Follow the instructions.

References:

- <https://sec555.com/r45es>
- <https://sec555.com/8jftv>
- <https://sec555.com/s9dpi>
- Video: <https://sec555.com/7rajw>
- Instructions: <https://sec555.com/kreay>

Alert Actions

Security alert

'Relvelshe' backdoor was detected
(Agentless)

High
Severity

Active
Status

10/23/24, 02:50 PM
Activity time

Alert description

Copy alert JSON

Backdoors are malicious remote access tools that allow attackers to access and control infected machines. Backdoors can also be used to exfiltrate data.

Alert details

Take action

- Inspect resource context
- Mitigate the threat
- Prevent future attacks
- Trigger automated response
- Suppress similar alerts
- Configure email notification settings

SOC Analyst
key areas

Threat
detection
engineering
key focus

Email notifications

Email recipients

Select who'll get the email notifications from Defender for Cloud for the sans-range01-sec555 subscription.

All users with the following roles

Owner

Additional email addresses (separated by commas)

soc@sans.org

Notification types

Use the settings below to select the type of email notifications to be sent by Defender for Cloud.

☒ Notify about alerts with the following severity (or higher):

High

You'll receive a maximum of one email per 6 hours for high-severity alerts, one email per 12 hours for medium-severity alerts, and one email per 24 hours for low-severity alerts.

☒ Notify about attack paths with the following risk level (or higher):

High

You'll receive a maximum of one email per 30 minutes for attack paths with critical risk-level, one email per 1 hour for medium risk-level, and 1 email per 3 hours for attack paths with low risk-level.

When new alerts are received, you can configure automated responses for inbound alert remediation. With any Defender for Cloud alert, there are a few options to choose from when you select the "Take Action" tab, with the highlighted two being critical for any threat detection engineer. Those options are:

- **Inspect resource context:** Highlights appropriate logs of interest.
- **Mitigate the threat:** A detailed description is provided about what steps should be taken to remediate the threat.
- **Prevent future attacks:** Gives you a breakdown of security recommendations that could be followed to prevent this from re-occurring.
- **Trigger automated response:** "Trigger logic app", which allows you to trigger an automated action based on three types of triggers: Security Alert, Recommendation, or HTTP request (analyzed further on the next page).
- **Create suppression rule:** Allows you to create a suppression to ensure future detections are disregarded (analyzed later).
- **Configure email notification settings:** Allows you to configure email addresses of key people that you want to notify about the alert (including a filter for notifications going out for a certain severity level of alert and above), while also focusing on alerts that Defender for Cloud has identified an existing attack path of a certain severity and above.

Note that another great thing to think about is porting all these useful alerts into your desired ITSM or SIEM tool of note. Examples include ServiceNow, JIRA, and more.

Logic App Integration for Alert Response

The image shows a Microsoft Defender for Cloud alert and a Logic App Designer workflow. The alert on the left is titled "'Relvelshe' backdoor was detected (Agentless)" with a severity of 'High' and status of 'Active'. It includes a description of backdoors and a list of recommended actions. The Logic App Designer on the right shows a workflow named 'TestNotifications' with a trigger 'When a Microsoft Defender for Cloud alert is created or triggered' followed by actions 'Send an email (V2)' and 'Send SMS Message'.

1. Inbound security alert

2. Triggers Logic App

3. Logic App configuration using Designer, in a building block-like format

4. Upon alert reception from Defender for Cloud, send an email to the SOC group and also send an SMS message for high priority incident

Threat detection is all about responding to security incidents quickly and efficiently, with a focus on automation, aiming to reduce manual labor and any associated delays.

Section "**Trigger automated response**" provides an option to configure a logic app ("Trigger logic app") that allows you to trigger an automated action, as seen in the above image.¹ Navigating to "Logic Apps" allows you to see the list of Logic Apps already configured or to create a new logic app for your tenant. When you choose that and go to Workflows > "Get started", you can configure one from scratch or use the already existing Designer to help you create a workflow. When you choose that, select "New" to add a workflow, and once you select that, choose Developer > Designer to add appropriate triggers and actions.² There are several workflow triggers you can choose from to serve your needs.³

In the above example, when an alert is received, a notification email and an SMS message are configured to be sent out to the appropriate teams.

1. <https://sec555.com/9b0gi>
2. <https://sec555.com/wl6ki>
3. <https://sec555.com/98kz1>

Create a Rule for Alert Suppression

Security alert

'DDEDownloader' exploit malware was detected (Agentless)

High Severity Active 10/23/24, 02:50 PM Activity time

Alert description

Exploits take advantage of unsecure code in operating system components and applications. Exploits allow attackers to run arbitrary code, elevate privileges, and perform other actions that increase their ability to compromise a targeted machine. Exploits are found in both commodity malware and malware used in targeted attacks.

This detection might indicate that the malware was stopped from delivering its payload. However, it is prudent to check the machine for signs of infection.

Last updated time

10/23/24, 02:50 PM

Mitigate the threat

To remediate the threat:

1. Contact your incident response team.
2. If the machine is part of a network, make sure the machine is connected to the network.
3. Install Microsoft Defender for Endpoint on the machine.
4. Update malware definitions to the latest version.
5. Run a full scan on the machine.

If you believe a file is being incorrectly identified as malicious, click the file name or file hash to view details.

You have 37 more alerts on the alert page.

Prevent future attacks

Your top 3 active security recommendations:

- High
- Medium
- Medium

Alert suppression criteria are critical.

A suitable name, reason, and comment help avoid confusion.

New suppression rule

Create suppression rule in order to automatically dismiss alerts by pre-defined conditions. [Learn more >](#)

Rule Conditions

Subscription *

sans-range01-sec555

Alerts *

☐ Custom ☒ All

Entities

File Directory Contains test-SOC-detect

Rule details

Rule name *

SOCRedAtomicExclusion

State *

Enabled

Reason *

The resource isn't relevant for me to monitor

Comment

This folder contains Red Atomic scripts to test SOC detection capability.

Appropriate alert suppression reduces analyst fatigue. Happy SOC analyst = Happy Life 😊

Assume that one of your threat detection engineers has created a folder named "test-SOC-detections" and they have placed a copy of the Red Atomic scripts by Red Canary, which they are using to check if SOC detection rules are triggering properly. Well, in that case, you need to exclude that folder from making alerts fire unintentionally. You can easily create a suppression rule for that purpose:

1. Navigate to "Microsoft Defender for Cloud" > "Security alerts" > Choose the alert of interest > In the right pane, go to "Take action" > "Suppress similar alerts" > "Create suppression rule".
2. Choose the subscription in question.
3. Select the alert scope (custom alert or All).
4. Choose the appropriate entities (in the above example, the file directory containing a portion of the directory name has been specified).
5. Specify an alert name and state (enabled or disabled).
6. Choose a suitable reason from the dropdown list or "Other", if none applies.
7. Add the appropriate comment.
8. Choose a rule expiration timeframe (specifying when the rule should expire) or None. **Be careful not to set None unless you really are certain you never want this alert to fire.**
9. Hit "Apply".

Note that if you are thinking of creating your own custom rules, you can always do so and choose to also suppress specific alert aspects using KQL.

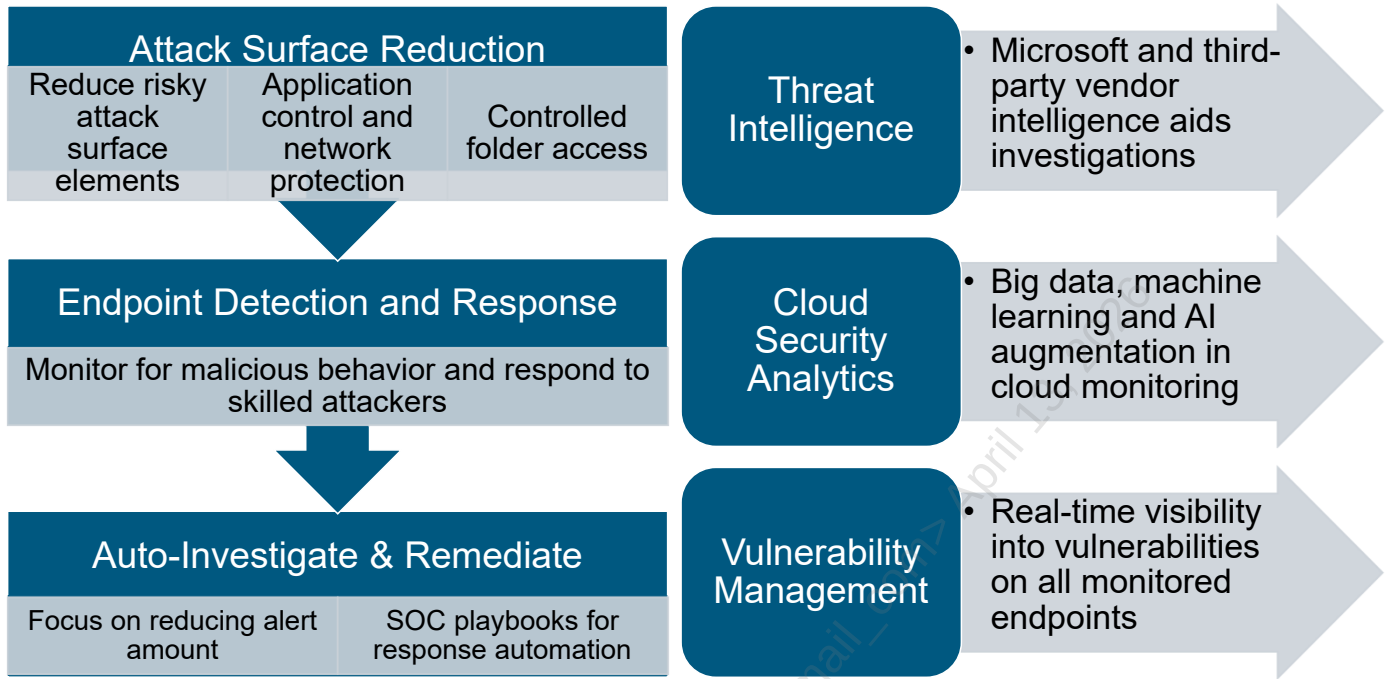
Defender for Endpoint



The student will dive into the Defender for Endpoint architecture, onboarding steps, deployment, and post-onboarding tasks.

This area is intentionally left blank.

Defender for Endpoint Key Points



Defender for endpoint sensors collects telemetry about a variety of events, like firewall, browser activity, possible threats, hardware information, network activity, update status, sensor health, AV protection and functions, exploit protection, and many more. Device discovery allows it to detect devices that may be present on the network but are currently unmanaged, so not currently onboarded to the tool. It uses the already onboarded sensors to probe the network and collect information about other neighboring devices. Each client that subscribes to Microsoft Azure gets an isolated Defender tenant, which is totally independent from other clients, and makes data accessible only via Azure AD authentication.

Defender for Endpoint aims at continuously checking your environment for risks and flags them for your attention. A great feature to note here is mapping attack paths, giving you insight into ways that the attacker may be able to access sensitive data or crown jewel resources. Specific features include the following:

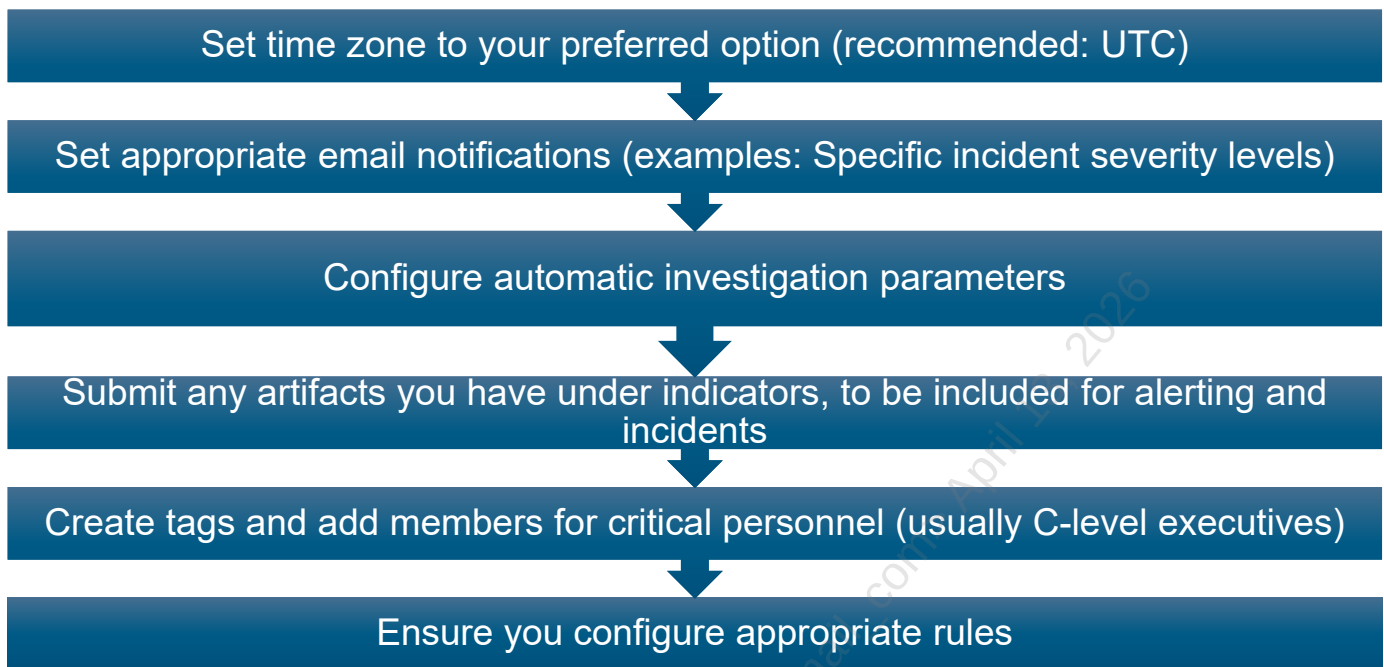
- **Attack Surface Reduction:**¹ Aims at reducing network exposure to attacks.
 - Application Control: Applications aren't trusted explicitly but only run if you trust them. You can deploy appropriate policies to ensure a machine has the minimum OS prerequisites in addition to limiting which applications are allowed to run in your environment. Supported in Windows 10/11 and Windows Server 2019 onward.
 - Configure rules to limit application capability and reduce likelihood of damage to your environment.
 - Network Protection: Microsoft SmartScreen offers anti-phishing and anti-malware support,² reputation-based URL and application protection, and the ability to manage it via group policy or Microsoft Intune. It also assesses network connections and traffic for signs of malicious artifacts.
- **EDR (Endpoint Detection and Response):**³ All endpoints with Defender are monitored for vulnerabilities, malware, exploit kits, and other signs of potential intrusions, and it can take automatic action to suppress these or raise them to the attention of the SOC team in near real time. It monitors network connections, file system changes, and registry activity for suspicious indicators.
- **Automatic Investigation and Remediation:**⁴ The focus is to reduce the number of alerts under

investigation so the SOC can work more efficiently. Automation is integral here and workbooks are extremely vital.

- **Threat Intelligence:** Defender's threat intelligence is a combination of Microsoft and third-party information about a variety of TTPs that exist in the industry and are tracked for your attention while also generating alerts of interest when one is identified in your environment.
- **Cloud Security Analytics:** An emphasis on using AI and ML for cloud application monitoring (e.g., the Office 365 suite).
- **Vulnerability Management:** Having the Defender sensor on monitored machines gives you an unparalleled viewpoint of existing vulnerabilities and ways to remediate and patch those accordingly. Increased accuracy and false positive reduction are key to endpoint hardening. Also provides the ability to integrate with Microsoft Intune to take immediate action (e.g., request an application to be updated or a patch to be rolled out ASAP).

1. <https://sec555.com/w5dns>
2. <https://sec555.com/26hip>
3. <https://sec555.com/8mxn7>
4. <https://sec555.com/kzdjs>

General Settings Overview



Here are some settings worth considering:

1. Set a preferred time zone to ensure investigation consistency (Settings > Microsoft Defender portal).
2. Set appropriate notifications about incidents, actions taken, and threat analytics (Settings > Microsoft Defender XDR > General > Email notifications > Add incident/Add notification/Create a notification rule).
3. Go to Settings > Endpoints > Rules > Automation uploads and define which file extensions you require to include in file content analysis, which means that content analysis will submit suspicious files to the cloud for additional inspection. You can also define if you need the machine's memory to be included so that suspicious processes can be analyzed further for malicious indicators.
4. Go to Settings > Endpoints > Rules > Indicators, to import file hashes, IP addresses, URLs/domains, and certificates as IOCs.
5. Go to Settings > Email & collaboration > User tags > Create. There, you can define any identities in your tenant that may be high-profile individuals like Managing Directors, VPs, or C-level executives.
6. Go to System > Settings > Endpoints > Rules and ensure you check for appropriate configurations under:
 - **Indicators** (note you can also use the indicator API for robust updates, throttled at 100 calls/minute and 1,500 calls per hour).
 - **Web content filtering** (choose suitable sub-categories within Adult Content, High Bandwidth, Legal Liability, Leisure, and Uncategorized).
 - **Automation folder exclusions:** If you need automated investigation to skip certain folders, you can include them here.

Post Onboarding Critical Task List

Task	Description	Priority
Attack surface reduction (P1/P2)	Ensures that configuration settings are properly set and that exploit-mitigation techniques are applied to help reduce your attack surfaces.	Recommended
Mobile threat defense (P1/P2)	Microsoft Defender for Endpoint on Android and iOS is our Mobile Threat Defense solution. Companies tend to be proactive when protecting PCs from vulnerabilities and attacks, but mobile devices often go unmonitored and unprotected.	Recommended
Next-generation protection (P1/P2)	Brings together machine learning, big-data analysis, threat resistance research, and the Microsoft Cloud infrastructure to protect devices in your enterprise organization.	Recommended
Auto investigation and remediation (P2)	The technology in automated investigation uses various inspection algorithms and is based on processes that are used by security analysts. These capabilities are designed to examine alerts and take immediate action to resolve breaches.	Recommended
Microsoft Secure Score (P2)	Helps you dynamically assess the security state of your enterprise network, identify unprotected systems, and take recommended actions to improve the overall security of your organization.	Recommended
Endpoint detection and response (P2)	Microsoft Defender for Endpoint detection and response capabilities provide real-time and actionable advanced attack detections.	Recommended
Threat and vulnerability management (P2)	Identifying, assessing, and remediating endpoint weaknesses is pivotal for running a healthy security program and reducing organizational risk.	Recommended
Windows Firewall	Windows Firewall helps prevent malicious hackers and software from accessing your PC through the internet or a network.	Recommended

- Review the proposed list of Defender capabilities and configure features accordingly for increased protection.
- Create an attack surface reduction policy to aid risk mitigation.
- Create additional endpoint policies using templates, like Defender Antivirus settings, Defender update controls, and more.
- Configure the Windows firewall for host protection.
- **Remember, host preventative capability is the last line of defense.**

Take a good look at the above image and ensure you go over the references below. They both have great recommendations to consider when it comes to strengthening how your endpoints react when encountering malicious or suspicious activities that may be taking place.

1. Create a robust attack surface reduction policy by going over each setting and configuring it accordingly.
2. Use the pre-existing endpoint security policy templates to craft your desired protection policy.
3. Review the Secure score and vulnerability management information to stay on top of vulnerabilities.

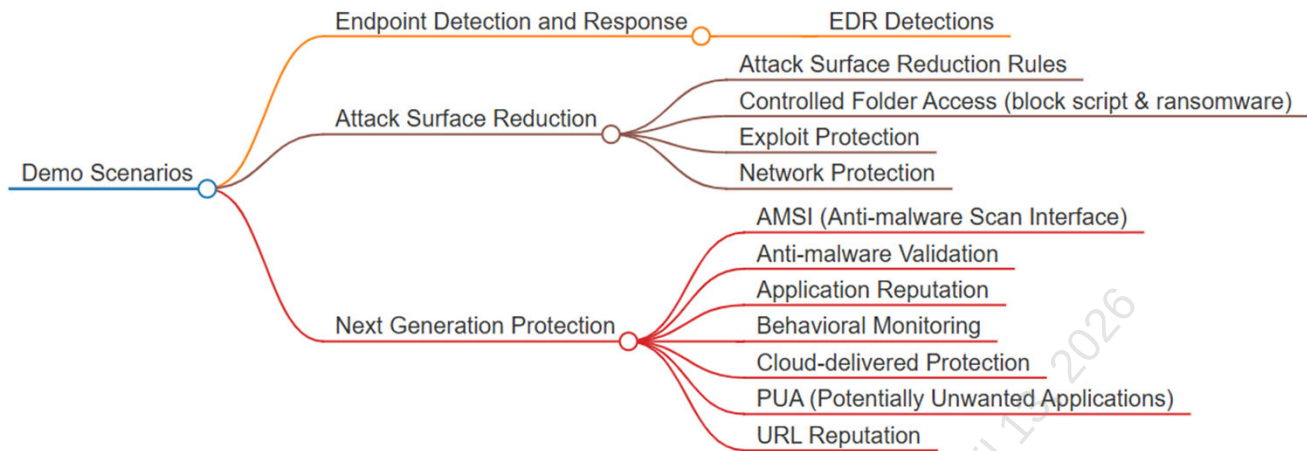
References:

- <https://sec555.com/otdul>
- <https://sec555.com/zlj89>
- <https://sec555.com/dq4em>
- <https://sec555.com/o7wpk>
- <https://sec555.com/6mih4>
- <https://sec555.com/71lpy>

Image reference:

- <https://sec555.com/h7r85>

Demo Scenarios for Operation Verification



- After deployment and initial configuration of the tool's features, take it for a spin using harmless demo scenarios.
- Zero impact, maximum benefit, and comfort for leadership.
- You can even create your own. 😊

Microsoft makes available numerous scenarios¹ for harmless testing while still providing great benefits.² As you are testing, make sure you look out for the following:

- Are these scenarios working properly across different devices (e.g., Windows, macOS, Linux)?
- Have you forgotten to switch some of the related features on?
- Have all desired features been configured appropriately for detections to work?
- Are your tool policies set and up-to-date with corporate policies?
- Do you need to create additional scenarios of note to ensure thorough testing is in effect?

If a test fails, try to identify the root cause and resolve it accordingly. Don't try to instigate workarounds or temporary fixes because that results in greater issues further down the line. Also, it makes it harder for others to assess issues when you're not there.

1. <https://sec555.com/mqs9x>
2. <https://sec555.com/9e6in>

Asset List Inspection

All devices										
Computers & Mobile Network devices IoT/OT devices Uncategorized devices										
Total	Critical assets	High risk	High exposure	Not onboarded	Newly discovered					
14	2	3	4	4	1					
☐ Name	IP	Device type	Risk level	Exposure level	OS platform	OS version	Sensor health state	Onboarding status	Last device update	
☐ iron-man.4os3dbvxxk4ehly0zgea...	10.130.9.80	Server	■ ■ ■ ■ No known ri...	▲ Low	Linux	20.4	● Active	✓ Onboarded	Oct 31, 2024 4:21 PM	
☐ soc01.4os3dbvxxk4ehly0zgea...	172.17.0.1	Server	■ ■ ■ ■ High	▲ Low	Linux	20.4	● Active	✓ Onboarded	Oct 31, 2024 4:21 PM	
☐ sec555-range-cdrsn-bastion.4...	10.130.9.200	Server	■ ■ ■ ■ No known ri...	▲ Low	Linux	20.4	● Active	✓ Onboarded	Oct 31, 2024 3:20 PM	
☐ mail01.avengers.org	10.130.9.25	Server	■ ■ ■ ■ High	▲ High	Windows Server 20...	21H2	● Active	✓ Onboarded	Oct 31, 2024 5:11 PM	
☐ dc02.avengers.org	10.130.9.10	Server	■ ■ ■ ■ No known ri...	▲ Medium	Windows Server 20...	1809	● Active	✓ Onboarded	Oct 31, 2024 5:26 PM	
☐ linux01.4os3dbvxxk4ehly0zgea...	10.130.10.30	Server	■ ■ ■ ■ No known ri...	▲ Low	Linux	20.4	● Active	✓ Onboarded	Oct 31, 2024 3:21 PM	
☐ spiderman.4os3dbvxxk4ehly0...	10.130.9.242	Server	■ ■ ■ ■ No known ri...	▲ Low	Linux	20.4	● Active	✓ Onboarded	Oct 31, 2024 3:11 PM	
☐ dc01.avengers.org	10.130.9.5	Server	■ ■ ■ ■ No known ri...	▲ Medium	Windows Server 20...	21H2	● Active	✓ Onboarded	Oct 31, 2024 4:50 PM	
☐ ftp01.avengers.org	10.130.9.21	Server	■ ■ ■ ■ High	▲ Medium	Windows Server 20...	1809	● Active	✓ Onboarded	Oct 31, 2024 5:16 PM	
☐ win05	10.130.10.25	Workstation	■ ■ ■ ■ No known ri...	▲ Medium	Windows 10	23H2	● Active	● Can be onboarded	Oct 30, 2024 12:55 PM	
☐ win02.avengers.org	10.130.10.10	Workstation	■ ■ ■ ■ No known ri...	▲ High	Windows 10	21H2	● Active	✓ Onboarded	Oct 31, 2024 2:55 PM	
☐ win03	10.130.10.15	Workstation	■ ■ ■ ■ No known ri...	▲ High	Windows 10	21H2	● Active	● Can be onboarded	Oct 31, 2024 12:56 PM	
☐ win01	10.130.10.5	Workstation	■ ■ ■ ■ No known ri...	▲ High	Windows 10	21H2	● Active	● Can be onboarded	Oct 31, 2024 12:56 PM	
☐ win04	10.130.10.20	Workstation	■ ■ ■ ■ No known ri...	▲ Medium	Windows 10	23H2	● Active	● Can be onboarded	Oct 30, 2024 1:02 PM	

Well, all these look active and good to go

Why are these not onboarded but can be?

As an engineer, you will always be responsible for the smooth running of the devices in your environment. Your analysts will be relying on you to ensure all devices are onboarded, reporting into the console, and overall are ready for action. If they aren't, then the SOC can't respond to incidents. Now, what's wrong with the above picture?

Navigating to Assets > Devices provides the above summary. A total of 14 devices have been discovered by Defender, but 4 of them are marked as not onboarded. But Defender states that these can be onboarded. Hmm, why is that? The reason is in the fine print. If you were to look closer, there are a couple of things not exactly right. But what are these?

You can, of course, try reading the logs, navigating to the tool's linked articles and information, or do yourself a favor and make it as easy as possible. Use a tool that was mentioned earlier—the MDE Client Analyzer. You have two options for using the tool.

- Using Live response¹
- Running the tool locally²

Let's go with option 2, detailed on the next page.

1. <https://sec555.com/kzmv1>
2. <https://sec555.com/wyqp0>

Running the MDE Client Analyzer Tool to Troubleshoot the Issue

MDE Client Analyzer Results

Script Version: 08May2024 | Script RunTime: 31/10/2024 6:12:36 PM +00:00

Device Information

General Device Details

Device name	win03
Device Operating System	Windows 10 Pro
OS build number	Microsoft Windows NT 10.0.19044.0.3086
OS Edition	Client
OS Architecture	64-bit
SystemBootTime	09/14/2024 00:40:15
Streamlined Connectivity Readiness	This device is not ready for streamlined connectivity. Please update the following components: EDR Sense
System-wide WinHTTP proxy	Direct access (no proxy server).

AV Component Details

Defender AV Platform Version	4.18.24080.9
Defender AV Security Intelligence Version	1.421.12.0
Defender AV engine Version	1.1.24090.11

Detailed Results

Category	Severity	Id	Test Name	Results
Configuration	Error	122010	MoCAMPVersion	Please note that this machine is running with an outdated version of Defender Platform. Platform versions older than N-2 will no longer be supported.
Configuration	Warning	121012	SecurityIntelligenceVersion	Please note that this machine is running with outdated security intelligence version. It is recommended to apply the most recent security intelligence version to ensure optimal protection and compatibility.
Connectivity	Warning	131020	Streamlined Connectivity	Device is not ready to support streamlined connectivity. The following components do not match the minimum required version: EDR Sense
Connectivity	Warning	131007	AVCloud	Test connection to the Microsoft Defender Antivirus cloud service failed: ERROR: ValidateMapsConnection failed (0x80508015)

1. Defender platform is outdated (ERROR)
2. Security Intelligence version is outdated (Warning)
3. Streamlined connectivity readiness failed (Warning)
4. Unable to reach the Cloud AV service (Warning)

Important:

Basic hygiene matters. Check the errors, fix them, update what requires updating, and ensure Defender is enabled and running.

When the MDE client analyzer tool ran, it flagged a few items for our attention:

- The Defender platform is outdated and doesn't meet the minimum requirements to be supported. **An update is mandated.**
- Security intelligence is outdated and comes back with a warning. Ideally, you want to update to the latest and greatest, so you can have appropriate definitions and telemetry provided from the sensor. Easy to fix with an update.
- When onboarding the sensor, there are two connectivity options to choose from: **Standard and streamlined**. Streamlined was chosen, but it isn't supported. That won't allow the machine to be onboarded properly if it's not fixed. Another easy fix. Going back to onboarding and switching the connectivity type to standard allows you to get a new local script, which you can run on the machine in a few minutes.
- Connectivity issues matter a lot. Although this issue can be very misleading and lead you to endless support articles about checking network connectivity, proxy settings, and tumbling down the rabbit hole, refrain from that and look at something very simple. Is your virus and threat protection enabled on your Windows monitored machine? If that's a no, then this warning can be indicative of that. If you do switch protection on, then you can consider network and proxy settings, firewall blocks, and other items outlined at <https://learn.microsoft.com/en-us/defender-endpoint/configure-network-connections-microsoft-defender-antivirus#validate-connections-between-your-network-and-the-cloud>.

Running MDE Client Analyzer Again to Verify Fixes Applied

MDE Client Analyzer Results

Script Version: 08/May/2024 | Script RunTime: 31/10/2024 10:04:39 PM +0000 |

Device Information

General Device Details

Device name	win03
Device Operating System	Windows 10 Pro
OS build number	Microsoft Windows NT 10.0.19045.0.5011
OS Edition	Client
OS Architecture	64-bit
SystemBootTime	10/31/2024 21:53:18
Streamlined Connectivity Readiness	READY
System-wide WinHTTP proxy	Direct access (no proxy server).

AV Component Details

Defender AV Service Status	Running
Windows Security Center Service Status	Running
Windows Security Health Service Status	Running
Defender AV SSLOptions configuration	False
Defender AV mode	Active
Defender Network Inspection Service	Running
Defender Network Inspection Driver	Running
Defender AV Platform Version	4.18.24090.11
Defender AV Security Intelligence Version	1.421.29.0
Defender AV engine Version	1.1.24090.11

Type	State	Date & time
Last full scan	No scan performed	
Last quick scan	No scan performed	
Security intelligence	Version 1.421.29.0	Oct 31, 2024 1:50:18 PM
Engine	Version 1.1.24090.11	Oct 31, 2024 1:50:18 PM
Platform	Version 4.18.24090.11	Oct 31, 2024 6:28:19 PM

Update history

> Feature Updates (1)

> Quality Updates (5)

✓ Definition Updates (3)

Security Intelligence Update for Microsoft Defender Antivirus - KB2267602 (Version 1.421.29.0) - Current Channel (Broad)
Successfully installed on 10/31/2024

Update for Microsoft Defender Antivirus antimalware platform - KB4052623 (Version 4.18.24090.11) - Current Channel (Broad)
Successfully installed on 10/31/2024

Security Intelligence Update for Microsoft Defender Antivirus - KB2267602 (Version 1.421.28.0) - Current Channel (Broad)
Successfully installed on 10/31/2024

Sensor reporting fine and endpoint now onboarded

Fixed!
No errors or warnings.

As you can see, installing the sensor using the standard script, and updating the necessary components, in addition to ensuring virus and threat protection is activated and reporting into the console, solved all the problems. Now, both the MDE client analyzer tool and the Defender for Endpoint console show the same data and are in sync, while the machine now shows as being fully onboarded. If that weren't the case, then Defender would be unable to relay telemetry about installed software, vulnerabilities, and other risks, so you would remain partially blind. Note that if a device stops reporting to the console for more than 7 days, the health state switches to "Inactive". Other possible health statuses are "Active" (when the sensor is reporting properly) and "Misconfigured" (when a device has a network communication issue, or the sensor is experiencing a problem).

When looking at device exposure levels (which relate to pending security recommendations), you have three options: Low, Medium, and High. However, a device can be classified as "No data available" if:

- It has stopped reporting for 30 days or more, which will not allow the exposure to be calculated, as the device is then considered inactive.
- The device is running an unsupported OS.

Troubleshooting Mode

win05
High Criticality: None Active

Overview Incidents and alerts Timeline Security policies Security recommendations Inventories

VM details

Category	Type
Computers and Mobile	Unknown
Subtype	Domain avengers.org
OS	SAM name
Windows 11 64-bit (Release 23H2 Build 22631.4317)	-
Asset group	Health state
-	Active

Active alerts (Last 180 days)
Risk level: High
33 active alerts, 1 active incident

Active alerts: High (2) Medium (4) Low (12) Info (15)

View all incidents and alerts

Logged on users (Last 30 days)
1 logged on user

Device value Set criticality

Manage tags

Report device inaccuracy

Run Antivirus Scan

Collect Investigation Package

Restrict App Execution

Initiate Automated Investigation

Initiate Live Response Session

Isolate Device

Ask Defender Experts

Action center

Download force release from isolation script

Exclude

Go hunt

Turn on troubleshooting mode

Works even if the device is managed by specific organizational policies

Is tamper protection enabled, and you need to disable it or turn some Defender features off?

Are certain device elements turned off by policy?

Logs are available after troubleshooting mode expires (set for 4 hours)

Once troubleshooting mode is on, you can't turn it off

This mode will give you enough access to work around restrictions and be able to address problems. When enabled, you see a message stating "Troubleshooting mode is on," and the session lasts for 4 hours. Once you turn it on, there's no way to cancel the session. You will have access to any generated logs even after the 4-hour window lapses. To collect them, choose the device in the Defender portal and select the "Collect Investigation Package" feature. The logs will be there until an administrator collects them.¹ The tool won't remove them until that takes place. If you need to disable tamper protection when in troubleshooting mode, use the following PowerShell command:

```
Set-MPPreference -DisableTamperProtection $true
```

If you need to make changes to the Defender settings, you need local administrator privileges on the device that you are troubleshooting. The following activities take place:

1. MpPreference snapshot is obtained (before troubleshooting starts and after completion). That ensures you have a record of the preference and scan configuration.
2. Advanced hunting can be used to query all troubleshooting events.
3. Operational logs from the session are collected.
4. If you want to view setting changes, start the Event Viewer application and browse to Applications and Services Logs > Microsoft > Windows > Windows Defender > Operational. You can even create a custom view or filter for events of interest, like event ID 5001, real-time protection is disabled, or 5004, real-time protection configuration changed.²

1. <https://sec555.com/plekc>
2. <https://sec555.com/k5cp3>

SANS CYBER DEFENSE SEC555 | Detection Engineering and SIEM Analytics 80

Adding an IOC

Available capacity: 0/15000 indicators

Four categories of IOCs are supported: File hashes, IP addresses, URLs/Domains, Certificates

Five supported actions:

- Allow
- Audit
- Warn
- Block execution
- Block and remediate

Export Import Add item

IP address	Application	Action
☐ 83.222.191.62		Block execution
☐ 146.190.247.230		Block execution
☐ 152.32.158.35		Block execution
☐ 195.178.110.6		Block execution

Alert is automatically created and resolved

User tries to navigate via Edge but gets a message that the page isn't reachable

Hmmm.. can't reach this page

83.222.191.62 refused to connect.

Try:

- Search the web for 83.222.191.62
- Checking the connection
- Checking the proxy and the firewall

Refresh

Automated investigation started manually

Informational No threats found Resolved Suspicious activity Automated investigation

A user is trying to reach 83.222.191.62 but is getting blocked, as the IP is an active Defender IoC.

There are four distinct categories of IOCs supported: **File hashes**, **IP addresses**, **URLs/Domains**, and **Certificates**. In each of these categories, there's an option called "Add item", so individual artifacts can be added, while there's also an option to use the "Import" option to add items in bulk. To accomplish that accurately, when going to the bulk import page, there's an option to download a .CSV sample. Choose that and fill the template in the exact format the tool expects so you don't encounter issues that will make you waste time afterward. When creating an indicator, you have five available actions:

- **Allow:** Allows the IoC to continue operation and action is performed.
- **Audit:** IoC activity generates an alert, while the associated action is allowed.
- **Warn:** A warning message is displayed to the user, but they have the option to disregard it and complete their action.
- **Block execution:** The IoC is blocked from executing and the action is not allowed (like in the above image).
- **Block and remediate:** The IoC is blocked from executing, and the action is not allowed, but a remediation action is also taken.

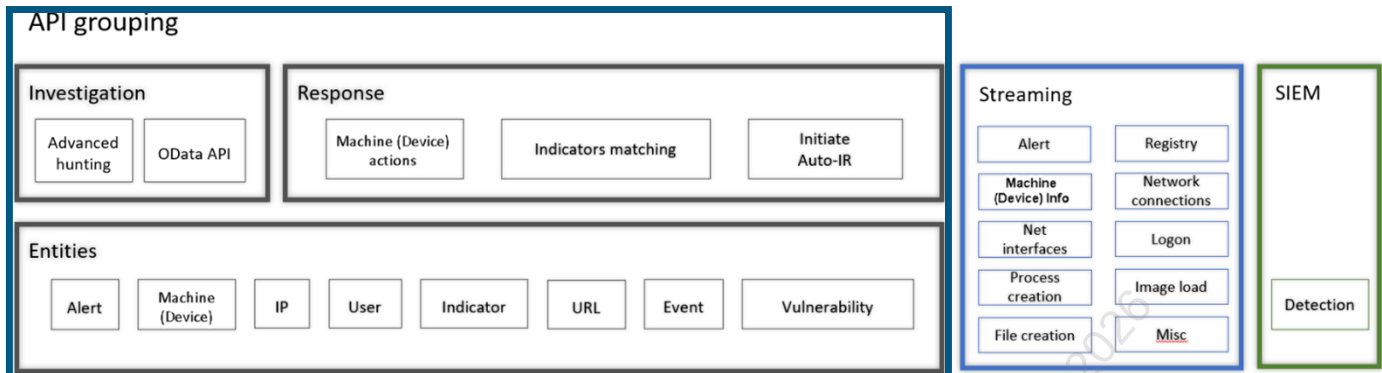
In the alert details page, you have the option to create an alert or not. If you choose to do so, there are four available severity levels (Informational, Low, Medium, and High), while there are multiple alert categories and associated MITRE techniques to choose from.

Note that if the IoC is placed there temporarily or as a test, you can set an expiration date to avoid triggering alerts after the desired timeframe.

Reference:

- <https://learn.microsoft.com/en-us/defender-endpoint/manage-indicators>

Defender API Architecture



- Three Microsoft Defender APIs exist:
 - Investigation (e.g., advanced hunting queries, info about users, file creation)
 - Response (e.g., manage device action settings)
 - Entities (e.g., manage IOCs and vulnerabilities)
- Raw data streaming (long-term storage to Azure storage)
- SIEM integration (send to third-party SIEM solution)

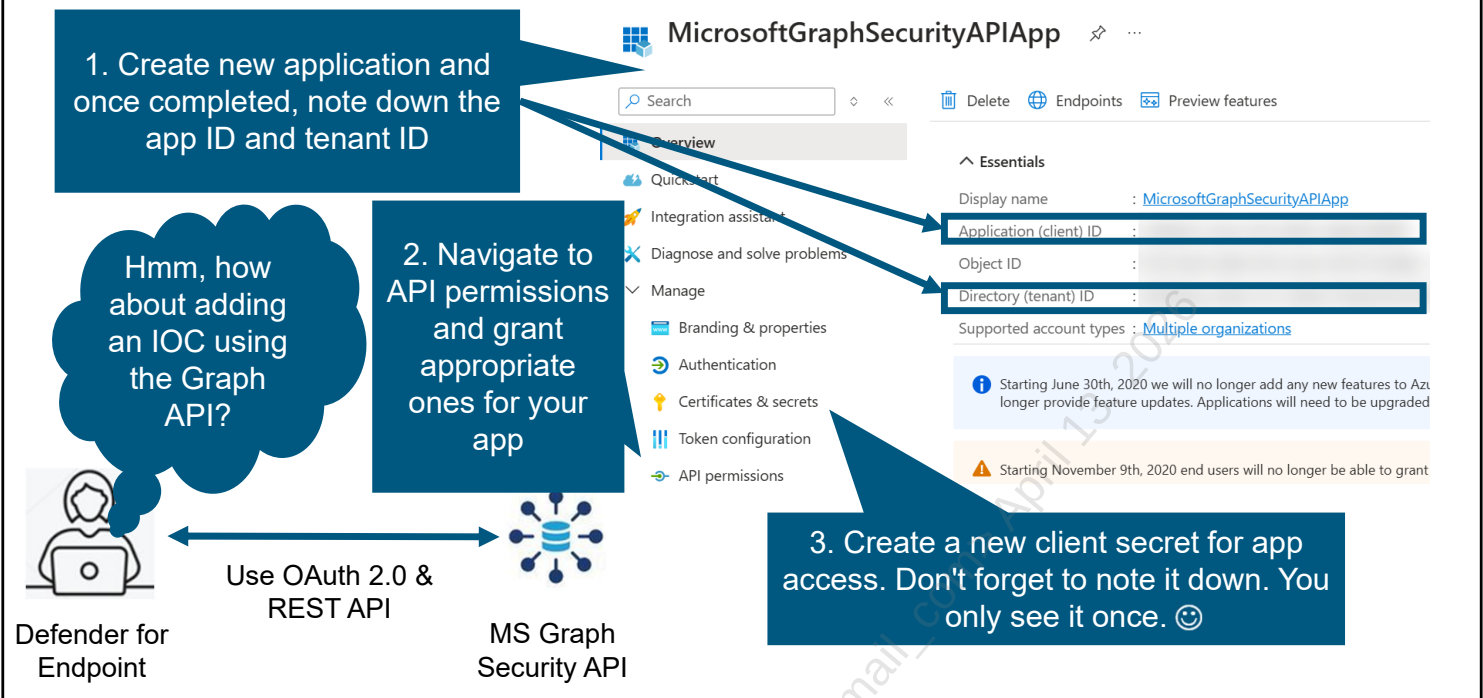
Defender for Endpoint makes three collections of APIs available:

- Microsoft Defender for APIs:** Uses Azure AD authentication to provide access. A variety of options are available, including calls for adding/viewing IOCs, running advanced threat hunting queries, pulling alert and vulnerability details, and more.
- Raw data streaming:** If you need to record alerts and event information for longer periods of time, you can use this method to push data to Azure storage. That provides an excellent mechanism for long-term storage, which can be used for:
 - Later investigations
 - Lookups
 - Regulatory obligations
- SIEM integration:** Useful if you want to take the alerts and push detections into a third-party SIEM tool of your choice by tapping in directly and using a REST API interface.

Image reference:

- <https://sec555.com/4aiof>

Using Microsoft Graph Security API for Defender



The Microsoft Graph Security API can be used to obtain information like alerts, events, actions, add custom indicators, and you can even interact with it using Power BI or an API integration (e.g., with an external SIEM tool). It uses the OAuth 2.0 protocol and makes a REST API call to MS Graph to obtain the information in JSON format. To that purpose, you can create an application in Azure that needs to:

- Get the app registered in Azure and create a password for it. Note that it needs to support OAuth 2.0.
- After creation, obtain the Azure application ID and tenant ID.
- You can run it as a signed-in user (delegated permission) or run it as a background service without a signed-in user (application permissions). The latter is the recommended approach.

Process breakdown:

1. Create an application: Go to your Azure portal > App registrations > New registration. Fill in the information and create the new app. Once completed, note the tenant and application ID.
2. Click on the App name and go to API permissions > Add a permission > Microsoft Graph > APIs my organization uses > Delegated or Application permissions (depending on which one you're using) > search for "WindowsDefenderATP" and select it > Enable Alert.Read.All. Once completed, select "Grant admin consent for <tenant-name>".
3. Go to Certificates & secrets > Client secrets > New client secret. Make sure you note the app secret value because you won't be able to retrieve it again.

As mentioned previously, the Graph Security API allows you not only to interact with Defender, but it's really a programmatic method for you to make any API calls and invoke information in a prompt and responsive manner, without being delayed by the GUI or sometimes being hindered by it.

Note that app permissions depend on what it needs to do (here, get a copy of the Defender alerts).

Get an Access Token

```
$tenantId = ''
$appId = ''
$appSecret = ''
$sourceAppIdUri = 'https://api.securitycenter.microsoft.com/.default'
$soAuthUri =
"https://login.microsoftonline.com/$TenantId/oauth2/v2.0/token"
$authBody = [Ordered] @{
    scope = "$sourceAppIdUri"
    client_id = "$appId"
    client_secret = "$appSecret"
    grant_type = 'client_credentials'
}
$authResponse = Invoke-RestMethod -Method Post -Uri $soAuthUri -Body
$authBody -ErrorAction Stop
$token = $authResponse.access_token
$token
```

Replace with previously obtained tenant ID

Replace with previously obtained app ID

Replace with previously obtained app secret value

Use this API URI for Defender but change accordingly for interacting with other resources

Once you have performed all previous steps, you need to ensure you obtain an access token to execute queries and interact with the Graph API. One way is to use the below PowerShell script. Remember to replace the tenant/app ID and app secret with the values you copied earlier.

```
$tenantId = '' # Paste your tenant ID here
$appId = '' # Paste your Application ID here
$appSecret = '' # Paste your Application key here
$sourceAppIdUri = 'https://api.securitycenter.microsoft.com/.default'
$soAuthUri =
"https://login.microsoftonline.com/$TenantId/oauth2/v2.0/token"
$authBody = [Ordered] @{
    scope = "$sourceAppIdUri"
    client_id = "$appId"
    client_secret = "$appSecret"
    grant_type = 'client_credentials'
}
$authResponse = Invoke-RestMethod -Method Post -Uri $soAuthUri -Body
$authBody -ErrorAction Stop
$token = $authResponse.access_token
$token
```

Decode Token Value for Validation

jwt.ms

Enter token below (it never leaves your browser):

yJ0eXAIoIJKV1QICJhbGciOiJSUzI1NiIsIngldCI6ImNQYUs0RWZ5SQk5RDtNDdGpZC2ZeWw1OUtVFMCIsImpcZCI6ImNQYUs0RWZ5SQk5RDtNDdGpZC2ZeWw1OUtVFMCj9.e

yJhdWQioIjodHRwcovL2FwaS5zZWw1cm0eNlbnRlc1staWlyb3NvZnQuY29tIiwiaXNzIjoiaHR0cHM6Lz9zdHMuZD2luZG93cy5uZXQvOwQDRhMmEtYjQwS00NM2MzLWI

wYjYtMDdkZGUzMzljNTRkLyIsImh0cGI6MTczMDY0bjEzNywmibmJmIjojNXNmZWJjQ2MTM3LCJleHAIOjE3MzA2NTAwMzcscmFpbYyI6ImSyQmdQzKjKemVSZEVE2ejQ2dEVWYSc3c

11HRXCdCdE9IwiYXBwX2Rpc3BsYXl1YWw1IjoiTWljcm9zb2Z0R3JhcHctZWw1cm0eUFQSUFWcCI6ImFwcGlkiOiYzhZhhZmRhMjItNWFlYS00M2NiThiZjQtY2E4YWIxNjB

Decoded Token

Claims

```
{
  "typ": "JWT",
  "alg": "RS256",
  "x5t": "3PaKa4EfyBNQu3CtjYsa3YmhQ5E0",
  "kid": "3PaKa4EfyBNQu3CtjYsa3YmhQ5E0"
}, {
```

```
"aud": "https://api.securitycenter.microsoft.com",
"iss": "https://sts.windows.net/[redacted]",
"iat": [redacted],
"nbf": [redacted],
"exp": [redacted],
"aio": [redacted],
"app_displayname": "MicrosoftGraphSecurityAPIApp",
"appid": "c8afda2-[redacted]",
"appidacr": "1",
"idp": "https://sts.windows.net/9d04c-[redacted]",
"idtyp": "app",
```

All the useful information from the token is broken down in simple language so you can verify its properties

The roles section shows you all the permissions the app currently has, so you can tackle access limitations

```
"oid":  
"rh":  
"roles": [  
  "Machine.Isolate",  
  "Event.Write",  
  "SecurityConfiguration.ReadWrite.All",  
  "IntegrationConfiguration.ReadWrite",  
  "Machine.Scan",  
  "Url.Read.All",  
  "Ip.Read.All",  
  "Ti.ReadWrite",  
  "Ti.Read.All",  
  "User.Read.All",  
  "Machine.ReadWrite.All",  
]
```

You can use jwt.ms to decode the token provided in the previous step and identify if there's anything posing an issue with your access or if you made any mistakes when configuring any of the previous properties using the script. If you need a full breakdown of claims made, you can browse to the Claims tab (next to the "Decode Token").

Reference:

- <https://sec555.com/7vt8x>

Using Microsoft Graph Explorer: Test Tenant

The screenshot shows the Microsoft Graph Explorer interface. On the left, there's a sidebar with 'Sample queries' and a list of GET requests like 'my profile', 'my photo', 'my mail', etc. The main area shows a 'Request body' tab with a GET request to 'https://graph.microsoft.com/beta/me/profile'. The 'Response preview' tab shows a successful JSON response. Annotations point to various parts of the interface:

- HTTP response code**: Points to the status bar showing 'OK - 200 - 334 ms'.
- Sample queries ready**: Points to the 'Sample queries' sidebar.
- Graph API HTTP request rendered**: Points to the 'Request body' tab.
- Check "Modify permissions" if you get an access code response error, like 403**: Points to the 'Modify permissions' tab.
- Check here if you need to validate your existing token value or use a new custom token**: Points to the 'Access token' tab.
- Interact using the CLI, PowerShell, Go, Java, and more**: Points to the 'Code snippets' tab.

1. GET: Standard info request.
2. POST: Send new data to the server (can't modify existing data).
3. PUT: Send new data to the server with the ability to update/delete existing data.
4. PATCH: Modify a resource partially.
5. DELETE: Delete a resource.

Using the Graph Explorer can be extremely useful if you want to query the Graph API in a very efficient and easy way. There are even already prepared templated queries you can use, depicted on the left sidebar. The HTTP request query is rendered dynamically each time you change your request or choose one from the already existing list.

- If you want to customize the request, you can do so in the "Request body".
- You can use multiple types of HTTP requests:
 - **GET:** Standard data request sent to the server so information can be provided back to the client.
 - **POST:** Send new data to the server (can't modify existing data).
 - **PUT:** Send new data to the server with the ability to update/delete existing data.
 - **PATCH:** Modify a resource partially. Like PUT but allows a resource to be updated without being replaced.
 - **DELETE:** Delete a resource.
- If you get any errors in your HTTP response regarding lack of permissions, switch to the "Modify permissions" tab and check what those issues may be. As soon as you grant the remaining permissions, you should be ready to resubmit the query successfully.
- If you want to interact using a coding language, go to the "Code snippets" tab and choose between C#, the CLI, PowerShell, and many more options.

Reference:

- <https://sec555.com/0i6js>

Using Microsoft Graph Explorer: Live Tenant

Tenant: Escal Institute of Advanced Technologies DBA SANS Institute

GET v1.0 https://graph.microsoft.com/v1.0/me Run query

Request body Request headers **Modify permissions** Access token

Permissions

One of the following permissions is required to run the query. If possible, consent to the least privileged permission.

Permission	Description	Admin consent required	Consent type
User.Read	Allows you to sign in to the app with your organizational account and let the app read your profile. It also allows the app to read basic company information.	No	Unconsent

OK - 200 - 134 ms

Response preview Response headers Code snippets Toolkit component Adaptive cards Expand

```
{
  "@odata.context": "https://graph.microsoft.com/v1.0/$metadata#users/$entity",
  "@microsoft.graph.tips": "This request only returns a subset of the resource's properties. Your app will need to use other permissions to get all the properties available for this resource see https://learn.microsoft.com/graph/api/resources/user",
  "businessPhones": [],
  "displayName": "Mitropoulos, Nick",
  "givenName": "Nick",
  "jobTitle": null,
  "mail": "nick.mitropoulos@sans.org",
  "mobilePhone": null,
  "officeLocation": null,
  "preferredLanguage": null,
  "surname": "Mitropoulos",
  "userPrincipalName": "nick.mitropoulos@sans.org",
  "id": "..."
}
```

Log in with your tenant details to query your corporate environment

Data is now drawn from your tenant and presented to you

If you want to be able to query your own environment for information, then you can log in using your Azure AD username and password, and the tool will allow you to interact with your live environment. This is extremely useful for SOC Analysts, Engineers, incident handlers/responders, and quite a lot of others.¹

Another tool for you to interact with the Graph Security API is the Postman API client. It allows you to query for information, render complicated requests, troubleshoot non-working components, and supports HTTP, REST, SOAP, GraphQL, and WebSockets.²

1. <https://sec555.com/dh6vw>
2. <https://sec555.com/zu54d>

Alert Tuning

'Uacme' hacktool was detected (Agentless) on a cloud resource

TenantId	9d044a2a-b40e-47c3-b0b6-07dde339c94b
Machine Name	sec555-range-cdrsn-mail01
Threat Information	HackTool:Win32/UacmeImclg
Threat Category	Tool
EffectiveAzureResourceId	/subscriptions/4996a69f-f666-4903-a983-338cd2be6206/resourceGroups/SEC555-RANGE-CDRSN/providers/Microsoft.Compute/virtualMachines/sec555-range-cdrsn-mail01
CompromisedEntity	sec555-range-cdrsn-mail01
ProductComponent Name	Servers
EffectiveSubscriptionId	4996a69f-f666-4903-a983-338cd2be6206

Looks bad. Is it?

Part of the Red Atomic scripts placed for testing on the various machines

Tune alert
Set alert properties where the rule applies
New rules apply only to new alerts.
[Learn more about alert tuning](#)

Tuning the alert seems prudent

Which criteria should you use? Would this work?

Alert details

Category: Suspicious activity
MITRE ATT&CK Techniques: -

Detection source: Microsoft Defender for Servers
Service source: -

Generated on: Nov 1, 2024 1:56:56 PM
First activity: Nov 1, 2024 1:56:40 PM

Last activity: Nov 1, 2024 1:56:40 PM

Evidence

Entity Name	Remediation Status	Verdict
atomic-red-team-mas...		

As already noted in the previous section about Defender for Cloud, a very important activity of any security environment is to be able to tune alerts to cater to your organization's needs. For example, in the above image, you can see Defender triggering an alert for a hack tool identified on a device. However, a more thorough inspection of that alert shows this tool is part of the Red Atomic scripts, deliberately placed in a folder to test the rule and tool efficacy. So, it shouldn't be something the SOC is worried about. As such, it has been tuned based on a detection meeting the desired file name or hash of interest. But what happens when an attacker uses this tool and names it using that name? Then you won't see that alert. Is that desirable? Probably not. Maybe you should just go with the file hash on this one, instead of using a logical OR between the two, meaning your rule would be tuned and the alert ignored for either of these matching. In a production network, this can even be accompanied by a specific testing machine to make the tuning effort even more specific. This is an example of the never-ending threat detection conundrum.

Balance out triggering too many false positive alerts vs. not detecting malicious activity.

There is a myriad of criteria you can apply to tuning, including machine name, IP address, file hash, username, URL, processes, and many more. Each tuning effort is specific, and the criteria can vary. But each time you tune an alert, remember that it may cost the defense visibility if you overdo it or tune the wrong way.

KQL for Engineers

Run query Last 24 hours Save Share link

Query

Query results are presented in your local time zone as per settings. Kusto filters, however, work in UTC.

```

1 DeviceTvmSoftwareInventory
2 | where SoftwareName contains "openssl"
3 | where SoftwareName contains "3.0" or SoftwareVersion contains "3.0"
4 | project DeviceName, SoftwareName, SoftwareVersion

```

Getting started Results Query history

Export Show empty columns 7 items Search

DeviceName	SoftwareName	SoftwareVersion
> dc02.avengers.org	openssl	3.3.0.0
> mail01.avengers.org	openssl	3.3.0.0
> win02.avengers.org	openssl	3.3.0.0
> win01.avengers.org	openssl	3.3.0.0
> win05.avengers.org	openssl	3.3.0.0
> win03.avengers.org	openssl	3.3.0.0
> win04	openssl	3.3.0.0

```

DeviceTvmSoftwareInventory
| where SoftwareName contains
"openssl"
| where SoftwareName contains
"3.0" or SoftwareVersion contains
"3.0"
| project DeviceName,
SoftwareName, SoftwareVersion

```

- KQL is not aimed just for security analysis but also for identifying engineering issues.
- The above query identifies vulnerable devices to the OpenSSL critical 2022 vulnerability.
- Well, 7 out of 14 devices is actually 50% of the total. Oops. 😞

You can navigate to the advanced hunting option (under Investigation & response > Hunting) and use a KQL query to visualize important items for you in the format that you desire. The queries can render information quite quickly and efficiently. For example, let's have a look at the above example:¹

```

DeviceTvmSoftwareInventory
| where SoftwareName contains "openssl"
| where SoftwareName contains "3.0" or SoftwareVersion contains "3.0"
| project DeviceName, SoftwareName, SoftwareVersion

```

This query checks all existing software to identify if OpenSSL is there, and if so, it checks for the existence of version 3.0. Once it finds it, the related results are rendered in a table using the project operator, which allows us to select specific columns to include in the result. As you can see, 7 devices are found to be susceptible to this vulnerability. Device names can be chosen to pivot to each individual machine's information page.

It's really beneficial to familiarize yourself with the different vulnerability management formats and table schemas, as that will give you the ability to craft more composite yet productive queries as you go along.² And if you have never seen KQL before, don't worry. There's a separate section coming later in the course to provide enough information to get your feet wet.

1. <https://sec555.com/jbuer>
2. <https://sec555.com/a17mq>

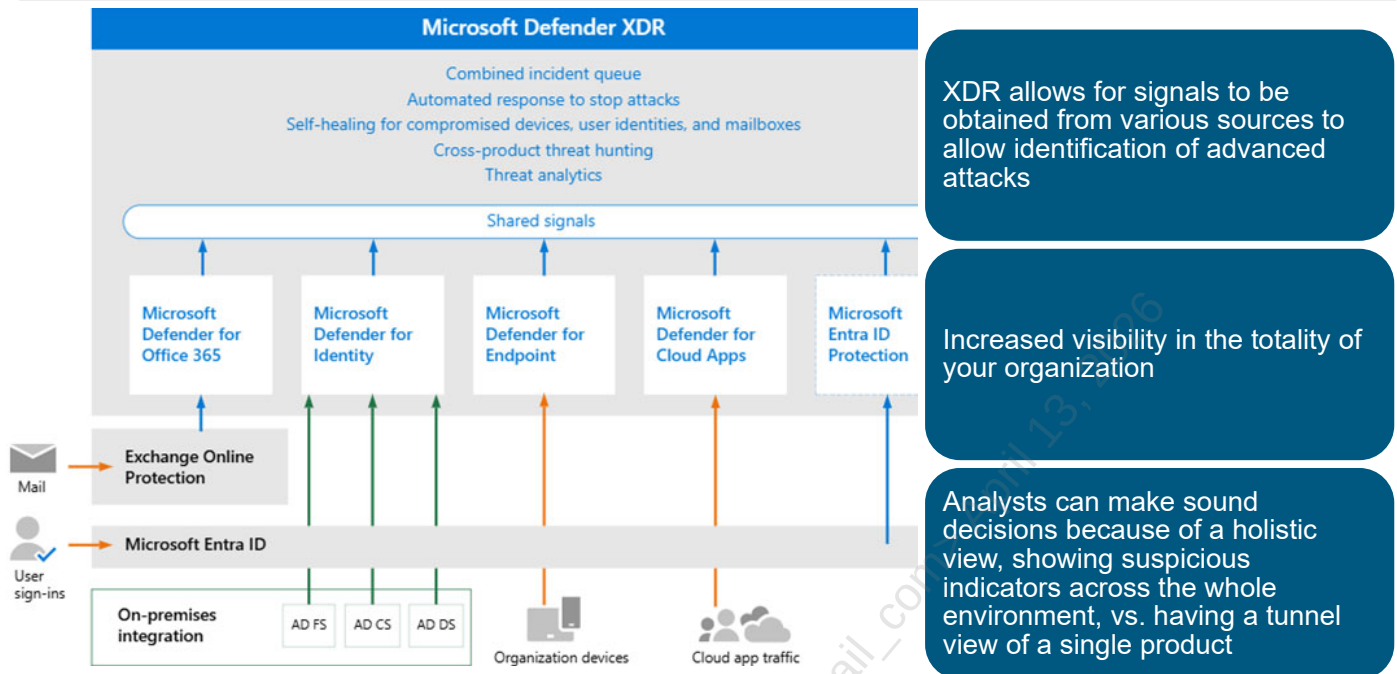
Defender XDR and Copilot for Security



The student will obtain a basic overview of Defender XDR and Copilot for Security.

This area is intentionally left blank.

Defender XDR Architecture



Microsoft's Defender XDR is an all-in-one combinatory solution. It combines all the above elements and obtains telemetry and signals from all of them, which is coupled with their intelligence, analytical output, and underlying AI & ML insight to create detections and assess the infrastructure for advanced attacks.

- **Defender for Office 365:** Protect against malicious emails while also safeguarding SharePoint, OneDrive, Teams, and the other Office 365 apps. Provides features like anti-malware, anti-spam, anti-phishing, connection filtering, quarantine policies, and message tracing.
- **Defender for Identity:** Obtain telemetry from on-prem and Azure-based domain controllers, which helps identify threats such as lateral movement, attacks against Kerberos, compromised accounts, and brute force attempts against domain accounts.
- **Defender for Endpoint:** As already mentioned, able to protect endpoints and offer isolation, attack surface reduction, next-generation protection, and more.
- **Defender for Cloud Apps:** Monitor the use of your cloud applications by assessing your traffic and discovering applications. Identify rogue or suspicious ones that you can block. Policy creation allows you to adjust to your needs by not allowing apps to run on unmanaged devices and locking them down by using specific policies, like not allowing employees to share files using specific domains, monitoring file download volume for possible indications of data exfiltration, monitoring application behavior for suspicious indicators, and many more.
- **Entra ID Protection:** Identify risky sign-ins and users, create policies to allow conditional access, and enhance domain protection by using MFA or allowing sign-ins from specific locations, test policy deployment using report-only, and create more composite tasks using workbooks.

Image reference:

- <https://sec555.com/w0kyf>

XDR Data Retention Periods

Tool	Retention Period (in days)
Defender for Endpoint	180
Defender for Office 365	Depends on licensing (plan 1 vs. plan 2)
Defender for Identity	180
Defender for Cloud Apps	180
Entra ID	Depends on licensing (free, Entra ID plan 1 or Entra ID plan 2)
Microsoft Sentinel	Basic logs: 90, other log types depend on Sentinel pricing

- Data retention needs to be a balance between cost, response to incidents, and compliance/regulatory obligations.
- Defender XDR uses data centers available in the European Union, the US, the UK, Australia, and Switzerland.

Data retention periods are vital for several reasons. You may want to respond to an incident and you need the necessary data to aid you, or you need to comply with client contractual obligations or possibly with regulatory standards. Regardless of the reasons, ensure you identify them in advance so that when you configure the XDR components, you are set for success. Defender for Endpoint/Identity/Cloud Apps all keep data for 6 months.

Defender for Office 365 is dependent on the license. If you have plan 1, then it keeps alert metadata for 90 days, activity alert details for 7 days, quarantine data for 30 days, reports for 30 days (detailed information) or 90 days (aggregated data), and submission information and real-time detections for 30 days. However, if you have plan 2, action center data is available for 180 days, advanced hunting for 30 days, automated investigation and response keeps 30 days of email metadata and 60 days of investigation metadata, while incidents, remediation, threat analytics, and explorer are all kept for 30 days.

The free Entra ID tier gives you 7 days of sign-in and audit logs, 7 days of risky sign-ins reporting, and 30 days of MFA use logs.

Entra ID plan 1 gives you 30 days of sign-in logs, audit logs, and MFA use logs, and 30 days of risky sign-ins reporting.

Entra ID plan 2 gives you everything in plan 1, but increases the risky sign-ins reporting period to 90 days.

Note that all three options give you unlimited retention of the risky users reporting.

References:

- <https://sec555.com/tplwq>
- <https://sec555.com/0p6mq>

Copilot Security Operation



- Standalone vs. embedded mode
- Summarize incidents
- Analyze impact
- Perform script reverse engineering and IoC exporting
- Guide response

Before starting to use Copilot, you need to choose if you intend to use it via a generic command prompt bar where you submit questions and get guidance and answers (standalone mode) or if you are going to choose using it integrated in your security product stack (embedded mode). It has some very interesting use cases, like:

- **Summarizing incidents:** Used embedded in a product like Defender for Endpoint, it provides a good summary of incidents in an easily understood language, which aids analysts to quickly assess the situation.
- **Analyze impact:** Provides the ability to assess incident impact and prioritize accordingly.
- **Reverse engineering:** It can analyze a script and provide insight into what it is able to perform, thus absolving the analyst from having to know malware analysis. It can also export IOCs from the script and help you identify if they are present in your infrastructure.
- **Guide response:** Copilot offers investigation steps and suggestions on how to investigate incidents and contain threats.

Copilot Operation

After Copilot gets a user's input, it pushes that to the orchestrator module for the determination of what resources (in the form of skills) need to be roped in to respond to the query. During the "Build Context" phase, Copilot gets the data context for an answer to be provided. Any plugins you have available can be evaluated during the next phase (Plugins). In the "Responding" phase, Copilot provides a response in human language, which will be easily understood by the user. Lastly, during the "Response" phase, the final response is provided to the requesting user.

Reference:

- <https://sec555.com/q78dv>

Image reference:

- <https://sec555.com/q78dv>

Provisioning Copilot for Security

Set up your security capacity

Copilot for Security is a generative AI-first platform with asset mapping, tiered storage, policy services, integration services, and more. It powers all workloads of the security platform.

Azure Subscription *
sans-range01-sec555

Resource group *
sec555-range-cdrsn

Create a new one

Capacity name *
CopilotForSecurityXDR

This name must be unique and contain only lower case letters, numbers with no spaces.

Prompt evaluation location *
United States

☒ If this location has too much traffic, allow Copilot to evaluate prompts anywhere in the world (recommended for optimal performance).

Capacity region *
US East

Choose your Azure subscription, resource group, and Copilot capacity name for the service created in Azure

Choose your location for data storage

Role assignment

Control who has access to Copilot for Security by adding or removing users, groups, Microsoft Entra ID roles, or managed identities.

Owner (3)

Get additional functionality like owner settings, access management, plugin management, usage monitoring, and more. To manage security compute units, an owner also needs to have the "Azure Contributor" role in Microsoft Entra ID.

- SA Security Administrator Role • Manage in Microsoft Entra ID
- GA Global Administrator Role • Manage in Microsoft Entra ID
- MA Administrator admin@contoso.com

Contributor (3)

Can use Copilot for Security here and in your other Microsoft Security products.

- SO Security Operator Role • Manage in Microsoft Entra ID
- SR Security Reader Role • Manage in Microsoft Entra ID
- E Everyone All users in your organization

Owners have increased administrative permissions

Contributors have Copilot basic access. All tenant members get this by default, but you can change it.

Steps to provision Copilot:

1. To start provisioning Copilot, you need to provision capacity first and foremost. To do so, browse to <https://securitycopilot.microsoft.com> and start setting up your security capacity, as in the above image. After choosing your applicable Azure subscription and Copilot resource group, define a capacity name, prompt evaluation location, and capacity region. In accordance with your compliance requirements, you can choose between Microsoft Azure data centers in the EU, the UK, the US, Australia & New Zealand, Japan, Canada, and South America. Then, you need to set up your Security Compute Units, also known as SCUs. Depending on the SCU figure you choose, the number gets adjusted accordingly to display your monthly estimated cost. The other option to do this is using the Azure portal and browsing to your full list of services and choosing Copilot there and configuring it.
2. You need to set up your default environment and grant appropriate user permissions based on defined roles.

Although you can use Entra ID configured roles, Microsoft recommends avoiding that as they don't just have Copilot access, but more than that. As such, there are two Copilot-specific roles configured, which are the Copilot owner and contributor. For example, if you were to give a user Global administrator or security administrator level access, then they get Copilot owner access. When awarding user permissions, remember that all users in your Microsoft Entra tenant will have contributor-level access to Copilot, which allows them to submit queries using the tool prompt, but Copilot will never provide information back that is out of the role level that the users currently have. For example, if you ask billing information as a contributor, it won't be able to provide the desired insight as that requires more access. However, if you wish to restrict users from having contributor access, you can create new groups of users and assign them to have contributor-level access vs. everyone in your tenant.

Reference:

- <https://sec555.com/mbx51>

Image reference:

© SANS Institute 2025

- <https://sec555.com/mbx51>

Licensed To: Arvind Pariti <paritiarvind@gmail_com> April 13, 2026

Microsoft Copilot

1. I have no idea how to do it, so "show me a list of all virtual machines"

2. How about showing me "Linux virtual machines only"

3. Copilot creates an Azure Resource Graph query for execution

4. Output only shows 5 out of a total of 14 machines. Just the ones running Linux

Query 1

```

1 resources
2 | where type =~ 'microsoft.compute/virtualmachines'
3 | extend osType = tostring(properties.storageProfile.osDisk.osType)
4 | where osType =~ 'Linux'
5 | project name, location, osType

```

show me a list of all virtual machines

show me a list of my Linux virtual machines only

Querying your [selected subscriptions](#) using Azure Resource Graph...

```

resources
| where type =~ 'microsoft.compute/virtualmachines'
| extend osType = tostring(properties.storageProfile.osDisk.osType)

```

name	location	osType
sec555-range-cdrsn-bastion	eastus	Linux
sec555-range-cdrsn-lin01	eastus	Linux
sec555-range-cdrsn-soc01	eastus	Linux
sec555-range-cdrsn-tgt01	eastus	Linux
sec555-range-cdrsn-web01	eastus	Linux

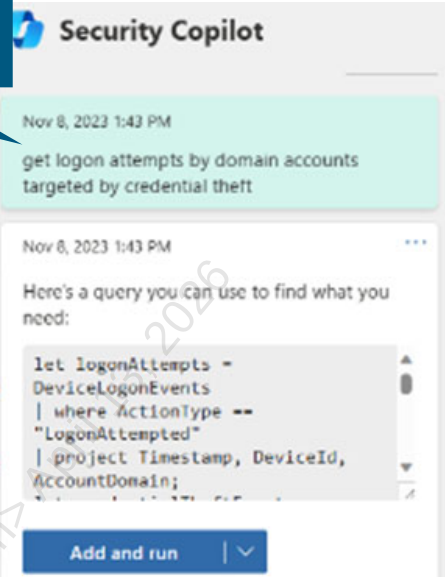
Today, you will have undoubtedly used some form of a Copilot technology; for example, when you last used a chatbot to get support while banking or to navigate through an issue with your utility provider. Copilots are AI assistants that we commonly see present as chat interfaces, and they can provide information on how to complete tasks or obtain insight into an activity, or provide information. The more driven and specific your queries are, the more value they can bring. And the beauty is that if your company uses Copilot, it can design and deploy its own by using the CoPilot studio or the Azure AI studio solutions. Microsoft has done a lot of work to integrate Copilot in various Microsoft applications. Here are some examples:

- **Azure:** In the above image, Copilot was asked to display a list of all virtual machines, and it rendered a link to do so. It was then asked to only display Linux virtual machines. As such, it proceeded by creating an Azure Resource Graph Explorer query, which provided the above list of 5 machines. Now that's pretty awesome, isn't it? You might not even know you could do that with the Resource Graph Explorer or that it even existed, but now you do.
- **Edge browser:** Try going to your favorite news site and ask Copilot to summarize the main points for you. Beats you spending 30 minutes reading through it, doesn't it? How about asking it to do some fancy searching and enrichment for you with terms of interest, and continue rendering and filtering your queries as it shows your results?
- **Office 365:** Use it to edit Word documents, ask it to perform Excel calculations, or check your schedule for you in Outlook.
- **Power BI:** Doing some business analyst work? Copilot to the rescue, so you can ask it to render or edit reports differently.
- **GitHub Copilot:** Source code developers can use it to render high-quality code for them in a very streamlined way. Another usage is to provide it with a source code snippet and ask it to tell you what function this code performs.

Copilot for Security

Advanced hunting

Get logon attempts for domain accounts targeted by credential theft



Query ready to run in advanced hunting

```
1 let logonAttempts = DeviceLogonEvents
2 | where ActionType == "LogonAttempted"
3 | project Timestamp, DeviceId, AccountDomain;
4 let credentialTheftEvents = DeviceEvents
5 | where ActionType in ("AsrLsassCredentialTheftAudited", "AsrLsassCred
6 | project Timestamp, DeviceId, InitiatingProcessAccountDomain;
7 logonAttempts
8 | join kind=inner credentialTheftEvents on $left.DeviceId == $right.De
9 | summarize count() by AccountDomain
10 | order by count_desc
11
```

Copilot for security has Microsoft and non-Microsoft plugins available.

Say that you wanted to create a Defender advanced hunting query, and you didn't know what syntax to use. Copilot can do it for you. In the above example, it was asked to create a hunting query to display logon attempts by domain accounts targeted by credential theft. This can help a security analyst obtain information by rendering quite complicated queries, which would take a good amount of time and research to do otherwise.

Microsoft plugins include Azure Firewall and WAF, Entra, Azure AI, Intune, Defender for XDR (including the above example of converting natural language to KQL), Defender Threat Intelligence, Purview (the MS governance and compliance module), and Sentinel.

Non-Microsoft plugins include integrations with ServiceNow, Splunk, Cyware, GreyNoise, Tanium, and CrowdSec threat intelligence.

References:

- <https://sec555.com/sva8u>
- <https://sec555.com/p60yb>
- <https://sec555.com/4fpd1>
- <https://sec555.com/aj126>
- <https://sec555.com/u1ks5>
- <https://sec555.com/r5blx>

Image reference:

- <https://sec555.com/5tj8q>

Copilot Defender XDR Plugin

Suspicious PowerShell command line on one ... Security Copilot Manage incident Ask Defender Experts Activity log

Attack story Alerts (1) Assets (2) Investigations (0) Evidence and Response (4) Summary

Suspicious PowerShell command line Clear selection

Incident graph Layout Group similar nodes

Communication Association

8:34:33 PM [8964] powershell.exe -NoExit -Ex... Remote execution

Command line **Analyze**

powershell.exe -NoExit -ExecutionPolicy Bypass -WindowStyle Hidden \$ErrorActionPreference=

Process id 8964

Execution details Token elevation: Default, Integrity level: High

Image file path C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe

Image file SHA1 6cbce4a295c163791b60fc23d285e6d84f28ee4c

Image file creation Sep 15, 2018 3:14:14 AM

Script analysis

Script analysis Nov 28, 2023 7:59 PM

1. The script starts a PowerShell session with the `-NoExit`, `-ExecutionPolicy Bypass`, and `-WindowStyle Hidden` flags. This means the PowerShell window will not close after running the script, the script's execution policy is set to bypass, and the PowerShell window will be hidden.
2. The script sets the `$ErrorActionPreference` variable to `'silentlycontinue'`, which means that any errors that occur during the execution of the script will be silently ignored.
3. The script creates a new `System.Net.WebClient` object and uses it to download a file from the URL `h"ttp://54.161.241.46/1.exe`. The downloaded file is saved as `C:\test-WDAP-test\invoice.exe`.
4. The script starts the process `C:\test-WDAP-test\invoice.exe`, effectively executing the downloaded file.

- Analyze PowerShell command.
- Breaks script function down for the analyst in human language.
- Like a mini-sandbox report.
- Guided responses supported.

Using the embedded Copilot Defender XDR capability allows you to get enhanced analytical input for investigating security incidents. In the above example, Copilot is being used to perform an analysis of a malicious PowerShell command that is part of a security alert on the Defender console. It breaks the operation of the script down into basic segments and ensures the analyst can read what the functions are in easy-to-understand language, while it also allows you to show the related code of each of those performed functions. There's also the option of analyzing files, so if a suspicious file was participating in the attack chain, Copilot can analyze that and break down the function for you. Think of it as submitting it to a smart sandbox with increased capability. As mentioned previously, this plugin can also be used to guide the analyst response, provide an incident summary, and allow an analyst to tell Copilot what output a KQL query should be able to provide, and the tool crafts the query for them. When an incident contains linked alerts, complicated IOCs, and has a very complex scenario unravelling, Copilot can take all of that into account and provide an instilled summary of what is going on so the analyst can proceed with the investigation and make quick remediation decisions. When providing guided responses, the tool can tell the analyst how to perform basic incident handling tasks (e.g., triaging or containment and eradication of attackers). Another interesting function is the ability to craft a report that can then be copied to another tool for further processing or be posted to the incident's activity log for other analysts and managers to review.

There are great plugins for Entra, Intune, and Defender for Cloud, providing some really augmented features to any analysis you may be performing.

Reference:

- <https://sec555.com/b8v2s>

Image reference:

- <https://sec555.com/b8v2s>

Summary

Plan your Defender for Cloud rollout by choosing the appropriate plan that fits your needs. Auto-provisioning is faster and easier, but sometimes manual provisioning may be required. Craft your alert use cases and ensure you perform tuning and automate actions by deploying Logic Apps accordingly.

If you're deploying Defender for Endpoints, go over the post-onboarding checklist and consider using demo scenarios to test your deployment for appropriate operation. Using the Microsoft Graph API can give you great power and flexibility. Lastly, in an era of AI, consider integrating with Copilot to maximize your SOC's efficacy.

This area is intentionally left blank.

Defender for Cloud

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Course Roadmap

Section 1: Detection Engineering and SIEM Architecture

Section 2: Network and Endpoint Analysis

Section 3: Asset Discovery, Baselines, and UEBA

Section 4: Cloud Logging and Monitoring

Section 5: Alerting and Detection Engineering Pipelines



- Azure Cloud Logging
 - ☐ Lab 4.1: Logging Unauthorized Access to Sensitive Data
- Microsoft Defender Suite and Copilot for Security
 - ☐ Lab 4.2: Defender for Cloud
- Microsoft Sentinel and KQL
 - ☐ Lab 4.3: Sentinel and KQL
- AWS Cloud Logging
 - ☐ Lab 4.4: Creating an AWS Lab, Configuring and Testing CloudWatch

This area is intentionally left blank.

Microsoft Sentinel



The student will get an overview of Sentinel's architecture, tables, ingestion flow, and normalization functionality.

This area is intentionally left blank.

Sentinel Functions



Sentinel is a SIEM and SOAR tool (but that's kind of like calling a nuclear submarine a tugboat).

Allows you to perform:

- Log collection
- Correlation
- Alerting
- Incident creation
- Data querying and visualization
- Threat hunting
- Response automation

Sentinel is a SIEM and SOAR tool that fully resides in the Microsoft cloud. But if you thought it was only about monitoring cloud data or just Azure, for that matter, think again. It allows you to ingest data from various other cloud providers and supports a variety of cloud and on-premises devices. That way, you can mix and match until you are content that you have ample visibility. The tool operates by using data connectors for data ingestion. There are connectors for pretty much everything you can think of, and currently the number is just short of 400¹ (e.g., connectors for AWS, Cisco Umbrella, Defender for Cloud/XDR/Endpoint, Darktrace, Juniper, LastPass, McAfee, Mimecast, and many more).² The tool allows you to get those logs in Sentinel by storing them in an appropriately configured Log Analytics workspace, and then be able to trigger alerts on content of interest. Sentinel comes with a lot of alerts out of the box, and if you connect it with Defender XDR, you get some great insight into your environment. You can also ingest incidents from the Defender suite in Sentinel and make this your default location for investigating security threats. There's also the option of initiating hunts, where senior analysts or threat hunters can make assumptions about threats and certain actors being present in their environment, so they hunt them down. Activities can be automated in the form of Azure Logic Apps, which means that they can facilitate rapid response tasks. Ensuring you are compliant with regulatory requirements is easy to do if you set proper retention periods for data to be stored in your environment. That means configuring your Log Analytics workspace properly or sending the data to Azure storage for a more permanent storage avenue.³

1. <https://sec555.com/2yj3h>
2. <https://sec555.com/u902p>
3. <https://sec555.com/ezibp>

Sentinel Workspace Architecture

Single-Tenant Single Workspace

- **Pro:** All information resides in a single workspace, offering increased visibility and easy querying.
- **Con:** Might increase bandwidth cost in the region, as it receives logs from other regional resources, and can prove a challenge for compliance reasons.

Single-Tenant Regional Workspaces

- **Pro:** Eliminates the bandwidth cost and compliance issues while also allowing for customized access and separate cost calculations and billing.
- **Con:** Information is in separate locations, making querying more challenging. Objects like workbooks now need to be multi-deployed.

Multi-Tenant Workspaces

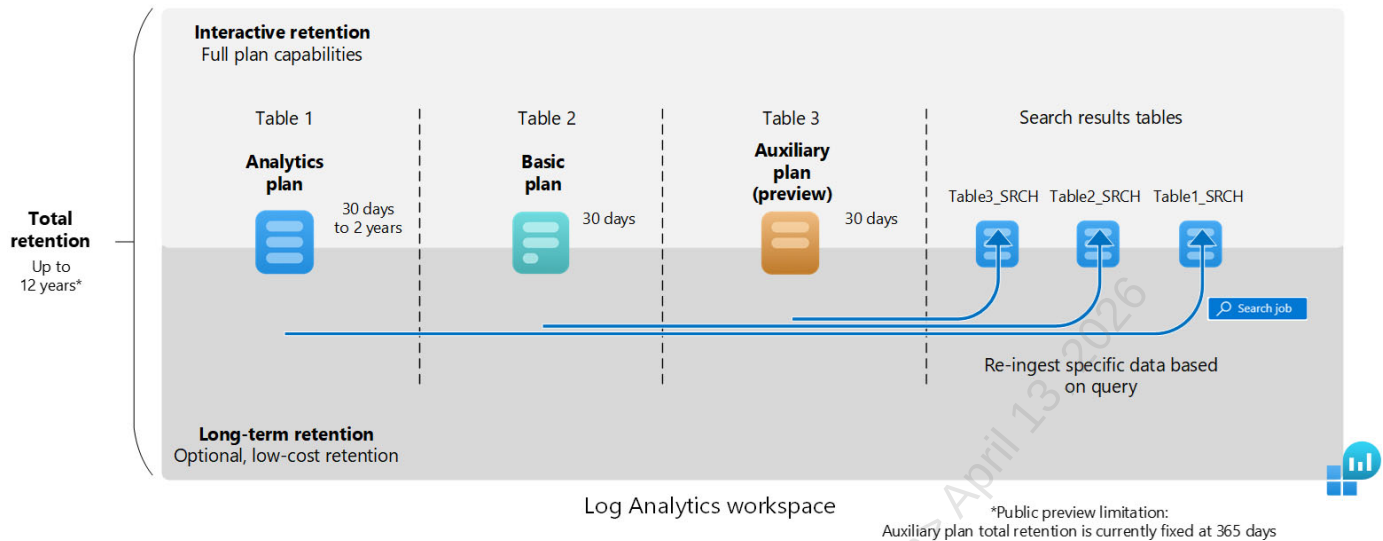
- **Pro:** Allows you the flexibility to manage any workspaces not present in your tenant but existing in others.
- **Pro:** Great if you're an MSSP.
- **Con:** Separate tenants increase the administrative overhead and associated maintenance costs but if you need to separate data this is a one-way street.

Before you create a workspace and connect it to Sentinel,¹ you need to decide on the architecture:²

- **Single-tenant single workspace:** The most significant advantage of this option is that you have a single workspace, which you use to monitor everything in your environment, and that can greatly aid in incident handling. All logging and tenant information resides there, so you have full visibility. Regarding permissions, you can use Sentinel's role-based access control model for granular access and combine it with Azure permissions on the Log Analytics workspace. The challenge is that when you send data to this single workspace, it may heavily increase the consumed bandwidth, since data from each location converges there. In addition, note that the location hosting the workspace may be present in a geographic area that conflicts with your required regulatory or compliance requirements.
- **Single-tenant regional workspaces:** This model helps you solve the geographical localization and associated compliance conflicts that may exist, in addition to any bandwidth cost challenges. You also have full control of the configuration of each separate log analytics workspace instance, including Azure permissions to granulate access. However, you are now missing out on having a central point of consolidating all the logs, giving you full visibility in your estate. Also, note that any workbook automation and configuration you do will need to be reconfigured for each of these instances.
- **Multi-tenant workspaces:** This model can be particularly useful for an MSSP or any other company that offers services to different clients. In those cases, separating workspaces in different tenants, offering full data separation, is the only way to go. If you do choose this option, Azure Lighthouse can help you manage those different Sentinel workspaces.³

1. <https://sec555.com/ylonz>
2. <https://sec555.com/a8ctf>
3. <https://sec555.com/49hqy>

Log Analytics Workspace Data Storage Options



Always remember to configure your workspace and table settings to reflect what your environment requires.

Log Analytics workspace data can be stored in two major states:¹

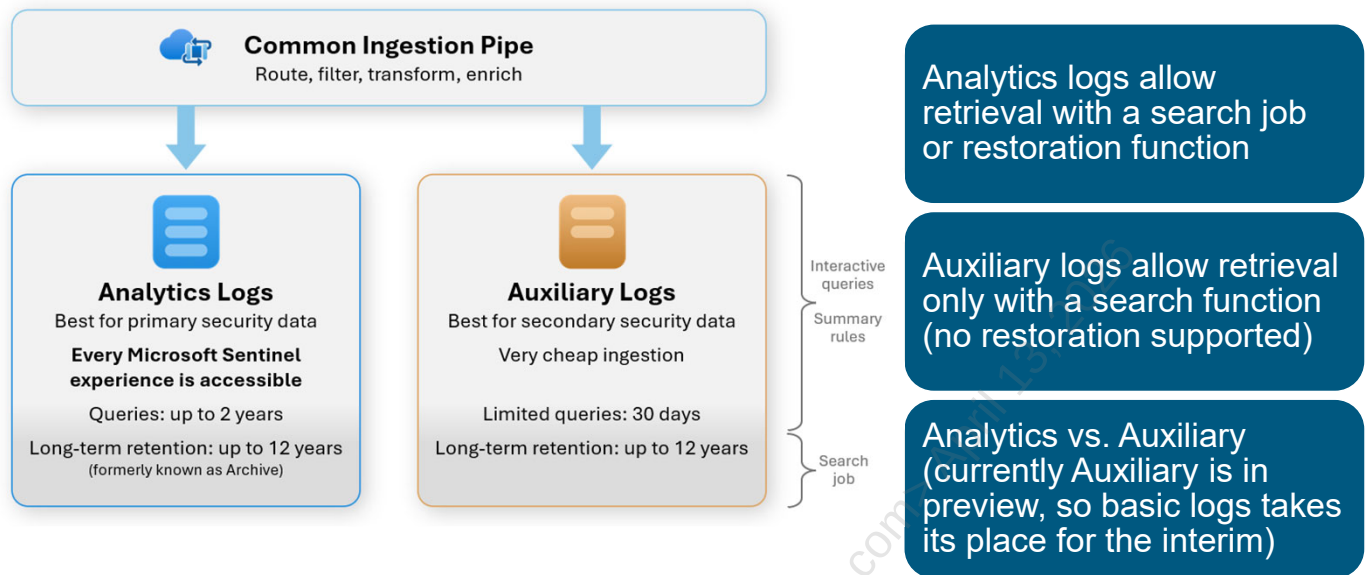
- **Interactive retention:** Data access depends on what plan you are on (from the ones mentioned on the next page).
Analytics plan: Allows you an interactive retention of 30 days to 2 years.
Basic and auxiliary plans: Interactive retention period is fixed at 30 days.
Note that in both cases, there are certain tables that have data available for 90 days by default.²
Data is available for:
 - Forming queries.
 - Monitoring.
 - Performing real-time analysis.
 - Troubleshooting any issues you experience.
- **Long-term retention:** Data can be maintained in its original tables for up to 12 years. The great benefit of this option is that if you need long-term storage, it gives you a great, cost-efficient option. To access the data, you need to run a search job so it can be retrieved.

1. <https://sec555.com/2lfpv>
2. <https://sec555.com/uxynk>

Image reference:

- <https://sec555.com/ml3qh>

Sentinel Log Storage Plans



Microsoft defines two main data categories for Sentinel ingestion: Primary and secondary security data.¹

Primary represents data that is of the utmost security importance, which is a priority for any security investigation. This needs to be available in near real-time and is used for monitoring, regular alerting, and analytic rules to trigger. Example data includes correlation alerts, UEBA hits, and scheduled alerts.

Secondary represents data that is volumetrically high and not of critical security value. That means it can be available on demand when there's a requirement to access it. Example data includes ad-hoc investigations and large-scale searches.

Microsoft Sentinel has the following two log storage plans available:²

- Analytics Logs Storage Plan:** Store primary security data in an easy-to-use and accessible manner. Interactive searching is allowed for data, for a period ranging from 30 days to 2 years. There's no associated cost per query you run, so you can use it as much as you require. When 30 days pass (note that some tables store data for 90 days by default, as mentioned in the previous page), your Log Analytics workspace data can be transferred to long-term retention, for a time dependent on your configuration. Maximum options are: 2 years interactive retention and total retention of 12 (meaning 2 years interactive + 10 long-term retention). In order for you to retrieve data from the long retention state and make it accessible in interactive mode, there are two ways:
 - Search job: Go to Microsoft Sentinel > <workspace-name> > Search > <enter search query>. Search jobs are nothing more than queries that are able to retrieve records for you. Their results are stored for 14 days. Search jobs can have a date range of 7 years, can continue running up to 24 hours, can return results of up to 1,000,000 records, are limited to 100 search results tables per workspace, and 100 search jobs can run per day per workspace, or
 - Restore archived data: Go to Microsoft Sentinel > <workspace-name> > Search > <go to Restoration tab> > select a table to restore and a start and end time > Choose Restore.

- Note that restoration has a minimum of 2 days of log data to be restored, with a maximum of 60 TB per single restoration, a maximum of 4 restores per table per week, a maximum of 2 restore processes in a workspace concurrently running, and 1 active restoration at a time per table.
- **Auxiliary Logs:** Note that this feature is currently in preview. It's designed to store secondary security data for long timescales in a very cost-efficient manner. The auxiliary plan keeps data in interactive retention for 30 days (90 for some tables), and then data gets pushed to long-term retention. Examples of candidate log sources for this category would be:³
 - Storage access
 - Netflow
 - VPC flow
 - Certificate
 - Proxy logs

Although this is a cheaper approach, it is also a more limited one, as your queries are charged per GB, while there's a performance hit of a much slower search. **Note that the restore function is not supported here. You can only run a search job to access data.**

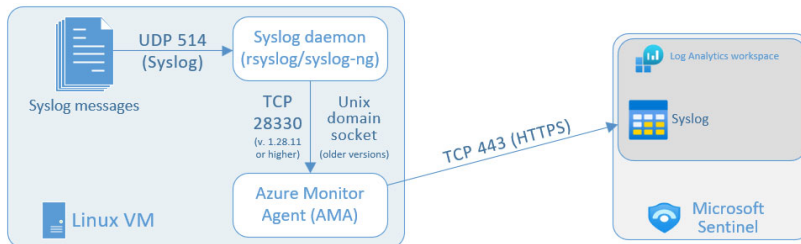
There's a third plan in operation, which is called **basic logs**. That's similar to auxiliary logs, but interaction with the data is higher than the auxiliary plan, but not as much as it costs in the analytics plan. This is an interim substitute for the auxiliary logs until the preview period passes.

1. <https://sec555.com/438h5>
2. <https://sec555.com/29q8u>
3. <https://sec555.com/l3k5w>

Image reference:

- <https://sec555.com/g1rm3>

Collecting Syslog from One Machine Using Sentinel AMA



Single Machine Syslog Architecture

TimeGenerated [UTC]	Computer	EventTime [UTC]
11/9/2024, 11:17:01.086 AM	spiderman	11/9/2024, 11:17:01.000 AM
SourceSystem	Linux	
TimeGenerated [UTC]	2024-11-09T11:17:01.08671Z	
Computer	spiderman	
EventTime [UTC]	2024-11-09T11:17:01Z	
Facility	authpriv	
HostName	spiderman	
Severity/Level	info	
SyslogMessage	pam_unix(cronsession): session closed for user root	
ProcessID	1685703	
HostIP	10.130.9.242	
ProcessName	CRON	
Type	Syslog	
_ResourceId	/subscriptions/...	/resourcegroups/sec555...

Linux logs

Install the AMA agent on the Linux machine(s) you need to monitor

Machine creates Syslog messages, which are first collected by a daemon service, commonly over TCP or UDP 514

Those are then sent to AMA

AMA sends those to your Sentinel workspace where they are under the Syslog table

On Sentinel, install the "Syslog via AMA" data connector

Syslog messages can be sent over UDP, TCP, or TLS. The process is very simple. First, on each machine you need to log data from, perform the following steps:

1. Install the AMA agent.
2. The machine's syslog-generated data will first hit the syslog local daemon, running on the monitored machine. Usual operating ports are UDP or TCP 514, although this is configurable, and you can change it. If you change the port in the syslog configuration, ensure you reconfigure the source application(s) you are logging from, so those logs are sent at that port.
3. The AMA agent gets the logs and forwards them to your Sentinel Log Analytics workspace. Logs being received by the AMA agent will use TCP port 28330 (if the agent version is 1.28.11 or newer). In prior versions, a Linux socket was used to send logs to the AMA.
4. Go to Sentinel > Configuration > Data Connectors > More content on Content hub > Syslog via AMA.
5. Install the connector, go to the connector page, and create a data collection rule where you choose the appropriate resources and Syslog logging levels. After the rule is created, you will see the syslog content present in the workspace, under the Syslog table.

Note that if you prefer, you can also install and configure the Sentinel data connector first and then perform the rest of the above steps.

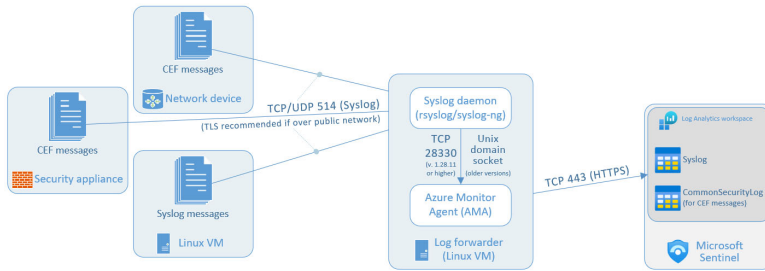
Reference:

- <https://sec555.com/zxyur>

Image reference:

- <https://sec555.com/ldxgv>

Collecting Syslog/CEF Using Log Forwarder and Sentinel AMA



Log Forwarder (Syslog or CEF) Architecture

11/9/2024, 11:56:56.983 AM	Directory Synchronization	EventRecordId	332223
TenantId		EventData	{\"01\": \"Current scheduler settings: {\\\"Allowed...
SourceSystem	OpsManager	EventId	904
TimeGenerated (UTC)	2024-11-09T11:56:56.9836742Z	EventOriginId	b5f37334-b5ca-4fd4-8656-558678a7ea61
Provider	Directory Synchronization	ManagementGroupName	
Channel	Application	Type	WindowsEvent
Computer	dc01.avengers.org		
Task	0		
EventLevel	4		
EventLevelName	Informational		
SystemUserId	N/A		
Version	0		
Opcode	0		
SystemProcessId	0		
SystemThreadId	0		

Windows
Logs

A Linux configured log forwarder needs the AMA agent installed (machine can reside on-prem or in the cloud)

All Syslog and CEF logs are forwarded to the log forwarder and subsequently sent to AMA

The AMA sends those to your Sentinel workspace, where CEF is under the WindowsEvent table and Syslog under the Syslog table (ensure the data connectors are present and configured)

Be careful to configure appropriate encryption for log transfers

If you intend to use a log forwarder to ship logs to Sentinel, then follow these steps:

1. Build a Linux forwarder and install the AMA agent on it. There's no limitation as to the location of that machine. You can make it on-premises, in the Azure cloud, or any other cloud for that matter. It totally depends on your network architecture and requirements.
2. Syslog and CEF logs from the various machines are then sent to the log forwarder, and it proceeds by sending them to the AMA agent. As mentioned already, logs being received by the AMA agent will use TCP port 28330 (if the agent version is 1.28.11 or newer). In prior versions, a Linux socket was used to send logs to the AMA. Finally, that agent sends those to the Sentinel workspace of your choice.
3. Go to Sentinel > Configuration > Data Connectors > More content on Content hub > Windows Forwarded Events.
4. Install the connector, go to the connector page, and create a data collection rule where you choose the appropriate resources and then customize the appropriate log types. Note that if you choose to log everything, you are going to get a ton of data and inundate yourself with too much, not to mention that it will skyrocket the cost.

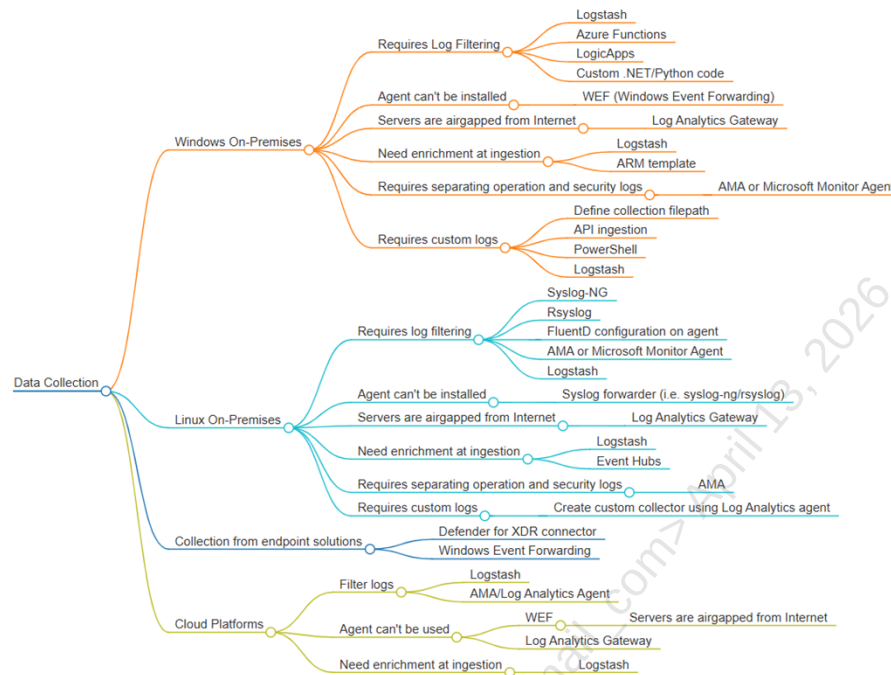
Reference:

- <https://sec555.com/2w8ox>

Image reference:

- <https://sec555.com/tab3w>

Performing Filtering Prior to Data Collection



You may be interested in filtering your logs before ingestion takes place, so that you make the most out of this and don't port over useless data. This helps reduce network bandwidth utilization and overhead, as well as minimize the volume of data to make the most out of the effort. Remember that you are transferring data to Sentinel, which is a cloud-based solution, and storing data there isn't cheap (same as with any other cloud-native tool). As such, it would be prudent only to send the things that matter to you, to reduce cost. Suggested methods are to use the Azure Monitor Agent (which is supported on Windows and Linux systems) or Logstash (which even has a Sentinel data connector). Things can get very interesting when you're experiencing certain limitations. The above mind map has been created considering Microsoft's documentation and industry best practices. It shows various scenarios of how to move forward, given the following limitations:

- Log filtering is required.
- You are unable to install an agent on the machine.
- The device doesn't have any internet connectivity
- Enrichment is required at ingestion.
- Separation of operation and security logs is mandated.
- Customization of logs is required.

Reference:

- <https://sec555.com/16ehy>

Sentinel Tables of Interest (1)

Table	Description	Example Fields
SecurityIncident	Incident details	Time, name, title, severity, status
ThreatIntelligenceIndicator	Threat intelligence	Time, expiration date, confidence, threat type, TLP
SecurityAlert	Security alerts	Time, name, severity, description, remediation steps
AzureActivity	Azure activity log	Time, level, resource group, subscription id, user, IP
AuditLogs	Entra ID audit log	Time, resource, operation name, tenant id, user
SecurityEvent	Azure security center events	Time, account, account type, machine name, event ID, activity, IP address, port, logon GUID and type
SigninLogs	Azure AD sign-in logs	Time, resource ID, resource, correlation ID, location, application, conditional access policy, MFA status
DeviceEvents	Multi-event type field	Time, device ID and name, filename, file path, initiating account SID, process file name and ID
DeviceFileEvents	File related activity log	Time, action, device ID and name, filename, user
DeviceInfo	Device information	ID, name, logged on users, OS build, platform
DeviceLogonEvents	Device sign-ins and authentication events	Time, account name, SID, logon type, device name, IP address and port of access

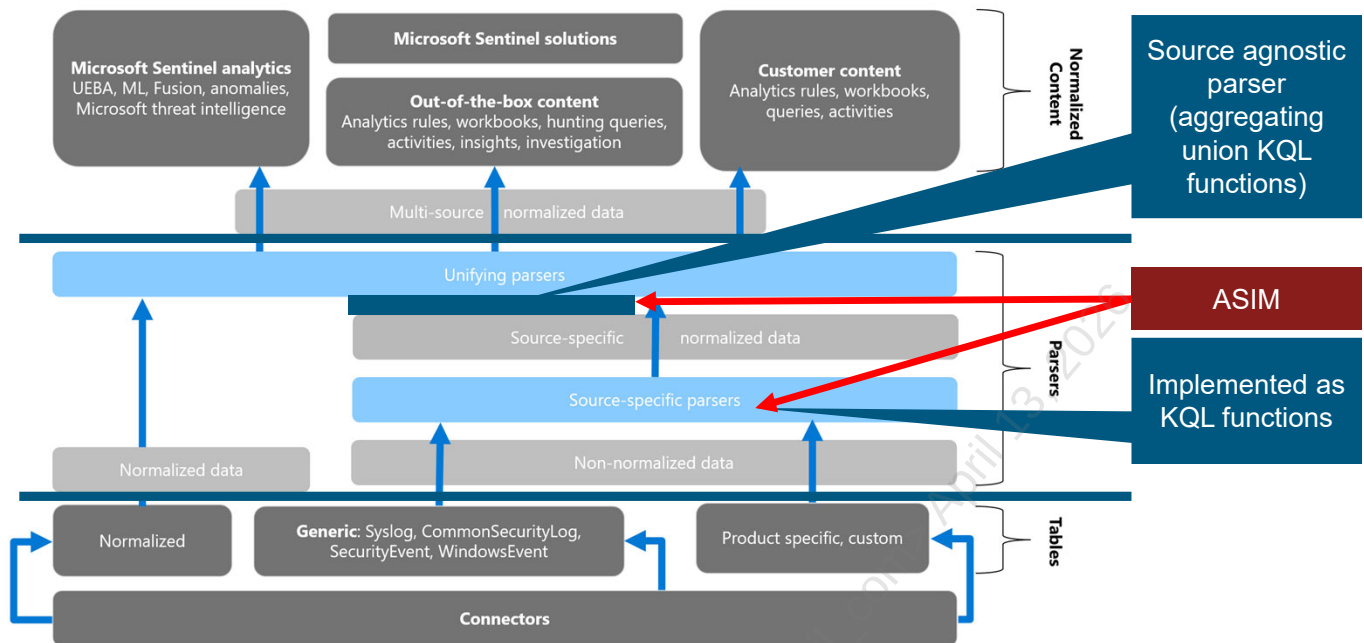
Sentinel contains a lot of tables that can be useful when performing investigations, troubleshooting, or creating detection engineering queries. These next two pages depict some tables of interest for your awareness and reference.

Sentinel Tables of Interest (2)

Table	Description	Example Fields
AlertEvidence	Alert artifact information	Timestamp, alert ID, detection source, filehash
DeviceFileEvents	File system level events	Timestamp, action, device, file, path, processid
DeviceImageLoadEvents	Events relating to DLL loading	Timestamp, device, folder path, account name, SID, command line, process ID, parent file name
DeviceProcessEvents	Process creation events	Timestamp, account name, action, device, filename, folder path, SID, process, hash, logon ID
DeviceRegistryEvents	Registry activity	Timestamp, device, account, SID, command, process, process ID, parent ID, previous key value
EmailEvents	Office365 email activity	Timestamp, attachment count, delivery action, message ID, recipient, sender, domain, IP, subject
EmailUrlInfo	Email URL data	Timestamp, network ID, URL, type tenant ID
EmailAttachmentInfo	Attachment data	Timestamp, file name and type, sender, recipient, hash, file size
Anomalies	Anomaly analytics in Sentinel	Timestamp, ID, rule name, description, start and end times, tactics, techniques, user, reason

This area is intentionally left blank.

Normalization in Sentinel: Advanced Security Information Model



Sentinel can take on data from a variety of different log sources, including on-premises and cloud resources. It uses ASIM (Advanced Security Information Model) to allow you to normalize and take advantage of data. When you do, you will be able to apply analytics rules at scale, across various log sources. Even if you add a different log source later down the line (like Infoblox logs), provided it supports ASIM, any compatible content can utilize it.¹ Under the hood, it uses the OSSEM (Open Source Security Events Metadata) model.² You would have also used that if you have ever used HELK for threat hunting. If you have data from different sources and the fields are named differently, your rules and content won't work. Using ASIM solves that problem. Sentinel uses data connectors that use parsers but have a higher performance impact. Query time normalization has less performance impact. But what is a query parser, you say? Query parsers are stored KQL functions that have been deployed using underlying ARM templates. That's why in the above image, you see a note about aggregating KQL functions. Any source agnostic parser uses union statements to aggregate data from the different sources you're using. Some parsers are already available in your Sentinel default deployment, while there are many more you can use.³ Note that query parsers don't modify the data; they merely represent it in a different view, keeping the source format intact. Sentinel actually uses a combination of query time parsers and ingestion time parsing. The latter does alter the data to normalize it, but that ends up speeding up the query. Not only that, but that simplifies their creation, and it also means that since the original data isn't altered, a new parser can be applied to your already existing data.

1. <https://sec555.com/pi14j>
2. <https://sec555.com/pydhq>

Image reference:

- <https://sec555.com/qbd2x>

Kickstarting ASIM

Subscription and resource group information

Subscription * ⓘ sans-range01-sec555

Resource group * ⓘ sec555-range-cdrsn

Instance region, workspace name, and region

Region * ⓘ (US) East US

Workspace * ⓘ 9784ba92-4453-0ae4

Workspace Region ⓘ East US

Functions

Search: vimRegistry

vimRegistryEventMicrosoftSysmonWindowsEvent

Parameters

```
starttime:datetime = datetime(null)
endtime:datetime = datetime(null)
eventtype_in:dynamic = dynamic([])
actorusername_has_any:dynamic = dynamic([])
registrykey_has_any:dynamic = dynamic([])
registryvalue_has_any:dynamic = dynamic([])
registrydata_has_any:dynamic = dynamic([])
dvchostname_has_any:dynamic = dynamic([])
disabled:bool = False

let RegistryAction = datatable (EventType: string, NewEventType: string)
[
    "CreateKey", "RegistryKeyCreated",
    "DeleteKey", "RegistryKeyDeleted",
    "DeleteValue", "RegistryValueDeleted",
    "SetValue", "RegistryValueSet",
    "RenameKey", "RegistryKeyRenamed"
];

let Hives = datatable (KeyPrefix: string, Hive: string)
[
    "HKLM", "HKEY_LOCAL_MACHINE",
    "HKU", "HKEY_USERS",
    "HKCR", "HKEY_LOCAL_MACHINE\\Classes"
];

// this is the parser for sysmon from WindowsEvent table
let ParsedRegistryEvent_WindowsEvent=() {
    WindowsEvent
```

ASIM has a collection of supported normalized schemas that keeps growing. Currently, the supported ones are Audit Event, Authentication Event, DHCP Activity, DNS Activity, File Activity, Network Session, Process Event, Registry Event, User Management, and Web Session.¹ In the above example, the Registry Event is used, which supports the following operations:

- RegistryKeyCreated
- RegistryKeyDeleted
- RegistryKeyRenamed
- RegistryValueDeleted
- RegistryValueSet

Use pre-existing templates to deploy ASIM by choosing the "Deploy to Azure" option.² Once you do that, the above depicted template will be present.

- You need to provide the subscription and resource group of your choice, and then the region, Sentinel workspace, and workspace region this resource will reside within. Then review and create.
- Once that's done, you can go to Microsoft Sentinel and then Logs. Choosing the Functions tab shows you the existing functions, allowing you to load the one you desire in the editor (in the above example, that's `vimRegistryEventMicrosoftSysmonWindowsEvent`).

1. <https://sec555.com/p9a5b>

2. <https://sec555.com/7aipl>

Case Study: Normalizing Sysmon Entries (1)

KQL Query

```
WindowsEvent
| where Provider == "Microsoft-Windows-Sysmon"
and EventID == 12
```

```
1 WindowsEvent
2 | where Provider == "Microsoft-Windows-Sysmon" and EventID == 12
3 | limit 10
4
5
```

results Chart Add bookmark

TimeGenerated [UTC] ↑↓	Provider
> 11/8/2024, 4:27:03.835 PM	Microsoft-Windows-Sysmon
> 11/8/2024, 4:22:11.463 PM	Microsoft-Windows-Sysmon
> 11/8/2024, 4:18:08.546 PM	Microsoft-Windows-Sysmon
> 11/8/2024, 4:17:17.443 PM	Microsoft-Windows-Sysmon

Sysmon events for creation or deletion of registry keys.

```
{
  "RuleName": "Suspicious, ImageBeginWithBackslash",
  "EventType": "DeleteValue",
  "UtcTime": "2024-11-08T16:27:03.8280000Z",
  "ProcessGuid": "{31e89cf3-3bce-672e-0b1e-010000000600}",
  "ProcessId": "4072",
  "Image": "C:\\Windows\\regedit.exe",
  "TargetObject": "HKLM\\HARDWARE\\New Value #1"
}
```

TimeGenerated [UTC] ↑↓	Provider
11/8/2024, 4:27:03.835 PM	Microsoft-Windows-Sysmon
TenantId	
SourceSystem	OpsManager
TimeGenerated [UTC]	2024-11-08T16:27:03.8353491Z
Provider	Microsoft-Windows-Sysmon
Channel	Microsoft-Windows-Sysmon/Operational
Computer	dc01.avengers.org
Task	12
EventLevel	4
EventLevelName	Information
SystemUserId	S-1-5-18
Version	2
Opcode	0
Keywords	0x8000000000000000
SystemProcessId	3244
SystemThreadId	4312
EventRecordId	119969
EventData	{ "RuleName": "Suspicious, ImageBeginWithB...
EventId	12
EventOriginId	b5f37334-b5ca-4fd4-8656-558678a7ea61
ManagementGroupName	AOI-fa0613c8-8df8-4862-bdd2-953dd536ec0b
Type	WindowsEvent
_ResourceId	/subscriptions/4996a69f-f666-4903-a983-338cc

Hmm, I wonder what's in there?

Sysmon is a great source of data for analysis. Provided you have already deployed the AMA agent within your environment, you need to create a custom data collection rule that will collect the necessary Sysmon logs. Under the "Collect" tab, use the following custom event log entry:

Microsoft-Windows-Sysmon/Operational!*

After you do that, Sysmon logs will be available in your Sentinel workspace. The above KQL query is:

```
WindowsEvent
| where Provider == "Microsoft-Windows-Sysmon" and EventID == 12
```

That filters for any activity around the creation or deletion of registry keys. Now, what's the challenge? If you review the above logs, you will notice that under EventData, you have quite a lot of meaningful items that aren't actively parsed into any separate fields for your visibility or use. Here's what's there:

- { "RuleName": "Suspicious, ImageBeginWithBackslash".
- "EventType": "DeleteValue".
- "UtcTime": "2024-11-08T16:27:03.8280000Z".
- "ProcessGuid": "{31e89cf3-3bce-672e-0b1e-010000000600}".
- "ProcessId": "4072".
- "Image": "C:\\Windows\\regedit.exe".
- "TargetObject": "HKLM\\HARDWARE\\New Value #1"}.

Reference:

- <https://sec555.com/16u3b>

Case Study: Normalizing Sysmon Entries (2)

Before Normalization

TimeGenerated [UTC]	Provider
11/8/2024, 4:27:03.835 PM	Microsoft-Windows-Sysmon
TenantId	
SourceSystem	
TimeGenerated [UTC]	2024-11-08T16:27:03.8353491Z
Provider	Microsoft-Windows-Sysmon
Channel	Microsoft-Windows-Sysmon/Operational
Computer	dc01.avengers.org
Task	12
EventLevel	4
EventLevelName	Informational
SystemUserId	S-1-5-18
Version	2
Opcode	0
Keywords	0x8000000000000000
SystemProcessId	3244
SystemThreadId	4312
EventRecordId	119969
EventData	["RuleName":"Suspicious.ImageBeginWithB...
EventId	12
EventOriginId	b5f37334-b5ca-4fd4-8656-558678a7ea61
ManagementGroupName	AOI-fa0613c8-8df8-4862-bdd2-953dd536ec0b
Type	WindowsEvent
_ResourceId	/subscriptions/4996a69f-f666-4903-a983-338cc

After Normalization

TimeGenerated [UTC]	Type
11/8/2024, 4:27:03.835 PM	WindowsEvent
EventStartTime [UTC]	2024-11-08T16:27:03.8353491Z
EventEndTime [UTC]	2024-11-08T16:27:03.8353491Z
EventCount	1
EventVendor	Microsoft
EventSchemaVersion	0.1.0
EventProduct	Sysmon
EventOriginalType	12
EventOriginalSubType	DeleteValue
DvcOs	Windows
ActingProcessId	4072
ActingProcessGuid	31e89cf3-3bce-672e-0b1e-010000000600
ActingProcessName	C:\Windows\regedit.exe
EventType	RegistryValueDeleted
RegistryKey	HKEY_LOCAL_MACHINE\HARDWARE
RegistryValue	New Value #1
Process	C:\Windows\regedit.exe
Dvc	dc01.avengers.org
EventResult	Success
EventSchema	RegistryEvent

Parser magic

```

EventStartTime = todatetime(TimeGenerated),
EventEndTime = todatetime(TimeGenerated),
EventCount = int(1),
EventVendor = "Microsoft",
EventSchemaVersion = "0.1.0",
EventProduct = "Sysmon",
EventOriginalType = tostring(EventID),
EventType = tostring(EventData.EventType),
DvcOs = "Windows",
EventMessage = tostring(EventData.RenderedDescription),
ActorUsername = tostring(EventData.User),
ActingProcessId = tostring(EventData.ProcessId),
ActingProcessGuid = extract('^{{(.*)}}$', 1, tostring(EventData.Image),
ActingProcessName = tostring(EventData.TargetObject),
TargetObject = tostring(EventData.TargetObject),
Parameter = tostring(EventData.Parameter)

```

- "EventType": "DeleteValue"
- "ProcessGuid": "{31e89cf3-3bce-672e-0b1e-010000000600}"
- "ProcessId": "4072"
- "TargetObject": "HKLM\\HARDWARE\\New Value #1"
- "Image": "C:\\Windows\\regedit.exe"

As you can see, now there's all that useful information from EventData that has been unpacked in a meaningful manner for us to use it however we see fit. For example, a SOC analyst performing an investigation for this activity can now use a KQL query like:

```

vimRegistryEventMicrosoftSysmonWindowsEvent
| where RegistryValue contains "New Value"

```

That wouldn't have been possible earlier, as that registry value field wasn't being parsed, so it wouldn't have been a searchable item. But now the analyst can create alerts or search with this item in their queries.

Microsoft has a really nice collection of ASIM security-related content, which includes analytics rules and hunting queries that you can use.¹

However, do note that as new versions of ASIM come around, table and function names change. So, you may find that you need to adjust these queries to fit the new version you may be using, which is easily done after you get accustomed to how this works and you read the documentation, plus you review the function source code in Sentinel.

1. <https://sec555.com/3zkcq>

Converting Alerts into Incidents

Instructions



Prerequisites

To integrate with Microsoft Defender XDR make sure you have:

- ✓ **Workspace:** read and write permissions.
- ✓ **Connector Access Control:** the user applying changes to the connector must be a member of the workspace's tenant.
- ✓ **Tenant Permissions:** 'Global Administrator' or 'Security Administrator' on the workspace's tenant.
- ✓ **License:** M365 E5, M365 A5 or any other Microsoft Defender XDR eligible license.



Configuration

Connect incidents & alerts

Connect Microsoft Defender XDR incidents to your Microsoft Sentinel. Incidents will appear in the incidents queue.

Disconnect

Option 1: Automatic incident generation via data connector configuration

Ensure you install the appropriate data connector (e.g., XDR). Configure it to send alerts in the form of incidents within Sentinel. If you have more than one product, enable accordingly. Another way is to use the pre-made rule templates.

Analytics rule wizard - Create a new Microsoft Security rule

General Automated response Review + create

Creating a rule to assign Mimikatz incidents to SOC Level 2

Status
☒ Enabled

Analytics rule logic

Microsoft security service *

Microsoft Defender for Endpoint

Filter by severity

☒ Any

☐ Custom

Include specific alerts

Only create incidents from alerts that contain the following text in the alert name

Mimikatz X +

Option 2: Manual incident generation, using analytics wizard

Some security teams in corporate environments like working off alerts in the actual tools themselves (e.g., alerts present in Defender for endpoints or via the Defender XDR console). However, Sentinel is, after all, a SIEM, so it gives you the option to convert incoming alerts into incidents. To do so, you can either:

1. **Enable automatic incident generation in the appropriate data connector:** For instance, if you are using Defender for Endpoint or Identity, you can install the data connector in Sentinel and configure it to allow incident creation. In the above example, the Defender XDR data connector has been installed, logs from all the related products (Defender for Identity, Cloud Apps, Office 365, and Endpoint) have been configured to send logs to Sentinel, while alerts have been configured to create incidents (as also shown in the above image).
2. **Create incidents via Sentinel:** Go to Microsoft Sentinel > Analytics > Create > Microsoft Incident Creation rule. If you do that, a wizard pops open. You define the rule name and description, the security service (the Defender product) it relates to, add any specific alert of interest to limit what this incident will be about, and you can even create an automation rule to take an action upon the incident being created, like assign a specific owner or team, change the status, run a playbook and other actions. Even though you might configure option 1 and automate incident creation from the various alerts, you will see that often enough, it is useful to manually create incidents to depict specific items or automate responses in a certain way, so this method is something that you should also consider adding to your arsenal.
3. **Use Sentinel rule templates:** A third option is to go to Microsoft Sentinel > Analytics > Rule templates and select a specific rule template that you want to modify to meet your needs. You can modify the rule query, which will be running when the rule triggers, the associated entity mappings for users, devices, and more. You can set the rule execution frequency, incident creation method, and if there's any desired automated response you wish to trigger with it. Any rule you end up creating from the template gets added to the active rule list afterward.

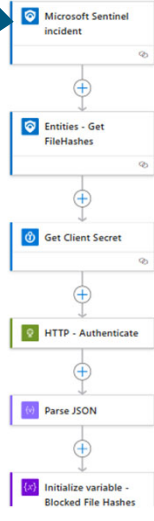
Playbook Creation

Home > Logic apps > AS-Block-Hash-in-Defender >

AS-Block-Hash-in-Defender

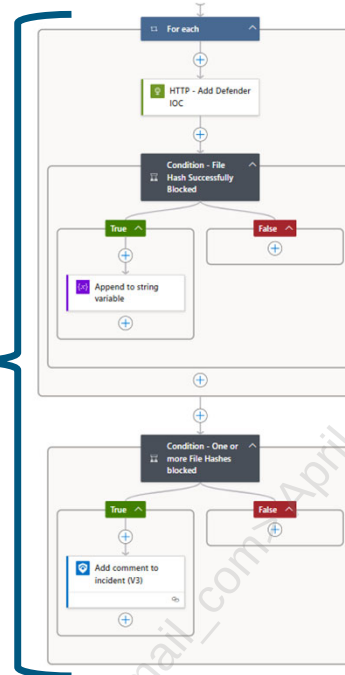
Run Save Discard Parameters Code view Errors Info File a bug

File hashes included in Sentinel Incident



Playbook gets the file hashes and uses the registered app's secret key

IOC is added to Defender, and after that a note is made to the original Sentinel incident



- Playbooks can be based on templates or created from scratch.
- Don't reinvent the wheel.
- Save your team time and deploy them whenever possible.
- Examples: Disable Entra user, block IOC, delete application, isolate machine, integrate with Slack/Teams.

Sentinel playbooks can be found under Microsoft Sentinel > Automation > Create Playbook... where there are various options to create playbooks based on incident, entity, or alert triggers, or you can always create a blank playbook from scratch. Microsoft has a rich GitHub repository of playbooks.¹ An example of that is an implementation of a playbook that can block file hashes in Defender. The basis of this is a Sentinel incident. Once the incident gets created and populated with malicious file hashes, the playbook automation kicks in to take those and block them in Defender. Once that is done, a note is added to the incident where it clearly states this file hash block was created based on the AS-Block-Hash-in-Defender playbook for clarity to anyone reading the incident notes. Most playbook automations get actionable by creating a Logic App with sufficient API permissions to allow it to initiate a specific action. For example, the Logic App created in this playbook has Ti.read/write Defender ATP permissions to allow it to communicate to Defender with sufficient power for file hashes to be added for blocking them.

It's extremely beneficial for engineers to create as many playbooks as possible and, after careful testing, deploy them in the environment. Automation helps save time, resources, avoid mistakes, and gain those valuable seconds to respond and terminate a compromise before the attacker gains further access in your environment.

To properly create and manage playbooks, you need Logic App Contributor (allows editing and managing logic apps) and Logic App Operator (allows reading, enabling, and disabling logic apps) permissions.² Microsoft has a great list of recommended playbooks.³

1. <https://sec555.com/nf8rx>
2. <https://sec555.com/9v4ni>
3. <https://sec555.com/lkqbt>

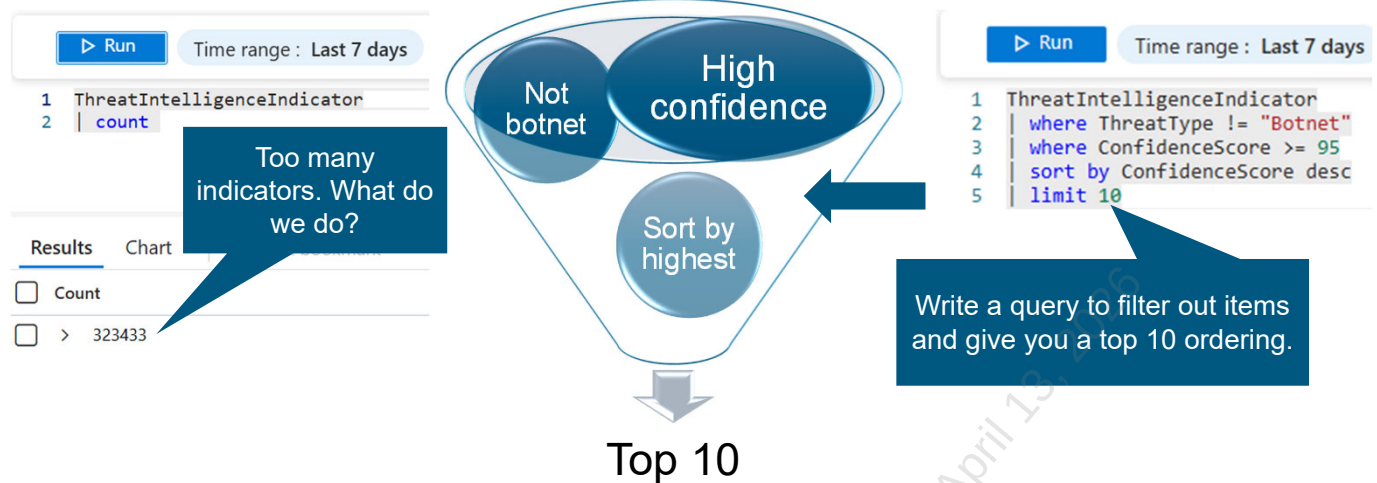
KQL (Kusto Query Language)



The student will gain a basic understanding of KQL query composition, basic operator description, and experience queries of interest.

This area is intentionally left blank.

KQL Introduction (1)



That collection of threat intelligence indicator data seems massive. What do we do?

Filter out items to gain some low-hanging fruit on where to focus.

The Kusto Query Language (KQL) is used by security solutions (like Sentinel, Defender XDR, and Azure Monitor), but also by the following products:

- **Azure Data Explorer:** Big data analytics platform used for large volume data analysis, allowing pattern identification and trending analysis.
- **Real-Time Analytics in Microsoft Fabric:** Used for data science and big data analytics.
- **Azure Resource Graph:** Allows you to form KQL queries to manage your Azure environment, and can be especially handy when querying for specific information in large companies with multiple resources.

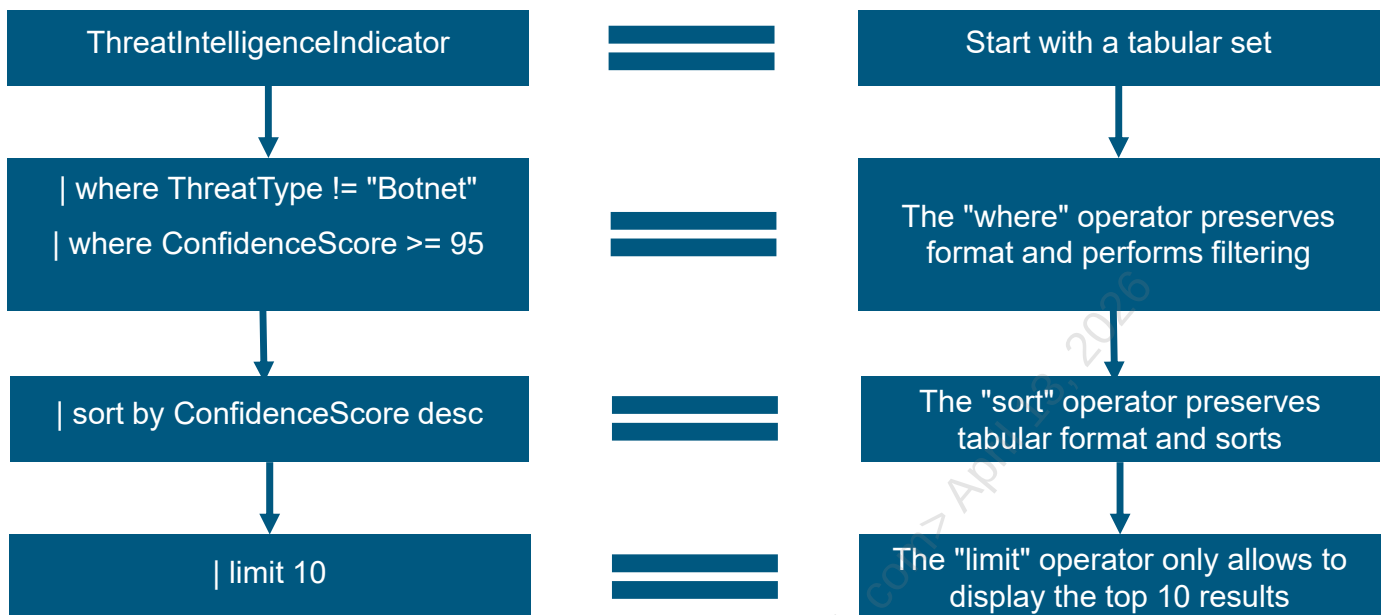
Overall, you can benefit by running queries that can be used to configure alerting, visualize information, perform health checks on resources, and identify and tackle performance issues. From a data analytics aspect, you can perform data transformations before storing it and reduce the amount of information you store, which can drive your costs down. In this example, an initial query was executed to identify the number of threat intelligence indicators in the database, which is 32,443:

```
ThreatIntelligenceIndicator
| count
```

Now, that's a lot. Because of that, a new KQL query is created:

```
ThreatIntelligenceIndicator
| where ThreatType != "Botnet"
| where ConfidenceScore >= 95
| sort by ConfidenceScore desc
| limit 10
```

KQL Introduction (2)



This one filters out indicators falling under botnets. It also checks that the confidence score is at 100%, classifies results by descending confidence score order, and only shows the top 10 results. If you have ever used Linux systems, the above query should remind you of the successive pipes (`|`), which allow you to funnel the output of a previous command to the next one, for further filtering. How does this query work?

- **Step 1:** Start with the tabular dataset of the `ThreatIntelligenceIndicator` table.
- **Step 2:** Use the **"where"** operator to select specific events by filtering out a threat category and only choosing a certain confidence score. The tabular format is still maintained.
- **Step 3:** The **"sort"** operator is then used to sort the results based on the confidence score, while again maintaining the tabular format.
- **Step 4:** A final **"limit"** operator is used to limit the results to the top 10 matches, while still maintaining the tabular format.

Interface Options in Sentinel KQL

The screenshot displays the Sentinel KQL interface. At the top, there are tabs for 'Tables', 'Queries', 'Functions', and 'Query History'. The 'Queries' tab is active, showing a query editor with the following KQL code:

```
DeviceNetworkEvents
| where ActionType == "ListeningConnectionCreated"
| where LocalPort == "3389"
| summarize by DeviceName
```

Below the query editor, there are buttons for 'Run', 'Time range: Custom', and 'Limit:'. The 'Results' tab is selected, showing a list of devices with their names and IP addresses. On the right side, there are several dropdown menus and buttons for saving and sharing the query. A 'Simple or KQL mode' button is also visible. A search bar is located at the bottom right, with 'DeviceName' and 'OpenPorts' listed as search results.

- If you want a free playground, try the MS demo environment at <https://aka.ms/LADemo>.
- Remember, KQL can be used in numerous products, like Sentinel, Defender, and Azure Monitor, and allows you to get the required information rapidly and in a summarized manner.
- To start easy, use pre-built queries and functions. Once you gain more experience, create your own and save them as functions or queries.
- Numerous export options exist for sharing details with other interested parties.

There are multiple ways you can run KQL queries, as that's supported in numerous different products. The image depicts the Sentinel interface while running a query that generates a list of devices that have accepted RDP connections (using port 3389):

```
DeviceNetworkEvents
| where ActionType == "ListeningConnectionCreated"
| where LocalPort == "3389"
| summarize by DeviceName
```

KQL queries are requests that you make to obtain results of interest. They can be resource, performance, or security related. They can support pattern identification and represent statistical models or perform heavy visualizations that provide high-level information to draw conclusions from big datasets. To make it easier to build a query, browse the precompiled "Queries" to load their code to the editor and run them or edit them to suit your needs. This can save a lot of time and make it easier to run useful queries, even if you are new to KQL. There are also functions available that essentially represent reusable queries or query portions. They can be:

- **Built-in:** These are KQL functions that don't support any user modification as they are hard-coded.
- **User-defined:** These are split into two subcategories:
 - **Stored functions:** Stored as database entities (like a table).
 - **User-defined functions:** When a function is stored, the goal is to be able to reuse it at will, whenever you need it. It allows you to have this fragment of query code available (like the source code in a programming language's function). They can be called with or without arguments. You can even define a function in a query's code using the "let" operator.

If you are interested in making your queries easily digestible by others or even for yourself, as you write more complicated statements, use the // characters to comment items out.

If you need to make a query using traditional SQL commands, KQL supports T-SQL, which is

© SANS Institute 2025

transactional SQL—an extension of SQL mainly used in Microsoft SQL Server. So, it gives you the SQL-supported commands plus some add-ons. The main differences are that SQL is open source while T-SQL is owned and maintained by Microsoft, and that some of the keywords are similar but not identical.

The data tables are created upon data being ingested, normalized, and mapped accordingly.

References:

- <https://aka.ms/LADemo>
- <https://sec555.com/0wshn>
- <https://sec555.com/1d9ue>
- <https://sec555.com/il4ef>
- <https://sec555.com/zw04u>
- <https://sec555.com/y8ubm>

Project and Project-Away Operators

Run Recall KQL tools help/SecurityLogs

1 AuthenticationEvents

AuthenticationEvents + Add visual Stats Search UTC Done (0.817 s) 3,869 records

I don't need all 7 of these columns.

timestamp	hostname	src_ip	user_agent	username	result	password_hash
> 2022-01-03 19:23:41.209621	MAIL-SERVER01	178.250.47.206	Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/534.0 (KHTML, like Gecko...	jasaade	Successful Login	d2f2ee41d79b5711085f03f4ddcae8b1
> 2022-01-03 19:23:46.650333	MAIL-SERVER01	58.128.200.24	Mozilla/5.0 (Macintosh; U; PPC Mac OS X 10_9_2) AppleWebKit/536.1...	marivera	Successful Login	d2ec8d8d42b8de03091d4238e7fafbc1
> 2022-01-03 19:23:47.110481	MAIL-SERVER01	94.208.164.246	Mozilla/5.0 (Macintosh; U; Intel Mac OS X 10_6_9) AppleWebKit/532.2...	beparrish	Successful Login	9c5c43626ed520201d45e17a8c8f3e57
> 2022-01-03 19:23:47.770901	MAIL-SERVER01	89.27.65.180	Mozilla/5.0 (X11; Linux i686) AppleWebKit/531.0 (KHTML, like Gecko) ...	chicks	Failed Login	bd133b0f0385b88aa05dfffa820ad8035
> 2022-01-03 19:23:52.281780	MAIL-SERVER01	212.218.197.70	Mozilla/5.0 (Macintosh; Intel Mac OS X 10_12_5) AppleWebKit/534.1 (...	yoopperman	Successful Login	07e6bde12a7147ad4de7d53084ebe012
> 2022-01-03 19:23:52.641792	MAIL-SERVER01	213.225.168.45	Mozilla/5.0 (Linux; Android 7.1.1) AppleWebKit/531.2 (KHTML, like Ge...	brburnett	Failed Login	a540bb9a4b6c26fd7774f0e6df13fbc7
> 2022-01-03 19:23:56.070251	MAIL-SERVER01	45.58.48.184	Mozilla/5.0 (Linux; Android 3.2.6) AppleWebKit/532.1 (KHTML, like Ge...	chhutchins	Successful Login	70f217931163bc42b03bf2da45b4563a

```
AuthenticationEvents
| project timestamp,
source=src_ip, user=username,
result
| take 5
```

timestamp	source	user	result
2022-01-03 19:23:41.209621	178.250.47.206	jasaade	Successful Login
2022-01-03 19:23:46.650333	58.128.200.24	marivera	Successful Login
2022-01-03 19:23:47.110481	94.208.164.246	beparrish	Successful Login
2022-01-03 19:23:47.770901	89.27.65.180	chicks	Failed Login
2022-01-03 19:23:52.281780	212.218.197.70	yoopperman	Successful Login

Displaying the results of the AuthenticationEvents table shows 7 columns in use. But what about only wanting to see 4 of those for your purposes? In that case, you can use the "project" operator to filter only for the columns of interest. You can even use new names of the columns if you want, or leave some intact. Let's say you needed to rename the src_ip column to source and the username column to user, while leaving timestamp and result intact. In addition, you wish to only filter for the first 5 entries.

In that case, your new query would be as follows:

```
AuthenticationEvents
| project timestamp, source=src_ip, user=username, result
| take 5
```

Now, how about if you needed the opposite?

Maybe you need to keep all the columns, but just remove the password hashes because they are sensitive datasets. In that case, you can filter with:

```
AuthenticationEvents
| project-away password_hash
| take 5
```

Important Operators (1)

Example	Operator	Description
SecurityLogs getschema	getschema	Displays the SecurityLogs table column name, column ordinal, data type, and column type
contains "System32"	contains	Result contains System32
sort by price asc	sort by	Sorting by ascending price
name == "Nick"	string value	Name is Nick
datetime(2025-03-01)..datetime(2025-04-15)	datetime	Date is between 1 March 2025 and 15 April 2025
InboundBrowsing where method == "GET" summarize EventCount = count() by src_ip	count	Count number of source IP rows
InboundBrowsing where method == "GET" distinct src_ip	Distinct	Lists the distinct values of a particular column

The next two pages display tables of some of the most important KQL operators to allow you to get familiar with items that you would commonly use in your queries.

- **Getschema:** Displays a given table's structure information. Specifically, the Column name, Column Ordinal, Data Type, and Column Type.
- **Contains:** This operator is used to denote a value (in this case, "System 32") that is contained in the query.
- **Sort by:** Used to sort results by ascending or descending order.
- **":** Used to denote a string value. For example, "Nick" searches for strings with Nick.
- **Datetime:** Used to denote a start and end date for the query.
- **Count:** Counts number of rows relating to an argument (here, src_ip).
- **Distinct:** Lists distinct values of a column.

Reference:

- <https://sec555.com/mz3a8>

Important Operators (2)

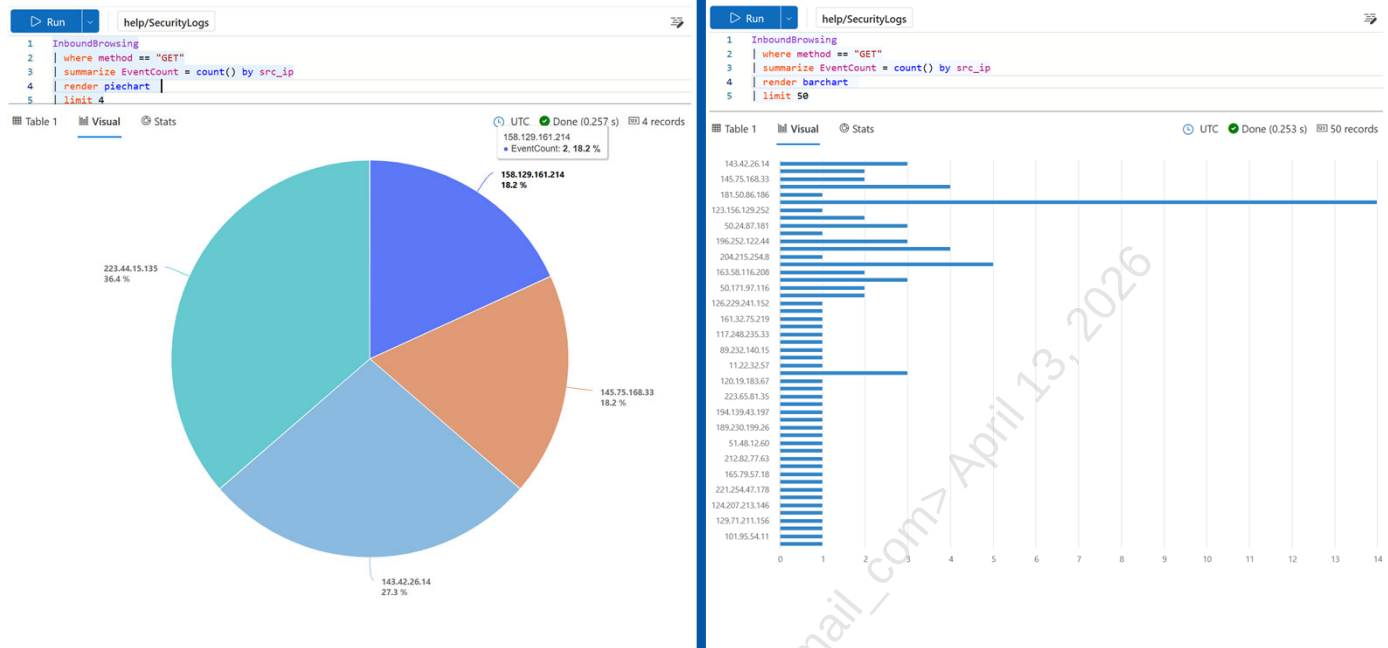
Example	Operator	Description
where Timestamp > ago(1d)	ago	All rows with a timestamp larger than a day
summarize alerts = count() by Machine	summarize	Summarize generated alert count by machine
summarize deletions = countif(FilesDeleted > 10)	countif()	Use countif to identify file deletions exceeding 10 events
summarize MaxChanges=max(FileChanges), MinChanges=min(FileChanges), AvgChanges=avg(FileChanges)	Max Min Avg	Calculate the max/min/avg file change amounts
Accidents take 100 project BeginLon, BeginLat render scatterchart with (kind = map)	Project Render Kind	Create accident visualization on a map by using project to choose the column with the longitude and the latitude. Afterward, use render to see the results in a scatter chart with kind set to map.

- **Ago:** Allows you to provide records that are larger or smaller than a given period (e.g., 1 hour, minute, day, etc.).
- **Summarize:** Provides a summary of results.
- **Countif:** Count occurrences meeting a specific condition (e.g., larger than 10, or smaller than 5).
- **Max:** Calculate the maximum value.
- **Min:** Calculate the minimum value.
- **Avg:** Calculate the average value.
- **Project, render, kind:** Create a visualization on a map by using **project** to choose the column with the longitude and the latitude. Afterward, use **render** to see the results in a scatter chart with **kind** set to map.

Reference:

- <https://sec555.com/ap6ey>

Visualization Operators



The render operator allows you to perform visualizations and should be used at the end of a query. Possible options for that operator include:

- Columnchart
- Barchart
- Piechart
- Scatterchart
- Pivotchart

These example queries allow you to visualize the amount of GET requests grouped by originating source IP addresses. Notice how a nice graph can yield an outlier? This can save you an immense amount of time when investigating security incidents.

```
InboundBrowsing
| where method == "GET"
| summarize EventCount = count() by src_ip
| render piechart
| limit 4
```

```
InboundBrowsing
| where method == "GET"
| summarize EventCount = count() by src_ip
| render barchart
| limit 50
```

Geospatial Visualizations

Run Recall KQL tools

```

1 StormEvents
2 | take 100
3 | project BeginLon, BeginLat, EventType

```

Table 1 + Add visual Stats

BeginLon	BeginLat	EventType
> -80.6048	28.0393	Waterspout
> -81.05	29.28	Heavy Rain
> -81.6763	28.8368	Tornado

```

StormEvents
| take 100
| project BeginLon, BeginLat, EventType
| render scatterchart with (kind = map)

```

Run Recall KQL tools help/Samples

Pin to dashboard Open Copy Export

```

1 StormEvents
2 | take 100
3 | project BeginLon, BeginLat, EventType
4 | render scatterchart with (kind = map)

```

Table 1 Visual Stats

UTC Done (0.253 s) 100 records

KQL queries can be used for rendering some very useful visualizations for the geospatial representation of data. The only thing you need to ensure is that you have the appropriate information required for rendering them.

In the above example, the following query shows the geographical longitude and latitude columns containing geospatial data.

```

StormEvents
| take 100
| project BeginLon, BeginLat, EventType

```

Let's add another line in the above query to make it render a geospatial visualization:

```

StormEvents
| take 100
| project BeginLon, BeginLat, EventType
| render scatterchart with (kind = map)

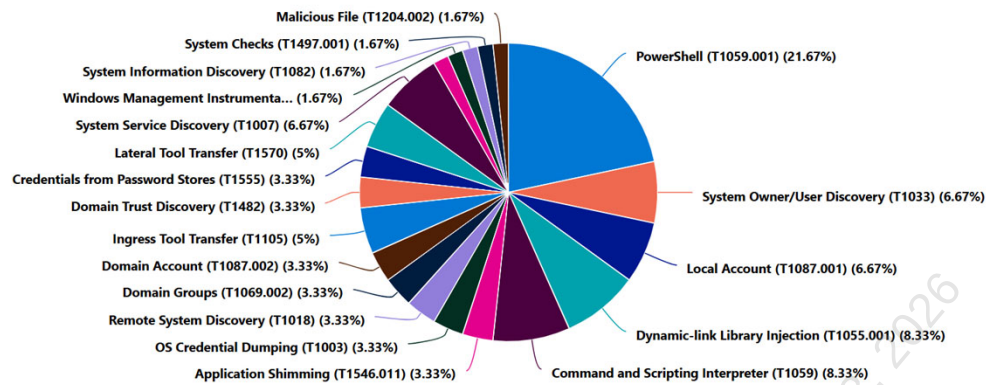
```

Reference:

- KQL Source for Rendering Images: <https://sec555.com/f1d2b>

Licensed To: Arvind Pariti <paritiarvind@gmail.com> April 13, 2026

MITRE ATT&CK Techniques Categorization



```
AlertInfo
| where Timestamp > ago(30d)
| where AttackTechniques != ""
| mvexpand todynamic(AttackTechniques)
| summarize count() by tostring(AttackTechniques)
| render piechart
```

This query can be used to navigate the alerts table and obtain useful information.

```
AlertInfo
| where Timestamp > ago(30d)
| where AttackTechniques != ""
| mvexpand todynamic(AttackTechniques)
| summarize count() by tostring(AttackTechniques)
| render piechart
```

It looks at the following:

- Alert information with a timestamp going back 30 days.
- Where there's an identified MITRE attack technique (no blank entries).
- The "mv-expand" operator allows each attack technique property to generate a unique record in the query output.
- Table values are then evaluated to generate a count of each attack technique used, which is finally rendered in a pie chart.

Reference:

- <https://sec555.com/7brq2>

Privileged Role Assignment Identification

```

1 let PrivilegedRoles = datatable(RoleName:string, RoleGuid:string)
2 ["Global Administrator", "62e90394-69f5-4237-9190-012177145e10",
3 "Privileged Authentication Administrator", "7be44c8a-adaf-4e2a-84d6-ab2649e08a13",
4 "Privileged Role Administrator", "e8611ab8-c189-46e8-94e1-60213ab1f814",
5 "Security Administrator", "194ae4cb-b126-40b2-bd5b-6091b380977d",
6 ];
7 AuditLogs
8 | where TimeGenerated > ago(365d)
9 | where OperationName has_all ("add", "member to role", "completed")
10 | where OperationName has_any ("timebound", "permanent")
11 | where TargetResources has_any(PrivilegedRoles | project RoleGuid)
12 | project TimeGenerated, TargetResources, OperationName, AdditionalDetails

```

Set your timeframe

Replace with any accounts you need

Matching fields in OperationName column

Results Chart Add bookmark

TimeGenerated [UTC]	TargetResources	OperationName	AdditionalDetails
> 11/3/2024, 4:40:06.971 PM	[{"id":"194ae4cb-b126-40b2-bd5b-6091b380977d","displayName":"Security Administrator","type":"Role","modifiedProperties":{"key":"RoleDefinitionOriginId","value":"194ae4cb-b126-40b2-bd5b-6091b380977d"}}, {"id":"62e90394-69f5-4237-9190-012177145e10","displayName":"Global Administrator","type":"Role","modifiedProperties":{"key":"RoleDefinitionOriginId","value":"62e90394-69f5-4237-9190-012177145e10"}}, {"id":"7be44c8a-adaf-4e2a-84d6-ab2649e08a13","displayName":"Privileged Authentication Administrator","type":"Role","modifiedProperties":{"key":"RoleDefinitionOriginId","value":"7be44c8a-adaf-4e2a-84d6-ab2649e08a13"}}, {"id":"e8611ab8-c189-46e8-94e1-60213ab1f814","displayName":"Privileged Role Administrator","type":"Role","modifiedProperties":{"key":"RoleDefinitionOriginId","value":"e8611ab8-c189-46e8-94e1-60213ab1f814"}}, {"id":"194ae4cb-b126-40b2-bd5b-6091b380977d","displayName":"Security Administrator","type":"Role","modifiedProperties":{"key":"RoleDefinitionOriginId","value":"194ae4cb-b126-40b2-bd5b-6091b380977d"}}]	Add member to role in PIM completed (permanent)	[{"key":"RoleDefinitionOriginId","value":"194ae4cb-b126-40b2-bd5b-6091b380977d"}]
> 11/3/2024, 4:04:02.481 PM	[{"id":"194ae4cb-b126-40b2-bd5b-6091b380977d","displayName":"Security Administrator","type":"Role","modifiedProperties":{"key":"RoleDefinitionOriginId","value":"194ae4cb-b126-40b2-bd5b-6091b380977d"}}, {"id":"62e90394-69f5-4237-9190-012177145e10","displayName":"Global Administrator","type":"Role","modifiedProperties":{"key":"RoleDefinitionOriginId","value":"62e90394-69f5-4237-9190-012177145e10"}}, {"id":"7be44c8a-adaf-4e2a-84d6-ab2649e08a13","displayName":"Privileged Authentication Administrator","type":"Role","modifiedProperties":{"key":"RoleDefinitionOriginId","value":"7be44c8a-adaf-4e2a-84d6-ab2649e08a13"}}, {"id":"e8611ab8-c189-46e8-94e1-60213ab1f814","displayName":"Privileged Role Administrator","type":"Role","modifiedProperties":{"key":"RoleDefinitionOriginId","value":"e8611ab8-c189-46e8-94e1-60213ab1f814"}}, {"id":"194ae4cb-b126-40b2-bd5b-6091b380977d","displayName":"Security Administrator","type":"Role","modifiedProperties":{"key":"RoleDefinitionOriginId","value":"194ae4cb-b126-40b2-bd5b-6091b380977d"}}]	Add eligible member to role in PIM completed (permanent)	[{"key":"RoleDefinitionOriginId","value":"194ae4cb-b126-40b2-bd5b-6091b380977d"}]

```

let PrivilegedRoles = datatable(RoleName:string, RoleGuid:string)
["Global Administrator", "62e90394-69f5-4237-9190-012177145e10",
"Privileged Authentication Administrator", "7be44c8a-adaf-4e2a-84d6-ab2649e08a13",
"Privileged Role Administrator", "e8611ab8-c189-46e8-94e1-60213ab1f814",
"Security Administrator", "194ae4cb-b126-40b2-bd5b-6091b380977d",
];
AuditLogs
| where TimeGenerated > ago(365d)
| where OperationName has_all ("add", "member to role", "completed")
| where OperationName has_any ("timebound", "permanent")
| where TargetResources has_any(PrivilegedRoles | project RoleGuid)
| project TimeGenerated, AADTenantId, TargetResources, OperationName, InitiatedBy, AdditionalDetails
| project-away InitiatedBy, AdditionalDetails, TargetResources

```

This interesting query can show you any type of Azure privileged assignments that were requested within a timeframe of interest (here, set for 1 year):

```

let PrivilegedRoles = datatable(RoleName:string, RoleGuid:string)
["Global Administrator", "62e90394-69f5-4237-9190-012177145e10",
"Privileged Authentication Administrator", "7be44c8a-adaf-4e2a-84d6-ab2649e08a13",
"Privileged Role Administrator", "e8611ab8-c189-46e8-94e1-60213ab1f814",
"Security Administrator", "194ae4cb-b126-40b2-bd5b-6091b380977d",];
AuditLogs
| where TimeGenerated > ago(730d)
| where OperationName has_all ("add", "member to role", "completed")
| where OperationName has_any ("timebound", "permanent")
| where TargetResources has_any(PrivilegedRoles | project RoleGuid)
| project TimeGenerated, AADTenantId, TargetResources, OperationName, InitiatedBy, AdditionalDetails
| project-away InitiatedBy, AdditionalDetails, TargetResources

```

Reference:

- <https://sec555.com/x7c4t>

Privileged Role Assignment Identification: Unpacked

☐ TimeGenerated [UTC] ↑↓	TargetResources	OperationName
☐ 11/3/2024, 4:40:06.971 PM	[{"id":"194ae4cb-b126-40b2-bd5b-6091b380977d","displayName":"Security Administrator","type":"Role","modifiedProperties":{},"administrativeUnits":[]}]	Add member to role in PIM completed (permanent)
TimeGenerated [UTC] 2024-11-03T16:40:06.971222Z	TargetResources [{"id":"194ae4cb-b126-40b2-bd5b-6091b380977d","displayName":"Security Administrator","type":"Role","modifiedProperties":{"displayname":{"oldValue":"","newValue":"Security Administrator"},"roleDefinitionOriginId":{"oldValue":"","newValue":"194ae4cb-b126-40b2-bd5b-6091b380977d"},"administrativeUnits":{"oldValue":"","newValue":[]}}}] > 0 [{"id":"194ae4cb-b126-40b2-bd5b-6091b380977d","displayName":"Security Administrator","type":"Role","modifiedProperties":{"displayname":{"oldValue":"","newValue":"Security Administrator"},"roleDefinitionOriginId":{"oldValue":"","newValue":"194ae4cb-b126-40b2-bd5b-6091b380977d"},"administrativeUnits":{"oldValue":"","newValue":[]}}}] > 1 [{"id":"63429edc-62b1-4e40-b0ea-1158fa2f8aee","displayName":null,"type":"Request","modifiedProperties":{"administrativeUnits":{"oldValue":"","newValue":[]}}}] > 2 [{"id":"b1f6c676-7273-4eed-8f27-9425eb7653d1","displayName":"Dones, Sam","type":"User","modifiedProperties":{"administrativeUnits":{"oldValue":"","newValue":[]},"userPrincipalName":{"oldValue":"","newValue":"sam.dones@sansrange01sec55.onmicrosoft.com"}}] administrativeUnits [] displayName Dones, Sam id b1f6c676-7273-4eed-8f27-9425eb7653d1 modifiedProperties {} type User userPrincipalName sam.dones@sansrange01sec55.onmicrosoft.com	

All of this seems like great information.
☺ How do I unpack it?

Roles of interest in this example are:

1. **Global Administrator** (GUID: 62e90394-69f5-4237-9190-012177145e10)
2. **Privileged Authentication Administrator** (GUID: 7be44c8a-adaf-4e2a-84d6-ab2649e08a13)
3. **Privileged Role Administrator** (GUID: e8611ab8-c189-46e8-94e1-60213ab1f814)
4. **Security Administrator** (GUID: 194ae4cb-b126-40b2-bd5b-6091b380977d)

In this example, the built-in monitored roles of interest are:

- **Global Administrator** (GUID: 62e90394-69f5-4237-9190-012177145e10)
- **Privileged Authentication Administrator** (GUID: 7be44c8a-adaf-4e2a-84d6-ab2649e08a13)
- **Privileged Role Administrator** (GUID: e8611ab8-c189-46e8-94e1-60213ab1f814)
- **Security Administrator** (GUID: 194ae4cb-b126-40b2-bd5b-6091b380977d)

You can add more to this list if you need to. The below-mentioned Microsoft resource contains a list of all Microsoft Entra built-in roles, which is a great starting point.

The KQL query is searching the audit logs for the period in question, for the OperationName column containing keywords of interest, indicative of privileged role assignments. After that, it just renders the information of the four columns being depicted (TimeGenerated, TargetResources, OperationName, AdditionalDetails). However, notice the above image? The "TargetResources" has some really great information that seems of high value for analysts. You need to extract it for them so they can gain more evidence during an investigation. So, how about we go back to the previous KQL query and enrich it?

Reference:

- <https://sec555.com/vljq6>

Privileged Role Assignment Identification: Improved Version

```
let PrivilegedRoles = datatable(RoleName:string, RoleGuid:string)
["Global Administrator", "62e90394-69f5-4237-9190-012177145e10",
"Privileged Authentication Administrator", "7be44c8a-adaf-4e2a-84d6-ab2649e08a13",
"Privileged Role Administrator", "e8611ab8-c189-46e8-94e1-60213ab1f814",
"Security Administrator", "194ae4cb-b126-40b2-bd5b-6091b380977d",
];
AuditLogs
| where TimeGenerated > ago(365d)
| where OperationName has_all ("add","member to role","completed")
| where OperationName has_any('timebound','permanent')
| where TargetResources has_any(PrivilegedRoles | project RoleGuid)
| project TimeGenerated, AADTenantId,TargetResources, OperationName, InitiatedBy, AdditionalDetails
| extend
    TargetId = tostring(TargetResources[2].id),
    TargetType = tostring(TargetResources[2].type),
    TargetUser = tostring(TargetResources[2].userPrincipalName),
    TargetDisplayName = tostring(TargetResources[2].displayName)
| project-away InitiatedBy, AdditionalDetails, TargetResources
```

The following segment has been added:

```
| extend
    TargetId = tostring(TargetResources[2].id),
    TargetType = tostring(TargetResources[2].type),
    TargetUser = tostring(TargetResources[2].userPrincipalName),
    TargetDisplayName = tostring(TargetResources[2].displayName),
| project-away InitiatedBy, AdditionalDetails, TargetResources
```

Specific fields of interest under "TargetResources" have been extrapolated to provide some more context. Those are the ID, type, userPrincipalName, and displayName. Of course, you can go ahead and unpack many more as you see fit for your use cases and environment. The goal is for you to make the most out of this and identify items of interest that you can then create queries or save them for future use, so you don't have to reinvent the wheel each time you create an additional query.

Summary

Integrating Defender with Sentinel can provide you with a great SIEM solution, enriched with SOAR. Choose your workspace architecture and log storage plans carefully. Define data retention periods that reflect your needs. Use ASIM to perform normalization and increase your filtering capability.

Use KQL for enhanced searching and filtering of vast event volumes. You can use KQL to search through years of data for specific items of interest. Powerful visualization operators can support your effort and enhance your threat hunting and incident response capabilities.

This area is intentionally left blank.

Sentinel and KQL

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Course Roadmap

Section 1: Detection Engineering and SIEM Architecture

Section 2: Network and Endpoint Analysis

Section 3: Asset Discovery, Baselines, and UEBA

Section 4: Cloud Logging and Monitoring

Section 5: Alerting and Detection Engineering Pipelines

- Azure Cloud Logging
 - ☐ Lab 4.1: Logging Unauthorized Access to Sensitive Data
- Microsoft Defender Suite and Copilot for Security
 - ☐ Lab 4.2: Defender for Cloud
- Microsoft Sentinel and KQL
 - ☐ Lab 4.3: Sentinel and KQL
- AWS Cloud Logging
 - ☐ Lab 4.4: Creating an AWS Lab, Configuring and Testing CloudWatch

This area is intentionally left blank.

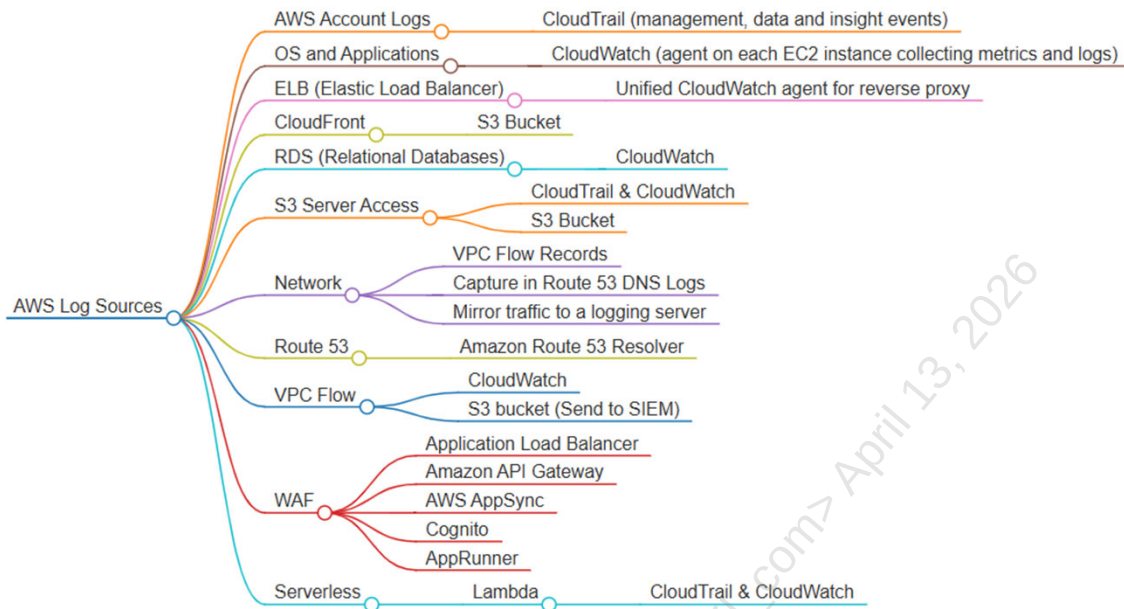
Objectives



The student will gain an overview of AWS logging services and log sources, as well as how those can be investigated and exported for further analysis.

This area is intentionally left blank.

AWS Log Types



There are numerous log sources available for you to log from, store, analyze, and dig into. The above mind map aims to give you a breakdown of the most encountered sources you should consider logging from, and which method allows you to do that in the most optimal way. As you may notice, there's a common theme here, showing quite a lot of AWS services as being good candidates for you to use. Those are outlined on the next page.

Reference:

- <https://sec555.com/euv6t>

AWS Services

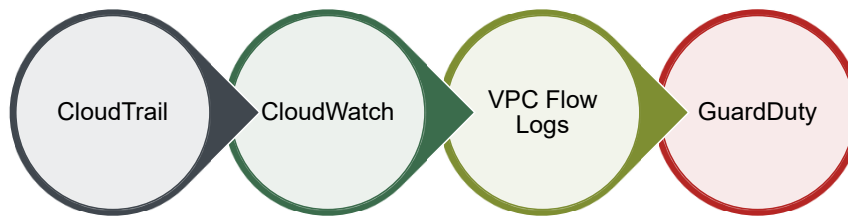
Name	Description
Security Hub	Indicates high-priority alerts and compliance progress within your estate. Accepts data from services like GuardDuty, Inspector, and Macie.
GuardDuty	Threat detection service monitoring your environment for malicious access, indications of compromise, or attacks.
Macie	Auto-discovery and protection of sensitive data. Utilizes machine learning to provide alerts when it detects sensitive data exposure.
CloudWatch	Monitoring services and applications within your environment. Collects metrics and monitors log files.
Inspector	Automatic security assessment service for compliance and security enhancement. Performs vulnerability identification and best practice deviation assessment.
Detective	Enhances your investigational efficacy by collecting log data and using ML and statistical analysis to expedite investigations.
CloudTrail	Supports governance, compliance, and auditing by logging and monitoring account activities.
AWS Config	Periodic assessment of resource configurations and storage in an S3 bucket for assessing history of changes.
Athena	Use SQL commands to directly query CloudTrail data stored in S3 buckets.

The above table lists the most common AWS security services that can aid you in logging and analysis of events taking place in your environment. A short description is provided, but within the pages that follow, the most useful ones will be analyzed in greater detail.

Reference:

- <https://sec555.com/3pwer>

AWS Core Logging Elements



Access via:

- AWS console
- AWS CLI
- Service API
- AWS SDKs

- **CloudTrail:** Governance and compliance, keep a record of user, role, and AWS service actions.
- **CloudWatch:** Log analysis, metric monitoring of resources and applications.
- **VPC Flow Logs:** Monitors interface inbound and outbound traffic for your AWS VPCs.
- **GuardDuty:** Machine learning, anomaly detection, malware scanning, and threat intelligence to monitor AWS resources for indications of compromise.

Logging and monitoring in AWS are achieved mainly by four services:

- **CloudTrail:** Provides governance and compliance, in addition to allowing you to keep a record of user, role, and AWS service actions.
- **CloudWatch:** Supports log analysis and metric monitoring of resources and applications.
- **VPC Flow Logs:** Monitors interface inbound and outbound traffic for your AWS VPCs.
- **GuardDuty:** Uses machine learning, anomaly detection, malware scanning and AWS threat intelligence, and external parties to monitor AWS accounts, users, resources, and data for signs of intrusions or indications of compromise.

There are numerous ways to access and manage your AWS services, which are:

- **AWS Service Console** (the CloudTrail console for CloudTrail, CloudWatch console for CloudWatch, and similar for other services): The advantage of the console is offering beautiful GUI access with really handy wizards, able to guide you in detail for most configurations you need to perform.
- **AWS CLI:** Able to expedite running queries, limit results, filter output, pipe it to other third-party tools, and more.
- **Service API:** Using service-based API calls to communicate with any AWS service of interest.
- **AWS SDKs:** Multi-language support with pre-created libraries that support programmatic access to AWS.

CloudTrail

Name	Home region	Multi-region trail	Insights	Organization trail	S3 bucket	Log file prefix	CloudWatch Logs log group	Status
LogCentral	US East (N. Virginia)	Yes	Disabled	Yes	aws-cloudtrail-	aws/cloudtrail/	arn:aws:logs:us-east-1:123456789012:log-group:/aws/cloudtrail	 Logging

- Record events via:
 - CloudTrail Console: Event history: Holds past 90 days of management events within an AWS region.
 - CloudTrail Lake: Events can be stored within the AWS data lake for audit and security. Data retention can be up to 7 or 10 years, if saved in a datastore.
 - Trail: AWS activities of interest are stored in an S3 bucket, while you can also choose to send those to CloudWatch or Amazon EventBridge.
- Microsoft Sentinel has a data connector called Amazon Web Services S3, which allows you to send CloudTrail logs from an S3 bucket.

CloudTrail logs contain metadata about API calls to AWS services (meaning management activity events performed using the API). It gives you numerous options to record and search events of interest:¹

- Event history:**² Supports searching events with lookup attribute and time range support. The upside here is that CloudTrail is enabled by default when you create an AWS account, and that automatically gives you access to CloudTrail's event history for up to 90 days of management activity (e.g., bucket querying, deletion/creation of users and resources). This is a free service. It supports recording activity performed via the AWS management console, AWS CLI, and AWS SDKs.
Console limitations: Supports up to 90 days of history. For anything more, it's advised to create an event data store and store items there. If you do, the default retention is 366 days, but you can extend up to 10 years. Also note that it doesn't store any non-management activities, like network or data-related events. If you intend to download event history data to a file, you can download 200,000 events per file.
- CloudTrail Lake:** Allows storing information for long-term access and analysis. To facilitate faster retrieval, it performs conversion of data to Apache ORC.³ If you send data to a data store, it allows archival for up to 10 years.
- Trail:**⁴ Data included in a trail gets stored in an AWS S3 bucket (storage takes place every 5 minutes and trails get dispatched to CloudTrail every 15 minutes, which means you might experience a delayed alert, if these events are used in a SIEM tool or other party solution), but you can also choose to send it to CloudWatch (discussed later) or EventBridge (allows you to build event-driven applications).⁵ Logs from trail S3 buckets can be easily sent to Microsoft Sentinel for analysis and rule creation.

AWS also has Insight Events available, which are second-order analytics generated by CloudTrail log monitoring. They're focused on abnormal activities, not security issues.

CloudTrail limitations:⁶

- It logs most API calls, but certainly not all of them. For example, using non-public APIs on the GUI

© SANS Institute 2025
may result in not logging that activity in CloudTrail. The DeepComposer (machine learning optimizer) and Trusted Advisor (supports cost optimization and performance increase) services are examples of that.

- Newer services often are not logged.
- The "Event time" field logs events in local time, not UTC. That can't be configured. If you are located in the UTC time zone, though, happy days. :)

1. <https://sec555.com/5sdt9>
2. <https://sec555.com/rmu7p>
3. <https://sec555.com/ncwph>
4. <https://sec555.com/y2czd>
5. <https://sec555.com/hz0uj>
6. SANS SEC541: Cloud Security Threat Detection

Accessing CloudTrail via Console

1. Click to show filters

2. Set desired attributes

3. Set desired time range

4. Download in CSV or JSON

CloudTrail lake settings

Lookup attributes

- AWS access key
- Event ID
- Event name
- Event source
- Read-only
- Resource name
- Resource type
- User name

Event name	Event time	User name	Event source	Resource type
GetBucketLocation	November 20, 2024, 17:28:34 (UTC+00:00)	sec555-evidence-lr...	s3.amazonaws.com	-
GetBucketLocation	November 20, 2024, 17:28:34 (UTC+00:00)	sec555-evidence-lr...	s3.amazonaws.com	-

GetBucketLocation details

Event time	November 20, 2024, 17:28:34 (UTC+00:00)	AWS access key	us-east-2
User name	sec555-evidence-lr...	Source IP address	Error code
Event source	s3.amazonaws.com	86.162	-
Event ID	435865a3-5fc1-4b6d-bca6-03a462961ea2	Event ID	Read-only
Request ID	KJ3VVT9WVRBKT5	Request ID	true

- Console helps keep things simple, especially if you're not entirely sure how to configure something.
- You can apply easy filtering for attributes of interest, set their values, and select an appropriate time range.
- Only exporting in CSV or JSON is supported (unless you are sending these to a third-party tool).

Accessing the CloudTrail console is very easy. After you log in to your AWS account, you choose CloudTrail, and you are presented with the service console. Choosing "Event History", depicted in the above image, allows you to apply filters and time ranges of interest to sort out the necessary events. The above filters can prove very powerful if you are searching for specific event names, usernames, or other items of interest. You can even choose which columns will be visible by a settings option on the right-hand side panel. But although the above information can be useful, the AWS CLI can also be used to gain more pinpointed data.

Selecting one of the two above event names will generate a detailed page of entries.

- **Event time:** Given in local time (e.g., November 20, 2024, 17:28:34 (UTC+00:00)). Note that you're not able to alter it.
- **Username:** The IAM role or user that performed an action (e.g., sec555-evidence-user).
- **Event name:** Shows the specific event taking place (e.g., get a bucket's location or list its contents).
- **Event source:** Designates which AWS service generated this (e.g., ec2.amazonaws.com).
- **AWS access key:** ID of which access key was used to submit this request.
- **Source IP address:** The source IP where the event was sourced from.
- **Event ID:** Unique identifier (GUID) created by CloudTrail to specify this event. This can be used to filter activity with a specific request ID.
- **Request ID:** Unique value identifying the request.

Accessing CloudTrail via AWS CLI

```
PS C:\Users\nikol\Documents\SANS\555\range info> aws cloudtrail lookup-events --lookup-attributes AttributeKey=EventName,AttributeValue=ListBuckets --max-items 2 --query 'Events[].[EventName,EventTime:EventTime,Username:Username]' --output table
```

LookupEvents		
EventName	EventTime	Username
ListBuckets	2024-11-20T17:34:46+00:00	sec555-evidence-lruen
ListBuckets	2024-11-20T17:30:38+00:00	sec555-evidence-lruen

Query 1: List buckets execution

```
PS C:\Users\nikol\Documents\SANS\555\range info> aws cloudtrail lookup-events --lookup-attributes AttributeKey=EventName,AttributeValue=GetBucketLocation --max-items 2 --query 'Events[].[EventName,EventTime:EventTime,Username:Username]' --output table
```

LookupEvents		
EventName	EventTime	Username
GetBucketLocation	2024-11-20T17:28:34+00:00	sec555-evidence-lruen
GetBucketLocation	2024-11-20T16:56:31+00:00	sec555-evidence-lruen

Query 2: List bucket location execution

```
PS C:\Users\nikol\Documents\SANS\555\range info> aws cloudtrail lookup-events --lookup-attributes AttributeKey=EventName,AttributeValue=GetBucketLocation --max-items 2 --query 'Events[].[EventName,EventTime:EventTime,Username:Username]' --output json
```

```
{
  "EventName": "GetBucketLocation",
  "EventTime": "2024-11-20T17:28:34+00:00",
  "Username": "sec555-evidence-lruen"
},
{
  "EventName": "GetBucketLocation",
  "EventTime": "2024-11-20T16:56:31+00:00",
  "Username": "sec555-evidence-lruen"
}
```

Query 3: List bucket location execution in JSON

```
aws cloudtrail lookup-events --lookup-attributes
AttributeKey=EventName,AttributeValue=ListBuckets --max-items 2 --query
'Events[].[EventName:EventName,EventTime:EventTime,Username:Username]'
--output table
```

You can easily interact with AWS using the CloudShell (available in the console), or you can download the AWS CLI client and connect it to the instance you need to manage or get information from. After downloading the tool, use the `aws configure` command to perform an initial setup and you're good to go.¹ In this example, the AWS CLI was used to look at CloudTrail events:²

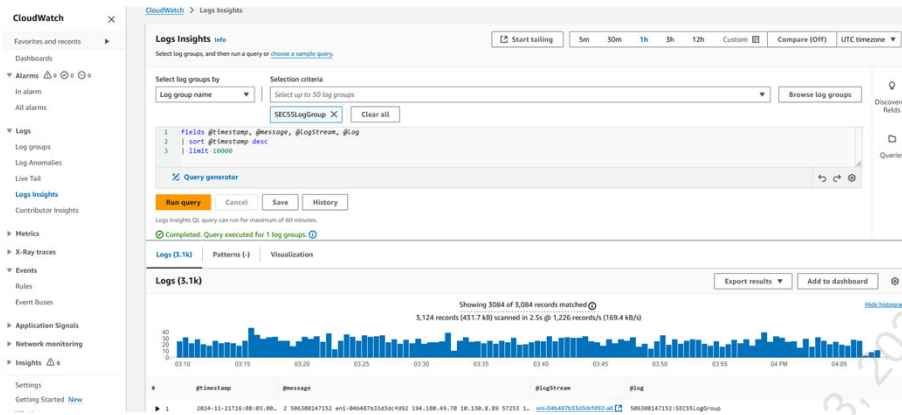
```
aws cloudtrail lookup-events --lookup-attributes
AttributeKey=EventName,AttributeValue=ListBuckets --max-items 2 --
query
'Events[].[EventName:EventName,EventTime:EventTime,Username:Username]'
--output table
```

Within the event history, there's a lookup attributes column picker, where this query is looking in the event name column, for a value of "ListBuckets", which means someone running the `listbuckets` command to get a list of the AWS buckets currently present. The query is limited to two rows while it is configured to display three interesting columns in a table format (those are the event name, event time, and username submitting this request).

Note that the query parameter is using the JMESPath query language to format the output. Apart from outputting it in a table, you can also choose JSON, YAML, or text.³

1. <https://sec555.com/gyjpn>
2. SANS SEC541: Cloud Security Threat Detection
3. <https://sec555.com/y4exw>

CloudWatch



CloudWatch stores log files from EC2 instances and other resources.

Monitor health and security of applications and AWS services, track metrics, set anomaly alerts, and search the logs for items of interest.

Ingest CloudTrail data and set alerts for specific activities.

Export interesting data to an S3 bucket for later use.

CloudWatch offers a good level of visibility into your services. It can collect various logs and be a central hub where you can configure alerts about your environment's health, plus any related security events of interest you desire. To that end, it supports two different logging classes to minimize cost.¹ There's a standard class for all CloudWatch logs that you require constant access to and need for real-time monitoring to take place. There's also an infrequent log class with lower pricing that caters to logs you require less frequently (e.g., when performing a post-mortem investigation or for any ad-hoc queries to your data). The most important thing to keep in mind is that you can't change the log class after the creation of a log group, so you need to take that into account carefully at the beginning.

Along those lines, also think carefully about configuring your desired retention period because CloudWatch stores logs indefinitely by default, so you need to scale that down, depending on your preferences. Supported timeframes begin from 1 day and reach up to 10 years.

You can also query your datasets either by using pre-created queries, modifying those, or creating your own from scratch. CloudTrail logs can be added in CloudWatch and then you can configure alerts for specific types of activities.

If you are using sensitive data, you can enable data protection on a particular log group, which allows that data to be protected, and even when that is part of a query result, it will still be masked, so you won't get accidental visibility into it.

It also supports container metrics and monitoring via Container Insights.²

1. <https://sec555.com/wav2j>

2. <https://sec555.com/onyg3>

CloudWatch Agent



Think of this as the Microsoft AMA equivalent.



Install on resources you need to monitor so they can relay data to CloudWatch log groups.



What kind of data?

Metrics (CPU utilization, hard disk read/write operations, network information, etc.).

Logs (OS or application logs from macOS, Linux, and Windows systems).

To allow CloudWatch to get the required information, an agent needs to be installed on the monitored resources. If you remember the earlier discussion about Microsoft Azure's AMA (Azure Monitoring Agent), then think of the CloudWatch agent as that equivalent resource. CloudWatch currently supports macOS, Linux, and Windows operating systems. You can install the agent using the CLI, the AWS Systems Manager (preferred for installations at scale), or install on devices residing on-premises.¹ Once installed, the agent can provide useful insight via monitored metrics (e.g., statistics about host and network operation) and logs being forwarded to CloudWatch for further analysis (application logs from various apps running on the monitored host and operating system logs²). When performing configuration, you will need to choose what the required metrics and logs are to satisfy the use cases and requirements of your environment.³ Remember, if you log too much, then the cost of storing that data becomes excessive, and most organizations would struggle. You can always use long-term storage solutions (also known as cold storage options) for some data, but when you need to access it, it takes time, and that may not be ideal. Then again, if you trim down your collection to only a handful of things, you may end up missing some critical log entry or metric monitoring that could have helped you detect and/or respond to a security incident. The advantage is that you can configure all these options within the CloudWatch agent, and you can define what items you need to be forwarded, while dismissing anything else that may not be of interest.

1. <https://sec555.com/bkq72>
2. <https://sec555.com/x8gsm>
3. <https://sec555.com/w380i>

CloudWatch Agent Configuration: Agent and Metrics Sections

```

"agent": {
  "metrics_collection_interval": 20,
  "region": "us-west-2",
  "logfile": "/opt/aws/amazon-cloudwatch-agent/logs/amazon-cloudwatch-agent.log",
  "debug": true,
  "run_as_user": "cloudwatchagent"
}
"metrics": {
  "metrics_collected": {
    "cpu": {
      "measurement": [
        "cpu_usage_idle",
        "cpu_usage_iowait"
      ]
    }
  }
}

```

How frequently do metrics get collected (defined in seconds)?

CloudWatch endpoint region

CloudWatch agent write log location

Debug level messages

User running the CloudWatch agent

Define metrics that require collection

An example configuration for the agent and metrics section is:

```

"agent": {
  "metrics_collection_interval": 20,
  "region": "us-west-2",
  "logfile": "/opt/aws/amazon-cloudwatch-agent/logs/amazon-cloudwatch-agent.log",
  "debug": true,
  "run_as_user": "cloudwatchagent"
}
"metrics": {
  "metrics_collected": {
    "cpu": {
      "measurement": [
        "cpu_usage_idle",
        "cpu_usage_iowait"
      ]
    }
  }
}

```

Agent section of the configuration:¹

- The **metrics_collection_interval** is an optional field for how frequent you need collection to take place (default value is 60 seconds, but in the above example, it has been set at 20 seconds).
- The **region** is set at us-west-2 and specifies the CloudWatch endpoint region. Note that if you don't explicitly fill in this field, the region will default to the one EC2 is already in.
- The **logfile** parameter is used to define where the CloudWatch agent will write the log messages.

- The **debug** parameter is optional and should only be set to true if you require debug messages. If not, set to false.
- The **run_as_user** parameter denotes the user running the CloudWatch agent. This is an optional field. Note: The default user is a root user.

Metrics section of the configuration:²

- The **metrics_collected** section denotes which metrics are to be collected. In this example, `cpu_usage_idle` is used to measure the percentage of time that the CPU is idle, while `cpu_usage_iowait` measures the percentage of time the CPU is waiting for I/O (input/output) operations to complete.³ Do note that there are additional optional fields not mentioned here to provide more clarity.

1. <https://sec555.com/gjors>
2. <https://sec555.com/gjors>
3. <https://sec555.com/wlsz6>

CloudWatch Agent Configuration: Logs Section

```
"logs": {
  "logs_collected": {
    "files": {
      "collect_list": [{
        "file_path": "/var/log/apache2/access.log",
        "log_group_name": "SEC55LogGroup"
      }]
    }
  }
}
```

Use it if you are configuring logs for collection

Files for collection

Specify file path of collected file/files

Define the log group that logs will be sent to

- Collect files (use the files parameter) or Windows events (use the windows_events parameter).
- Recommended to configure the destination log group explicitly.
- Be careful when creating a new log group, as its class can't be changed later.

There are two object types you can collect: Files and Windows activities (designated by parameter windows_events).¹

- The **logs_collected** section is a required item if the logs section is present. This is where you will state which log files or Windows events you need to collect.
- The **files** section is used to define the files requiring collection. It contains a single parameter, which is named **collect_list**, which has entries of those log files. If you are defining Windows events, this is used to specify types and levels.
- The **file_path** parameter states the file location that needs to be collected and uploaded to CloudWatch. If you need more than one file (e.g., everything under apache2), you can use /var/log/apache2/*.log.
- The **log_group** name is an optional parameter, but it is highly recommended that you use it to send your desired logs to a specific log group of interest, which you have already configured in CloudWatch. If, for some reason, that group doesn't exist, then it gets created. But if that happens, note that the newly created log group will have the default retention period, which is indefinite. You then need to manually configure it differently.
- Another useful optional parameter to note is **log_group_class**. That can be set to **STANDARD** or **INFREQUENT_ACCESS**, to reflect which of the two log classes you are using: the standard or the infrequent one.

There's also a full breakdown of parameters, including optional values and example configurations.²

1. SANS SEC541: Cloud Security Threat Detection
2. <https://sec555.com/y980e>

CloudWatch Log Groups

Choose log class (standard or infrequent)

Retention period selection is vital

Log class type can't be altered later

Use Logs Insights for a query-based input for filtering data

Numerous actions exist to configure your log group

Set desired retention period ("never expire" set by default)

Actions menu:

- Delete log group
- Edit retention setting
- Create metric filter
- Create data protection policy
- Subscription filters
- Create Contributor Insights rule
- Export data to Amazon S3
- View all exports to Amazon S3

Logs Insights query:

```
1 fields @timestamp, @message, @LogStream, @Log
2 | sort @timestamp desc
3 | limit 10000
```

As noted in the previous page, you need to select a log class for your log group, which can't be altered afterward.

The default retention period (never expires) should also be altered to reflect your needs. Note that the logs will be automatically deleted when the retention period is reached.

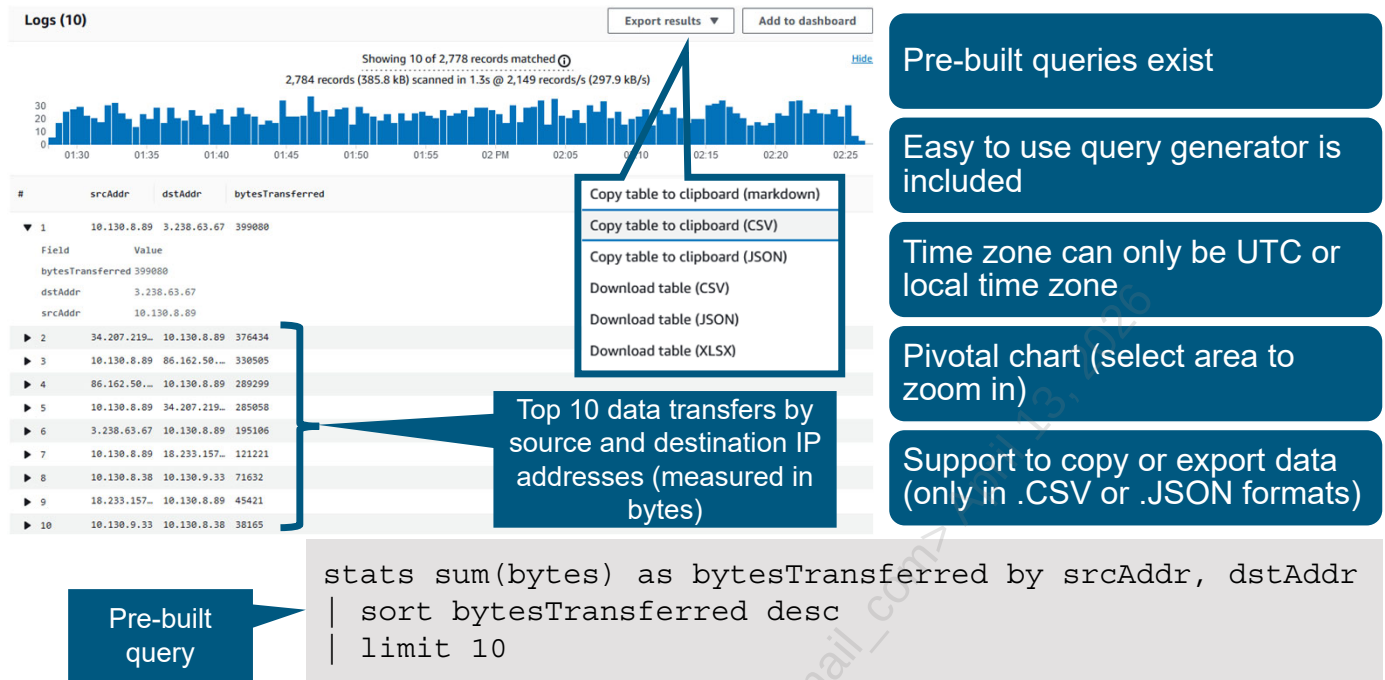
Log groups reflect collections of logs. Although they can support multiple streams, it would be highly beneficial if each log group contained one stream, reflecting a particular log type of interest. That also simplifies things because you will have a specific log type contained in that group (e.g., only Windows web server device logs).

Within the **Actions** menu, you can find numerous supported activities:

- Edit your current log group retention settings.
- Create a metric filter allowing monitoring events across CloudWatch logs.
- Create a data protection policy for sensitive data.
- Create Contributor Insight rules, which can support visibility on identification of unique contributor metrics, top talkers, service-impacting points, and more.
- Export data to an S3 bucket, in case you need to obtain and keep data relating to a specific investigation you are performing.
- View S3 data exports.

Selecting "View in Logs Insights" allows you to pivot over to a query interface where you can submit queries for data extraction.

CloudWatch Logs Insights



CloudWatch Logs Insights gives you the option to run queries in an easy-to-use interface. When performing queries, take into account the following AWS best practices:¹

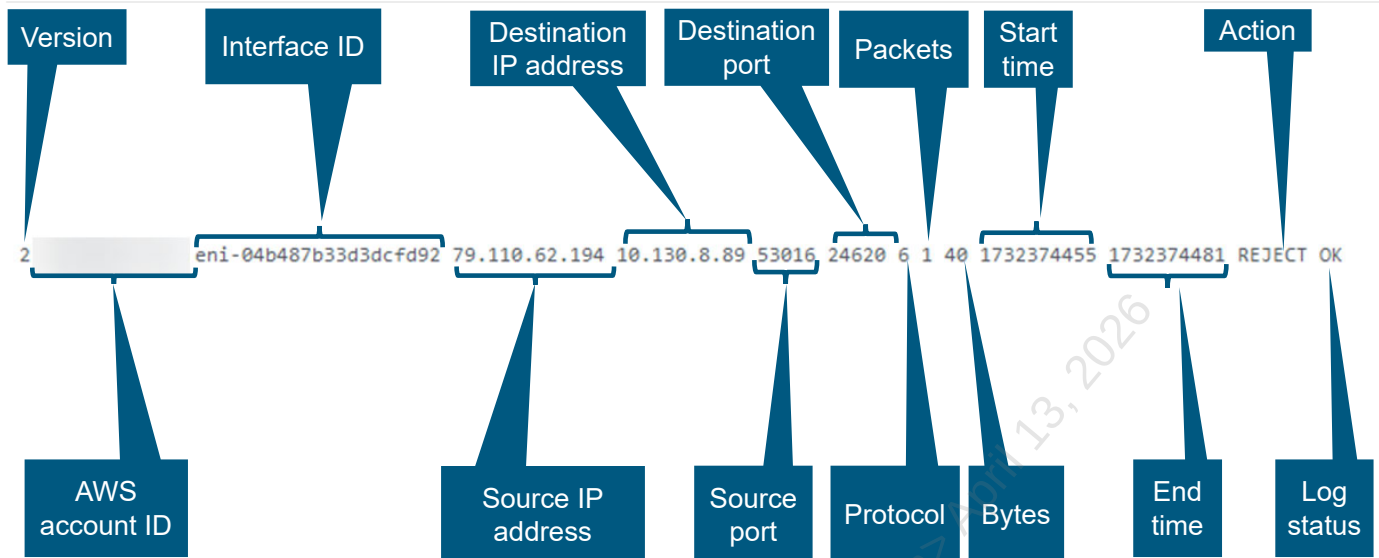
- Limit the log groups you're querying. CloudWatch supports querying up to 20 log groups, but if you can limit that down to 1, it would be great. The more limiting you are, the more efficient and less time-consuming the query you run.
- As in any security search, time matters. Try to limit the time frame of interest so you can be efficient and quick in performing your search.
- **Important:** Before running a new query in the console, cancel all existing queries. If you don't, they will keep running and consume resources and possibly degrade performance (depending on how intense your query is).

If you need to export data, you can do so in CSV or JSON. One of the downsides is that, sadly, the only supported time zones you can use are either your local time zone or UTC. There's nothing else.

Also note that CloudWatch automatically detects log fields for VPC flow logs, Route 53, Lambda, and CloudTrail.²

1. <https://sec555.com/qud1p>
2. <https://sec555.com/eoxt6>

Flow Logs



Get your VPC flow logs configured and sent to CloudWatch or an S3 bucket.

VPC flow logs are great for inspecting captured traffic going in or out of your VPC (Virtual Private Cloud). Once created, you can either store them using CloudWatch or send them to an S3 bucket or use Amazon Data Firehose to send them into a data lake for pattern identification and big data analytics.¹ The field meanings are as follows:²

- **Version (version):** Shows the flow log version in use. Default is version 2 (like in the above image).
- **AWS account ID (account-id):** Denotes the AWS account ID of the owner of the origin interface that traffic is recorded from. If this is showing "unknown", it usually means an AWS service has created the interface. In the above image, the AWS account ID has been masked for privacy.
- **Interface ID (interface-id):** Network interface of which you are recording traffic (in the above example, that is eni-04b487b33dedcfd92).
- **Source IP address (srcaddr):** If the traffic is inbound, this is the source IP address of the incoming packet(s). If traffic is outbound, this is the private IP address of the network interface for that outgoing traffic. In this example, the source IP is 79.110.62.194.
- **Destination IP address (dstaddr):** If the traffic is outbound, this is the destination IP address of the outbound packet(s). If traffic is inbound, then this is the private IP address of the network interface the traffic is coming into. In this example, the destination IP is 10.130.8.89 (falling in the private Class A IP address range (10.0.0.0-10.255.255.255)).
- **Source port (srcport):** Traffic source port. The above source port is 53016.
- **Destination port (dstport):** Traffic destination port. The above destination port is 24620.
- **Protocol (protocol):** IANA protocol number for the traffic.³ In this example, the protocol is 6, which denotes TCP.
- **Packets (packets):** Number of packets within this flow. 1 indicates one packet only.
- **Bytes (bytes):** Number of bytes transferred during this flow. In this example, 40 bytes were sent.
- **Start time (start):** First packet start time (in Unix Epoch format). Using an online Epoch to human time converter⁴ and inputting the start time of 1732374455 shows that it represents 24 November 2024 14:48:56 GMT.

- **End time (end):** Last packet received time (also in Unix Epoch format). Using the pre-mentioned converter and inputting the end time of 1732374481 shows that it represents 24 November 2024 14:52:08 GMT.
- **Action (action):** The action can have two values: ACCEPT (meaning that the traffic was accepted) or REJECT (meaning the traffic was rejected). A typical reason for that is due to an access control list. In the above example, the traffic was rejected.
- **Log status (log-status):** Flow logging status. Can be OK (meaning data is logged normally), NODATA (meaning there was no traffic to or from the network interface during the timeframe in question), or SKIPDATA (some flow log records were skipped, maybe due to an error or other issue).

AWS has numerous flow log examples available for review in their documentation.⁵

1. <https://sec555.com/waiu5>
2. <https://sec555.com/7w4ze>
3. <https://sec555.com/aybpf>
4. <https://sec555.com/o4zpe>
5. <https://sec555.com/z2xl9>

Flow Log Version Comparison

Version	Key Items
2	Basic flow log fields: Version, source and destination IP addresses and ports, protocol, action, account ID, interface ID, packet and byte numbers, start and end times, and action.
3	Added metadata like VPC ID, subnet ID, instance ID, TCP flags (FIN -1, SYN - 2, RST - 4, SYN-ACK - 18), type of traffic, and packet level source and destination IP addresses.
4	Enriched with details such as the AWS region of the network interface of the recorded traffic, the ID of the availability zone, and the sublocation type and ID (allowing more information to be identified about the network interface for which traffic is recorded).
5	Includes fields like pkt-src-aws-service and pkt-dst-aws-service, which denote the source/destination AWS services (examples include CLOUDFRONT, ROUTE53, EC2_INSTANCE, etc.). Also includes the flow-direction, which designates the direction of the flow relative to the interface traffic is captured on. Finally, the traffic-path shows the path that egress traffic takes to a destination (values are from 1 to 8, i.e., 3 indicates traffic went through a virtual private gateway).
6	Added fields like packets-lost-no-route (packet lost due to no existing route), packets-lost-blackhole (packets lost due to black hole), packets-lost-mtu-exceeded (packets lost due to MTU being exceeded), packets-lost-ttl-expired (packets lost due to expired TTL).
7	Added quite a lot of container information. AWS resource name of the ECS cluster, name of ECS cluster, ECS container ID, container instance ID, container ARN, and a few more.
8	Added reject-reason, indicating why traffic was rejected.

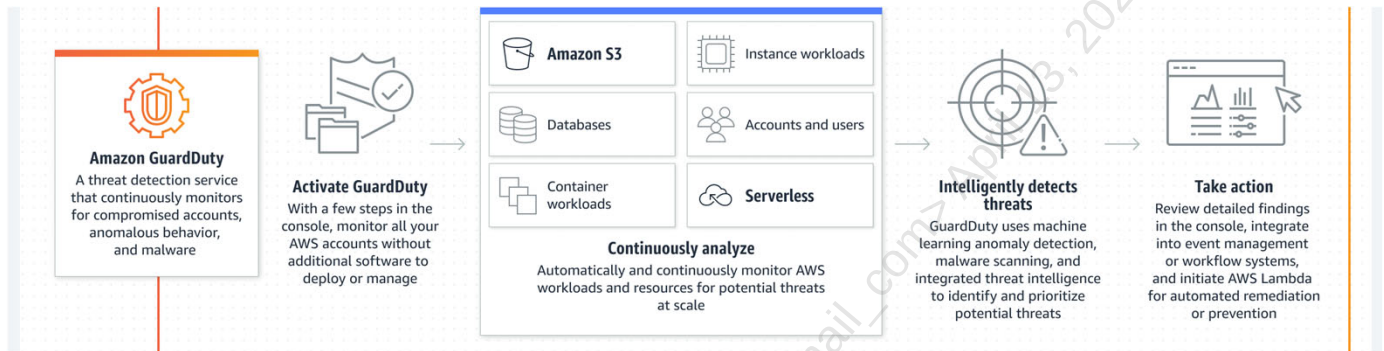
The above page presents a quick comparison of the different versions of flow log records for your awareness. Note that the default version in use is version 2 in most AWS security services. But there are examples of encountering different flow log record versions at times. For example, Amazon VPC transit gateways use versions 2 to 6. ECS containers use version 7. It's useful to identify what additional details can be provided by each of these flow log record versions, as that can be very handy in both security investigations and troubleshooting network issues.

References:

- <https://sec555.com/rdin4>
- <https://sec555.com/zicn2>

GuardDuty

- ML, anomaly detection, and malicious file discovery, shielding your environment.
- It can:
 - Protect S3 storage objects, RDS databases, and EKS Kubernetes.
 - Perform malware monitoring of various objects, like EC2 instances and S3 buckets.
 - Monitor VPC flow logs.



GuardDuty works around the clock to detect suspicious activity and report findings to you for awareness and further actioning. It mainly uses three technologies:

- Machine learning.
- Anomaly detection.
- Malicious file discovery.

It analyzes numerous data sources, like CloudTrail logs, Virtual Private Cloud (Amazon VPC) flow logs, and DNS query logs. It monitors S3 data events, Amazon Aurora login events, and runtime activity for Amazon Elastic Kubernetes Service (Amazon EKS), Amazon Elastic Compute Cloud (Amazon EC2), and Amazon Elastic Container Service (Amazon ECS).

It can detect attacks (such as reconnaissance, instance/account/bucket compromises) and uses three prioritization levels: Low, Medium, and High. If configured, it can perform automatic response actions to remediate security incidents.

Although it actively protects your monitored resources from malware, you can also initiate a manual (on-demand) scan by specifying the ARN.

Let's take a look at a finding example.

Reference:

- <https://sec555.com/eo6fp>

Image reference:

- <https://sec555.com/eo6fp>

GuardDuty Detection on S3 Bucket Public Access

Low Amazon S3 Block Public Access was disabled for the S3 bucket mytest123456789-344k by sec555-evidence-lruen calling PutBucketPublicAccessBlock. If this behavior is not expected, it may indicate a configuration mistake or that your credentials are compromised. [Info](#)

Overview

Incident severity, region, count, resource ID	Severity	LOW	Classified as low?
	Region	us-east-2	
	Count	1	
	Account ID		Impacted bucket
	Resource ID	mytest123	
	Created at	11-24-2024 17:16:56 (40 minutes ago)	
	Updated at	11-24-2024 17:16:56 (40 minutes ago)	

Classified as low?

Impacted bucket

Affected resources

AWS::S3::Bucket mytest123

S3 buckets

Destination: mytest123

Name	mytest123
Type	Destination
ARN	arn:aws:s3::mytest123

Default server side encryption

Encryption type AES256

Phew, at least it's encrypted

Action

Action type AWS_API_CALL
Service name s3.amazonaws.com

Action taken

Actor

IP address V4 119.29.119.187

Port 34532

Location

City Guangzhou

Country China

Lat 23.1181

Lon 113.2539

Originating IP address information

Organization

Asn 45090

Asn org Shenzhen Tencent Computer Systems Company Limited

Isp Tencent cloud computing

Org Tencent cloud computing

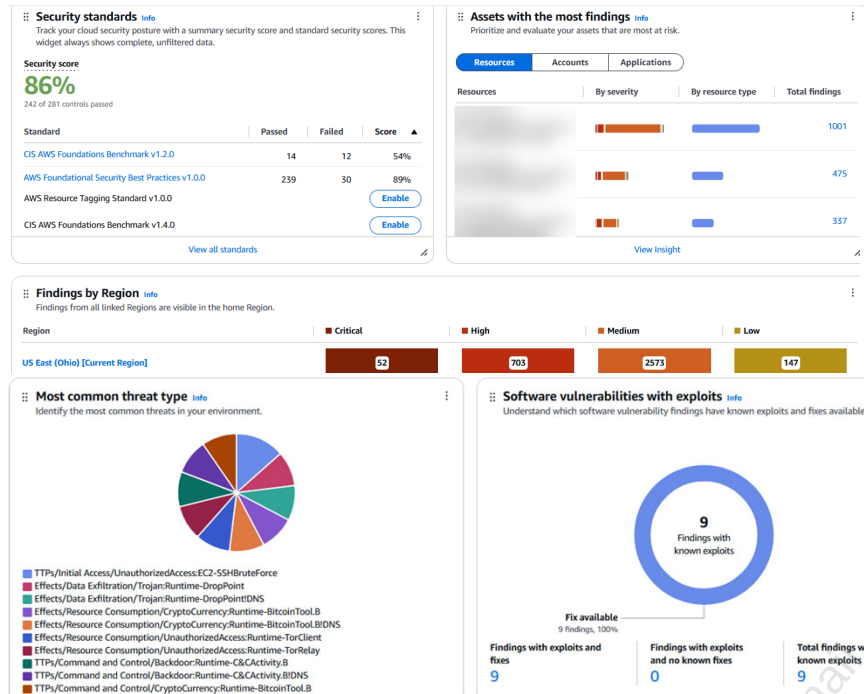
IP lookup in VirusTotal shows this is malicious



Key items of interest:

- At the top left corner, you can see the incident prioritization that GuardDuty assigned for this one (set as "Low").
- In the overview section, you can see details about the incident severity, impacted region, count (showing how many identical findings were there; for example, if the actor accessed the bucket 50 times, this would be 50), AWS account ID (redacted for privacy) and impacted resource ID, as well as when the object was created and last updated.
- At the affected resources and S3 buckets sections, you can see information about the bucket (including the object's ARN—Amazon Resource Name).
- Server-side encryption shows you the encryption type (here, the largest size of AES key has been chosen).
- In the action section, you can see that an API call was made to the bucket.
- The actor, location, and organization sections give you information about this access. The source IP address was 119.29.119.187, and the activity was originating from China.
- A quick lookup in VirusTotal shows this as being malicious (<https://www.virustotal.com/gui/ip-address/119.29.119.187/detection>).

AWS Security Hub



- Great one-stop shop of information.
- Really good for reporting and measuring for company compliance (supports CIS, AWS, NIST 800-53, and PCI DSS standards).
- Very useful to measure exposure points and classify by desired prioritization metric (e.g., resource, account, application, region).

The AWS Security Hub can provide immense insight in a very quick manner, so you can identify and focus on sources of attention. You can enable and measure compliance against multiple standards, such as:

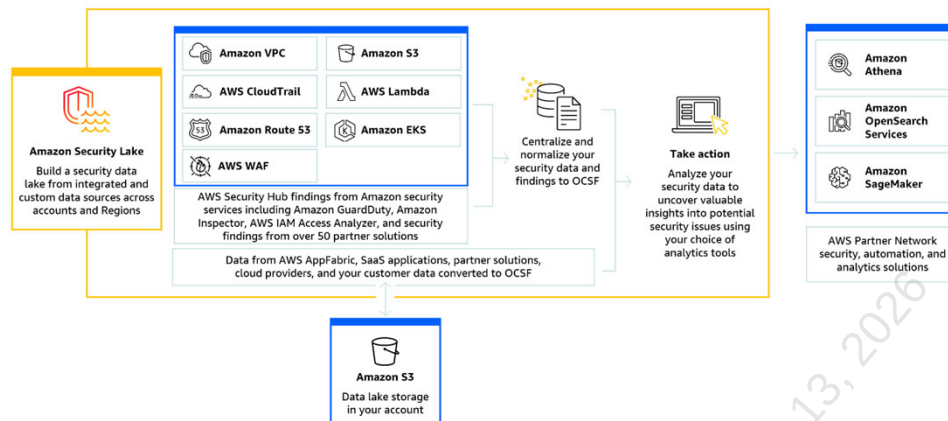
- **AWS Foundational Best Practices:** This is a list of best industry practices, created by AWS and industry professionals.
- **CIS AWS Foundations Benchmark:** Provides AWS resources configuration guidelines.
- **NIST SP 800-53:** A document by NIST, which is almost 500 pages long and contains about 1,000 security and privacy controls, out of which numerous have been selected for inclusion in AWS.
- **PCI DSS:** Applicable for organizations like banks or major retailers, which regularly store, process, and transmit cardholder information.

At the same time, you can pivot against the numerous available dashboards and start working on assets that have various weaknesses. Another great advantage of the security hub is that you can create automations (under Management > Automations) and trigger specific actions based on templates or from scratch. Your rules can apply to numerous criteria, and once they match, you can trigger actions like updating workflow statuses, severity levels, and more.

Reference:

- <https://sec555.com/w87b9>

Amazon Security Lake



- Data aggregation
- Data transformation and normalization
- Multiple levels of access
- Data Lifecycle management and optimization
- Access via:
 - AWS Console
 - Security Lake API
 - AWS CLI
 - AWS SDKs

Amazon's Security Lake can act as a main collection hub of information. It can be used to pull in AWS services logs (e.g., CloudTrail, VPC flows, S3 storage, EKS, WAF, Security Hub, and many more), Azure, other cloud data, and on-premises logs, and all of that can be roped into a considerably large data lake, which can continue to grow. That can later be used for pattern identification by applying machine learning and AI algorithms and tools. You can use multiple analytical tools, provided you point them to your lake. A typical example is the Amazon OpenSearch Service, which can be used to search and analyze big datasets. Maintaining compliance becomes more straightforward as you can collect and aggregate all your log data in a single location. Visibility and incident handling also become faster and possibly easier, because all of your data is now consolidated in a central location, which you can query. If you require less visibility, then you can configure access based on supported regions and AWS accounts. All the pre-mentioned options can be used to manage your lake (AWS console, API, AWS CLI, and SDKs).

Reference:

- <https://sec555.com/ngvmf>

Image reference:

- <https://sec555.com/ngvmf>

Summary

Select your AWS services of interest, enable them, and configure the appropriate logging levels. Use CloudWatch to gain environmental health visibility and select your log class of interest. Configure flow logs to capture traffic flow information so you have visibility of what goes in and out of your VPCs.

Use CloudTrail to monitor management events around your AWS tenant's activities. Utilize GuardDuty to enhance bucket and instance protection.

This area is intentionally left blank.

Creating an AWS Lab, Configuring and Testing CloudWatch

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Contacts and Resources

AUTHOR

Nick Mitropoulos

nick.mitropoulos@scarlet-dragonfly.com

@NickMitropoulos

www.linkedin.com/in/nickmitropoulos

Nick is the CEO of Scarlet Dragonfly, a company that handles a range of security services like SOC, incident handling, and vulnerability management, to name a few. He has over 16 years of experience in various industries, including consulting, education, telecommunications, healthcare, investment banking, financial, energy, oil and gas, insurance, pharmaceutical, law, military, and news. His breadth of experience, combined with his love for teaching, is crucial in helping his students better grasp the various facets of security.

Nick started collecting hacking newspaper articles back in the 80s when security was just starting to grow, and he was immediately hooked. He is a certified ISC2 instructor and a GIAC advisory board member, and he has an MSc (with distinction) in Advanced Security and Digital Forensics from Edinburgh Napier University and a BSc (with distinction and the highest held graduation grade of the department) from the Technological Educational Institute of Thessaly. He is also a faculty member of the SANS Technology Institute, an NSA Center of Academic Excellence in Cyber Defense, and a multiple winner of the National Cyber League competition. Nick has a great passion for teaching and has trained many individuals in a variety of security topics, mainly focusing on SIEM, security operation centers, incident response, and security certification courses.

Nick has worked for a variety of companies (including the Greek Ministry of Education, AT&T, F5 Networks, JP Morgan Chase, KPMG, and Deloitte) and has provided critical advice to many clients that want to improve their current security posture by creating new security operation centers and protocols, developing vulnerability management programs, managing third parties and security vendors, testing incident handling and forensic teams, redesigning perimeter security solutions, and developing custom-tailored training courses for company staff and specialized security teams. One of the greatest challenges for most security professionals is ensuring they have an in-depth understanding of all fundamental concepts of security. Nick loves teaching classes that help students obtain the knowledge required to secure their environments and enhance their personal security posture to protect themselves in an ever-growing digital arena.